



1ST EDITION

Microsoft Security Copilot

Master strategies for AI-driven cyber defense



BI YUE XU | ROD TRENT

Microsoft Security Copilot

Master strategies for AI-driven cyber defense

Bi Yue Xu

Rod Trent



Microsoft Security Copilot

Copyright © 2025 Packt Publishing

All rights reserved. No part of this book may be reproduced, stored in a retrieval system, or transmitted in any form or by any means, without the prior written permission of the publisher, except in the case of brief quotations embedded in critical articles or reviews.

Every effort has been made in the preparation of this book to ensure the accuracy of the information presented. However, the information contained in this book is sold without warranty, either express or implied. Neither the authors, nor Packt Publishing or its dealers and distributors, will be held liable for any damages caused or alleged to have been caused directly or indirectly by this book.

Packt Publishing has endeavored to provide trademark information about all of the companies and products mentioned in this book by the appropriate

use of capitals. However, Packt Publishing cannot guarantee the accuracy of this information.

Portfolio Director: Vijin Boricha

Relationship Lead: Anindya Sil

Program Manager and Growth Lead: Ankita Thakur

Project Manager: Gandhali Raut

Content Engineer: Tazeen Shaikh

Technical Editor: Nithik Cheruvakodan

Copy Editor: Safis Editing

Indexer: Tejal Soni

Proofreader: Tazeen Shaikh

Production Designer: Pranit Padwal

First published: July 2025

Production reference: 1180725

Published by Packt Publishing Ltd.

Grosvenor House

11 St Paul's Square

Birmingham

B3 1RB, UK.

ISBN 978-1-83588-452-2

www.packtpub.com

I dedicate this book to my extraordinary mother, Xu Yun. Like a phoenix soaring from the ashes, she transformed the obstacles and hardships of her youth in China into a life defined by determination, courage, and inspiring achievement.

Equally, I dedicate this book to my fearless leader and mentor, Pavan Ethhiraj. Thank you for always seeing my potential, even when I couldn't.

– Bi Yue Xu

This book is dedicated to Megan—my guiding algorithm, whose steady logic helps me navigate life's complexities. To Alex, Rachel, Eric, and Elly—your insights and curiosity continually refine my thinking. To Reid and Meredith—may your data be rich, your minds curious, and your hearts empathetic. And to my entire family—you are my Copilot, co-authoring a life of meaning with me.

– Rod Trent

Contributors

About the authors

Bi Yue Xu is a seasoned Principal Security Cloud Solution Architect at Microsoft, with over 15 years of experience in cybersecurity. Specializing in Digital Forensics and Incident Response, she is a Certified Windows Forensics Examiner (EnCE) and holds multiple security certifications, including GREM, GCFA, GCIA, GWAPT, GCWN, SC100, SC200, SC900, and others. Bi Yue's expertise is showcased in her work, from designing and developing a comprehensive four-day Defender for Endpoint training course, which has been delivered to over 300 organizations across 44 countries since its inception two years ago, to creating custom KQL detection and hunting queries, and even uncovering attacks related to zero-day.

I would like to extend my heartfelt thanks to my family for their patience, understanding, and unwavering support as I poured long hours into writing this book, often at the expense of missing family events. I am also grateful to Daniel P. Huynh and Aastha Sahni for their insightful feedback and the time they devoted to reviewing this book. Lastly, I would like to thank the entire Packt team for their support during the course of writing this book.

Rod Trent is a Senior Product Manager for Microsoft, where he focuses on the intersection between Security and AI. In his spare time, Rod writes KQL queries, authors fiction and nonfiction books, shares proud stories about his

grandkids, boasts about his Six Million Dollar Man addiction, and teaches AI to behave.

About the reviewers

Daniel P. Huynh is a cybersecurity expert and army veteran, currently serving as a Principal Product Manager at Microsoft. With a distinguished career in incident response and security operations, he has made significant contributions to both the private sector and the U.S. Army. Daniel holds Computer Science degrees from the United States Military Academy at West Point and the Naval Postgraduate School, along with numerous industry certifications. Renowned for his leadership and dedication, Daniel is committed to mentoring the next generation of cybersecurity professionals while driving innovation and excellence in the field.

Aastha Sahni is a seasoned cybersecurity professional with over seven years of experience, specializing in identity and access management, application security, SIEM, threat hunting, Azure cloud, and vulnerability management. She began her career as an engineer, transitioned to a technical trainer role, and is now a tenured security analyst at Microsoft.

In addition to her technical expertise, Aastha is a passionate advocate for diversity and inclusion, empowering women in cybersecurity through initiatives such as the BBWIC Foundation, which she founded. She also extends her impact as a mentor at WiCyS, TopMate, and WomenTechNetwork. Aastha has been an ambassador for Snyk, actively contributing to the cybersecurity community, and has served on the board of the Diana Initiative.

Preface

Be at the forefront of cybersecurity innovation with Microsoft Security Copilot, where advanced **artificial intelligence (AI)** tackles the intricate challenges of digital defense. This book unveils Security Copilot's powerful features, from AI-powered analytics revolutionizing security operations to intelligent orchestration that streamlines incident response and threat management. Through real-world case studies and frontline stories, you'll learn how to truly harness AI advancements and unlock the full potential of Security Copilot within the expansive Microsoft ecosystem.

Designed for security professionals navigating increasingly sophisticated cyber threats, this book equips you with the skills to accelerate threat detection and investigation, refine your security processes, and optimize cyber defense strategies. You will discover that Security Copilot is more than just a tool; it is your trusted partner in the fight against cyber threats, empowering you to work smarter, respond faster, and stay ahead of ever-evolving threats.

By the end of this book, you'll have become a Security Copilot ninja, confidently crafting effective prompts, designing promptbooks, creating custom plugins, and integrating logic apps for enhanced automation.

Who this book is for

This book is for cybersecurity professionals at all experience levels, from beginners seeking foundational knowledge to seasoned experts looking to stay ahead of the curve. While readers with basic cybersecurity knowledge will find the content approachable, experienced practitioners will gain deep insights into advanced features and real-world applications.

What this book covers

[Chapter 1](#), *Elevating Cyber Defense with Security Copilot*, introduces you to the world of AI, outlining its evolution from foundational principles to cutting-edge technologies. The chapter details how AI is fueling innovative advancements with a specific focus on Microsoft Copilot.

[Chapter 2](#), *Unveiling Security Copilot through Its Embedded Experience*, formally introduces Security Copilot to you by showcasing it in action. It highlights Security Copilot's core features across various embedded experiences and provides an introduction to the standalone experience.

[Chapter 3](#), *Navigating the Security Copilot Platform*, walks through Security Copilot's onboarding process and reviews its user interfaces after you have become acquainted with the platform. Following that, it presents a case study to demonstrate how Security Copilot can be applied in a real-world security incident investigation, offering a hands-on view of its practical use.

[Chapter 4](#), *Extending Security Copilot's Capabilities with Plugins*, highlights how plugins enable Security Copilot to expand and adapt to diverse needs. The chapter covers the preinstalled plugins as well as third-party offerings. It also provides insights into the development and use of custom plugins designed to address specific security requirements.

[Chapter 5](#), *The Art of Prompt Engineering*, takes a closer look at the techniques behind crafting clear, well-structured prompts. It introduces practical strategies for building effective prompts and shares best practices to support successful prompt engineering.

[Chapter 6](#), *The Power of Promptbooks in Security Copilot*, introduces promptbooks by exploring their role within the platform. This chapter highlights a range of prebuilt promptbooks, then offers guidance on creating custom ones tailored to specific security scenarios. It concludes with sample promptbooks and practical tips to support effective implementation.

[Chapter 7](#), *Automation and Integration – The Next Frontier*, introduces the **Security Copilot Logic Apps connector** and demonstrates its integration with **Azure Logic Apps workflows** that enable more customizable automation. This chapter also covers how Security Copilot can harness organization-specific insights through its file upload feature and the **Azure AI Search** plugin.

[Chapter 8](#), *Cyber Sleuthing with Security Copilot*, brings together the key concepts covered in earlier chapters by walking through a real-world **Microsoft Defender XDR** incident investigation. It also offers practical insights and strategies, including the use of custom plugins and the chaining of promptbooks, to enhance investigation workflows.

[Chapter 9](#), *Harnessing Security Copilot within the Microsoft Ecosystem*, presents additional case studies that demonstrate the practical application of Security Copilot. It illustrates how the platform supports analysts in examining user behavior, tracking suspicious activity, and detecting signs of account compromise. It also highlights how Security Copilot can streamline device comparisons and identify policy conflicts through its Intune plugin.

[Chapter 10](#), *Frontline Tales with Security Copilot*, continues with additional case studies that highlight Security Copilot's real-world impact. It demonstrates how the platform can track attacker infrastructure and transform threat intelligence into actionable insights. It also illustrates how

Security Copilot delivers strategic guidance to help chief information security officers to stay ahead of emerging threats.

[Chapter 11](#), *The Pricing Model in Security Copilot*, walks through the role of **Security Compute Unit (SCUs)** in the Security Copilot ecosystem. It details Security Copilot's pricing structure and cost calculation. It also offers practical guidance on cost optimization and highlights strategies to improve efficiency.

To get the most out of this book

- It's ideal to have some familiarity with the following foundational technologies and concepts. If you're new to these topics, don't worry; key ideas are introduced and explained throughout the book. That said, a basic understanding will make it easier to contextualize the material and follow along more effectively:
- A general understanding of cybersecurity operations and concepts, such as incident response, threat detection, and the attack life cycle
- A working knowledge of Microsoft Defender security solutions
- Some familiarity with scripting or automation workflows, such as **Kusto Query Language (KQL)** or Azure Logic Apps
- A basic awareness of AI concepts, including **large language models (LLMs)**, prompt engineering, and generative AI, though [Chapter 1](#) will give you an introductory refresher

Download the example code files

The code bundle for the book is hosted on GitHub at <https://github.com/PacktPublishing/Microsoft-Copilot-for-Security>. We also have other code bundles from our rich catalog of books and videos available at <https://github.com/PacktPublishing>. Check them out!

Download the color images

We also provide a PDF file that has color images of the screenshots/diagrams used in this book. You can download it here: <https://packt.link/gbp/9781835884522>.

Conventions used

There are a number of text conventions used throughout this book.

CodeInText: Indicates code words in text, database table names, folder names, filenames, file extensions, pathnames, dummy URLs, user input, and Twitter/X handles. For example: “For instance, when inquiring about error code `0xC7D14FBA`, Security Copilot explains that this error occurs because the app installation failed due to the necessary file being deleted before the process finished.”

User prompts are written as follows:



```
Can you explain in more detail about the following event: servic
```

Copilot outputs are displayed as:

The provided command line script executes a file named “jyglecpm.1v0.exe” in a hidden window. It then uses the ‘-encodedCommand’ parameter to run a base64-encoded command. The base64 string decodes to a PowerShell script located at ‘C:\Scripts\ExportADFSTokenSigningCert.ps1’. This suggests that the script is likely used to execute a hidden process and then run a PowerShell script, possibly for malicious purposes.

A block of code is set as follows:

```
Table = <tablename>
Time/Date range = <time range>
Query = <query processing example: the top medium severity aler
Display = <how the results are displayed example: just the aler
```

Bold: Indicates a new term, an important word, or words that you see on the screen. For instance, words in menus or dialog boxes appear in the text like this. For example: “Scroll to the bottom of the **Manage Sources** page, and within the **Custom** section, you’ll find an **Add plugin** option.”



Warnings or important notes appear like this.



Tips and tricks appear like this.

Get in touch

Feedback from our readers is always welcome.

General feedback: If you have questions about any aspect of this book or have any general feedback, please email us at customercare@packt.com and mention the book's title in the subject of your message.

Errata: Although we have taken every care to ensure the accuracy of our content, mistakes do happen. If you have found a mistake in this book, we would be grateful if you reported this to us. Please visit <http://www.packt.com/submit-errata>, click **Submit Errata**, and fill in the form. We ensure that all valid errata are promptly updated in the GitHub repository at <https://github.com/PacktPublishing/Microsoft-Copilot-for-Security>.

Piracy: If you come across any illegal copies of our works in any form on the internet, we would be grateful if you would provide us with the location address or website name. Please contact us at copyright@packt.com with a link to the material.

If you are interested in becoming an author: If there is a topic that you have expertise in and you are interested in either writing or contributing to a book, please visit <http://authors.packt.com/>.

Share your thoughts

Once you've read *Microsoft Security Copilot*, we'd love to hear your thoughts! Please [click here to go straight to the Amazon review page](#) for this book and share your feedback.

Your review is important to us and the tech community and will help us make sure we're delivering excellent quality content.



Stay relevant in a rapidly changing cybersecurity world - join 65,000+ SecPro subscribers

_secpro is the trusted weekly newsletter for cybersecurity professionals who want to stay informed about real-world threats, cutting-edge research, and actionable defensive strategies.

Each issue delivers high-signal, expert insights on topics like:

- Threat intelligence and emerging attack vectors
- Red and blue team tactics
- Zero Trust, MITRE ATT&CK, and adversary simulations
- Security automation, incident response, and more!

Whether you're a penetration tester, SOC analyst, security engineer, or CISO, **_secpro** keeps you ahead of the latest developments — no fluff, just real answers that matter.

Scan the QR code to subscribe for free and get expert cybersecurity insights straight to your inbox:



<https://secpro.substack.com>

[OceanofPDF.com](https://oceanofpdf.com)

1

Elevating Cyber Defense with Security Copilot

Welcome to Microsoft Security Copilot! In this book, you'll embark on an exciting journey into the world of next-generation cyber defense powered by AI. This opening chapter takes you to the fascinating world of **Artificial Intelligence (AI)** and illustrates how it has evolved over time. You'll gain insights into the technological advancements that have shaped AI, starting with the foundational principles of **machine learning** and progressing to more sophisticated technologies, including **deep learning**, **generative AI**, and **large language models (LLMs)**. These technological breakthroughs have contributed to the powerful AI capabilities we use today.

By exploring the core concepts behind AI, you'll gain a clearer understanding of how it operates behind the scenes. This deeper insight will enhance your knowledge and confidence in using AI tools such as **Microsoft Security Copilot**, allowing you to apply your understanding of AI principles to effectively utilize these tools.

You'll also gain a comprehensive view of how Microsoft is harnessing AI through its suite of Copilot solutions to drive the development of innovation and practical applications, as well as its significant role in enhancing cybersecurity to protect your digital assets and infrastructure.

We will cover these topics through the following sections in this chapter:

- AI evolution – core principles and generative advances
- Introducing Microsoft Security Copilot
- Discovering Microsoft Security Copilot

Getting the most out of this book - get to know your free benefits

Unlock exclusive **free** benefits that come with your purchase, thoughtfully crafted to supercharge your learning journey and help you learn without limits.

Here's a quick overview of what you get with this book:

Next-gen reader



Figure 1.1: Illustration of the next-gen Packt Reader's features

Our web-based reader, designed to help you learn effectively, comes with the following features:



Multi-device progress sync: Learn from any device with seamless progress sync.



Highlighting and notetaking: Turn your reading into lasting knowledge.



Bookmarking: Revisit your most important learnings anytime.



Dark mode: Focus with minimal eye strain by switching to dark or sepia mode.

Interactive AI assistant (beta)



Figure 1.2: Illustration of Packt's AI assistant

Our interactive AI assistant has been trained on the content of this book, to maximize your learning experience. It comes with the following features:

❖ **Summarize it:** Summarize key sections or an entire chapter.

❖ **AI code explainers:** In the next-gen Packt Reader, click the **Explain** button above each code block for AI-powered code explanations.

Note: The AI assistant is part of next-gen Packt Reader and is still in beta.

DRM-free PDF or ePub version



Figure 1.3: Free PDF and ePub

Learn without limits with the following perks included with your purchase:

📄 Learn from anywhere with a DRM-free PDF copy of this book.

📖 Use your favorite e-reader to learn using a DRM-free ePub version of this book.

Unlock this book's exclusive benefits now

UNLOCK NOW



Scan this QR code or go to packtpub.com/unlock, then search for this book by name. Ensure it's the correct edition.

Note: Keep your purchase invoice ready before you start.

AI evolution - core principles and generative advances

AI is the grand umbrella term that encompasses all forms of computational systems that can perform tasks that normally require human intelligence. AI encompasses a wide range of subfields, including **machine learning**, **deep learning**, **neural networks**, **Natural Language Processing (NLP)**, and **robotics**. Its applications are diverse, ranging from medical diagnosis and financial analysis to self-driving cars and virtual personal assistants.

The term *artificial intelligence* was first introduced by John McCarthy in 1956 during the *Dartmouth Conference*, marking the birth of AI as a field of study. AI gained momentum with the rise of machine learning, which focused on developing algorithms that allow computers to learn from data and make predictions or decisions without being explicitly programmed for specific tasks. The availability of large datasets and advances in computing power facilitated the development of more complex machine learning models.

The mid-2000s marked a significant breakthrough in AI with the advent of deep learning. Deep learning, a branch of machine learning, is characterized by neural networks with multiple layers. It began to gain prominence around 2006, largely driven by Geoffrey Hinton's groundbreaking work in developing techniques that enabled AI systems to learn in a human-like manner. Deep learning models achieved remarkable success in tasks such as image and speech recognition, NLP, and gaming. This era's progress was propelled by the availability of large datasets, powerful GPUs, and improved algorithms, all of which facilitated the training of increasingly complex models.

Generative AI, which can generate content that closely resembles human creation, saw significant advancements in 2014. It began with the capability to create realistic images from noise maps. Over time, it has evolved to craft an extensive variety of content, spanning from textual compositions and imagery to video clips, musical pieces, and synthesized speech.

The early 2020s were marked by an AI boom, particularly with the advancements in deep learning and the development of LLMs. These models are capable of summarizing, reading, or generating text in a manner similar to human communication, which has led to a substantial expansion of generative AI systems. Advanced chatbots such as ChatGPT, Copilot, and LLaMA have contributed greatly to the AI landscape, transforming our interaction with technology and unlocking unprecedented levels of efficiency and creative potential.

AI continues to advance at an unprecedented pace. However, its core components are deeply interconnected, starting with the broad foundation of AI and progressing to more specialized areas such as machine learning, deep learning, and, ultimately, specialized models such as generative AI and

LLMs. The core components of AI and their relationships are outlined next, illustrating how each one is interconnected within the broader AI ecosystem:

- AI is the broad field – the “umbrella”
- Machine learning is a core component of AI – it’s a method within AI
- Deep learning is a specialized subcomponent of machine learning
- Generative AI is an application area (or functional branch) of deep learning
- LLMs are a specific type of generative AI – very specialized components built on top of deep learning architectures

The following diagram offers a visual guide to these core AI components:

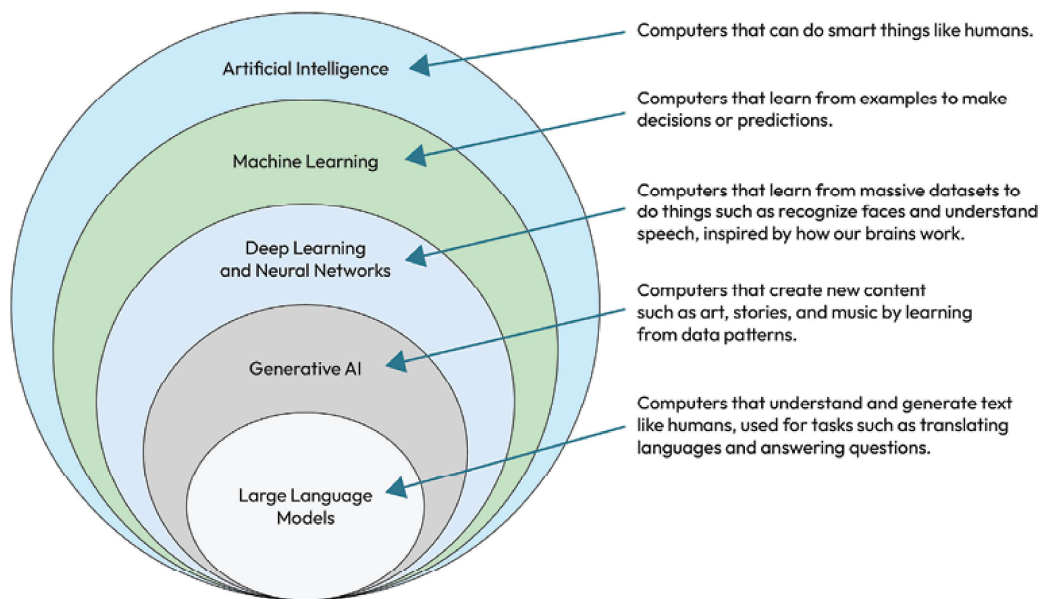


Figure 1.4 – Visual guide illustrating the layers within AI systems

Note that this visual guide depicts the core components of AI in layers, with each component in an inner layer being a subset of the component in the outer layer. Each layer also builds upon the capabilities of the outer layer,

illustrating how each foundational technology, such as machine learning, paved the way for more advanced developments, such as deep learning.

As AI continues to advance, its transformative impact is being felt across a wide range of industries. In healthcare, AI is revolutionizing the sector by helping doctors with diagnoses, creating personalized treatment plans, and accelerating the pace of drug discovery. Banks and financial institutions are leveraging AI's power to detect fraudulent activities, execute algorithmic trades, and manage risks. In the automotive industry, AI is behind the wheel of self-driving cars and boosting safety with advanced driver-assistance systems. Retailers are tapping into AI to tailor customer recommendations, streamline inventory management, and automate client services. In the manufacturing sphere, AI is used to optimize supply chain logistics, enable predictive maintenance, and ensure quality control through cutting-edge analytics and robotic automation.

The applications of AI across industries highlight its transformative potential and the ongoing technological evolution. While AI-powered tools and systems have already made a significant impact, the ongoing research and development continue to overcome present limitations and unlock new possibilities, paving the way for innovations that could revolutionize industries and everyday life.

With AI continuing to evolve, understanding the technologies driving this transformation becomes crucial. In the next few sections, we will delve into the core AI components that have shaped modern AI. By gaining a clear understanding of how each of these technologies works, you'll be better prepared to use them more effectively and with confidence, as AI is no longer a magical black box that just works.

The emergence of machine learning

As we explore the fascinating world of AI, we naturally come to focus on machine learning, the foremost fundamental concept in our ongoing exploration. Machine learning is a subfield of AI. It involves the development of algorithms and models that teach computer systems to identify patterns in data and use this knowledge to make informed decisions or predictions.

Let's illustrate the concept of machine learning with a simple example.

Imagine you give your friend Alex a bunch of pictures of different animals, cats, dogs, and rabbits, and you tell him which animal is which for each picture. As Alex examines the images, he begins to recognize patterns: cats have pointy ears and whiskers, dogs have floppy ears and snouts, and rabbits have long ears and fluffy tails.

Through repeated observation, Alex becomes pretty good at guessing which animal is which just by looking at their features. Now, if you show Alex a new picture of an animal he hasn't seen before, he can apply what he's learned about these patterns to make an educated guess—it might be a cat because of the pointy ears and whiskers, for example.

This process mirrors machine learning, where algorithms are trained on data to recognize patterns, such as features in animal pictures, and use these patterns to make predictions or decisions about new data that they haven't seen before. This ability to learn from data and predict outcomes is what makes machine learning such a powerful tool across various fields.

Let's look at a more technical example that illustrates machine learning, focusing on the relationship between input data and outcomes. Imagine we

have a dataset containing information about houses: their sizes in square feet and their corresponding prices. The goal is to build a machine learning model that can predict the price of a house based on its size.

We start by collecting the dataset, such as house sizes and their prices. We prepare this data, ensuring it's suitable for a machine learning model. We then select an algorithm that can predict continuous values, such as house prices based on size. By feeding the algorithm with the dataset, it learns the relationship between house size, the input, and house price, the output. During training, the model fine-tunes its parameters to reduce the prediction error. Once trained, the model can estimate the price of a new house by applying the patterns it has learned.

For instance, if the model has learned that a house's price increases by \$10,000 for every additional 100 square feet, it can predict that a 1,500-square-foot house might be priced at \$150,000 more than a house with 1,400 square feet. This demonstrates how machine learning algorithms can learn from data and make predictions on new, unseen data.

To summarize, in machine learning, the goal is to use an algorithm that can predict outputs from inputs. This algorithm is learned from examples of past input-output pairs. Once learned, this algorithm can then be used to predict what the output would be for new input data that the model hasn't seen before.

The rise of machine learning has been a driving force in the acceleration of AI. The momentum gained by AI with the advent of machine learning is profound, as it shifted the focus from rule-based programming to data-driven learning. This transition allowed computers to evolve from performing predefined tasks to making predictions and decisions based on data analysis. The importance of machine learning in this context is its role

in enabling AI systems to uncover insights and patterns within vast datasets that were previously unattainable with traditional computing methods. This capability has not only propelled AI forward but also opened new possibilities and applications, making AI more versatile and effective across various domains.

The rise of deep learning and neural networks

Now that we have seen how machine learning works in general, you may wonder about real-world scenarios where we encounter all sorts of data, such as images, text, and audio, and other forms of unstructured information. The traditional machine learning models often find these unstructured datasets challenging, as they typically require significant manual effort to process.

This is where deep learning comes in. Deep learning is a subset of machine learning that excels in interpreting and learning from unstructured data. You can think of deep learning as the whiz kid of machine learning that is good at making sense of messy data. It uses layers upon layers of artificial neural networks, like a deep stack of filters. Each layer learns different aspects of the data, allowing the system to process and understand all of that unstructured information. These layers help deep learning models to identify complex patterns and make smart predictions or decisions. *“For example, deep learning is what driverless cars use to process images and distinguish pedestrians from other objects on the road or what your smart home devices use to understand your voice commands.”* (Microsoft, *What Is Deep Learning?*, <https://azure.microsoft.com/en->

[us/resources/cloud-computing-dictionary/what-is-deep-learning](https://resources.cloud-computing-dictionary/what-is-deep-learning)).

Artificial neural networks are composed of layers of interconnected *neurons* that the input signal goes through one after another to predict the outcome. For example, in the following diagram, to identify whether it's a flower in the picture, the image passes through multiple layers of neurons (depicted as circles) to generate a prediction:

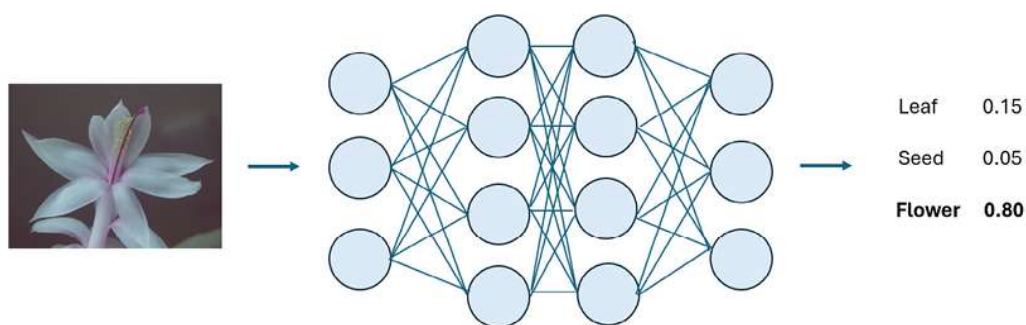


Figure 1.5 – Visualizing artificial neural networks

Deep learning algorithms are inspired by the structure and function of the human brain, and they are capable of automatically learning patterns and representations from data. These deep neural networks learn from vast amounts of diverse data, enabling them to automatically extract increasingly abstract features from raw data, making them highly effective for tasks such as image and speech recognition and NLP.

Deep learning enables machines to process and recognize patterns in data in ways that are inspired by human cognition, but at a much larger scale and scope. The advent of artificial neural networks has enhanced AI technology considerably, allowing machines to tackle previously insurmountable tasks, thus revolutionizing our use of technology in processing and engaging with intricate data.

Introducing generative AI

Generative AI is a fascinating branch of AI that specializes in creating new content. Leveraging deep learning techniques, it extracts patterns from training data to create new instances that mimic the original dataset. This innovative technology excels at producing diverse outputs that can be text, images, music, and so on, based on the patterns it has learned from the training data. Generative AI has attracted significant attention for its potential to produce realistic and creative outputs, revolutionizing industries such as art, entertainment, design, and scientific research.

At the core of generative AI are several key technologies and methodologies. Neural networks serve as the backbone of generative AI. These computational models are inspired by the complex network of neurons in the human brain. In the context of generative AI, these networks use their learned knowledge to create new content. Imagine them as skilled apprentices who, after analyzing countless paintings, can create entirely new artworks that blend elements from various styles they've observed.

The **Transformer models**, including OpenAI's **Generative Pre-trained Transformer (GPT)** series, have become a cornerstone of modern generative AI. The Transformer model is like a super-smart assistant that excels at understanding and generating content. Imagine you're asking this assistant a question. It carefully analyzes each word and its context in your question to figure out what you're asking for, then provides an answer.

For instance, if you ask, "Which state is Seattle in?" the Transformer model analyzes the question by focusing on important words such as *state* and *Seattle*. It understands that you're asking about Seattle's location. Using its extensive knowledge of language and information from vast amounts of

text, it finds the most likely answer. In this case, based on its training, it knows Seattle is in the state of Washington and generates an answer, “Seattle is in Washington state.”

The Transformer model, as its name implies, takes input data and generates contextually relevant responses. It is skilled at processing language by understanding the relationships between words and generating responses that are contextually relevant and informative. It can generate clear and relevant text, such as writing articles, answering questions, or composing poetry. The model can condense long pieces of articles into concise summaries while retaining the essential information.

It can understand questions posed in natural language and provide accurate answers based on the context provided. Beyond translation, the Transformer model can comprehend and interpret the nuances of language, aiding in tasks such as sentiment analysis and classification.

Besides Transformer models, there are other popular techniques for implementing generative AI, enabling its wide-ranging applications in fields such as NLP, image and video generation, music composition, and beyond.

In image and video generation, generative AI creates art, realistic images, and videos for advertising and media production. In music and audio generation, it composes music across genres, synthesizes sound effects, and generates natural-sounding voices for virtual assistants and audiobooks. In text generation, generative AI aids in creative writing by producing poems, stories, and articles, while enhancing chatbots and virtual assistants for more natural interactions. In scientific research, generative AI accelerates drug discovery by predicting molecular structures and designing new materials with specific properties. *“The use of artificial intelligence (AI) is proving to be a game-changer when it comes to medicine with the*

technology now helping scientists to unlock the first new antibiotics in 60 years” (Oceane Duboust (2023) Euronews, Scientists discover the first new antibiotics in over 60 years using AI

<https://www.euronews.com/health/2023/12/31/scientists-discover-the-first-new-antibiotics-in-over-60-years-using-ai>).

LLMs

In earlier sections of this chapter, we covered machine learning, a branch of AI. Machine learning enables machines to make predictions or decisions without being explicitly programmed for each specific task. Then, we explored deep learning, a subset of machine learning, that utilizes multi-layered or “deep” neural networks to analyze complex patterns in data. Deep learning is particularly good at recognizing patterns in unstructured data such as images, sound, and text. We then discussed generative AI, which leverages deep learning techniques to produce original and creative content. It generates outputs that can be text, images, music, and so on, based on the patterns it has learned from the training data.

You may now be curious about the roles of ChatGPT and Microsoft Copilot within the extensive AI ecosystem. To understand this further, it’s important to discuss another key element known as LLMs.

LLMs are a specialized form of generative AI, and they excel in generating text that closely resembles human writing. These models, such as GPT, represent an advanced application of the Transformer model architecture, but scaled up significantly in terms of model size and training data.

These models are trained on extensive datasets drawn from a variety of sources, with each model's capabilities shaped by the data it has been exposed to, including its training cutoff date. By predicting the next token (which can be a word or part of a word) in a sequence, these models become powerful tools for understanding and generating human language. They can be used for a variety of tasks, such as text completion, translation, summarization, question-answering, and code generation.

LLMs predict the next word in a sentence by considering the words that come before it. This is done by calculating the probability of each possible next word based on the patterns it has learned during training. The model uses these probabilities to generate the most likely next word, which leads to the creation of coherent and contextually appropriate sentences.

In the grand scheme of AI, LLMs represent the cutting-edge of what's possible with generative AI and deep learning, pushing the boundaries of how machines understand and create human-like text. They are a powerful tool in the AI toolkit, enabling a wide range of applications from automated content creation to sophisticated conversational agents.

ChatGPT and Microsoft Copilot are both technologies that leverage LLMs to assist users in accomplishing tasks more efficiently. While both technologies understand and generate human language, they serve different purposes and operate within different scopes. ChatGPT, part of the OpenAI family, is designed to engage in conversational dialogue and perform a range of language-related tasks, including creative writing, problem-solving, and coding assistance. Microsoft Copilot, on the other hand, is specifically integrated into the Microsoft ecosystem. It aims to streamline workflows and enhance productivity by assisting with tasks across the suite

of Microsoft applications, such as summarizing emails, drafting documents, and managing meetings.

At their core, ChatGPT and Microsoft Copilot employ sophisticated AI through LLMs for natural language tasks. These models leverage deep learning and generative AI methods to handle linguistic data in ways that mirror human-like comprehension and innovation.

Understanding natural language processing

You may have noticed that we mentioned NLP a few times in the previous sections. NLP is a core field within AI that focuses on empowering computers to understand, interpret, and generate human language effectively. By ensuring interactions are both meaningful and contextually aware, NLP enhances the way machines engage with and respond to human communication. It is like giving computers the superpower to understand, interpret, and talk to us in our own language. NLP is a key component behind how your phone understands your voice commands, how spam filters keep your inbox clean, and even how virtual assistants such as Siri or Alexa chat with you like a friend.

At its heart, NLP uses clever tricks from machine learning to teach computers how to handle the complexities of human language. Imagine algorithms that can read through mountains of text to figure out whether an email is important or junk, or sift through customer reviews to tell you how people feel about a product. These tools use patterns from tons of examples to make smart decisions about language.

But it doesn't stop there. Deep learning turbocharges NLP by letting computers learn intricate linguistic features directly from raw text data, diving deep into how language works. Think of it like teaching a computer to spot sarcasm or understand the subtleties in a poem. Neural networks, the brains behind deep learning, learn these things by crunching through tons of sentences, spotting patterns, and building their own understanding of language rules.

Then there's generative AI, which not only understands what we say but can also create new text that is coherent, contextually appropriate, and often indistinguishable from human writing, with LLMs leading the way. These techniques advance NLP by improving both language generation and understanding.

NLP integrates various methodologies from machine learning, benefits from advancements in deep learning for understanding complex language patterns, utilizes techniques from generative AI for text generation, and pushes the boundaries with state-of-the-art LLMs for advanced natural language understanding and generation tasks.

Putting it all together

With a foundation laid across the core components of AI, spanning machine learning, deep learning, generative AI, LLMs, and NLP, it's clear we are witnessing a profound transformation. AI has evolved from basic data processing to machines capable of producing original, human-like creativity. Machine learning provides the basic tools for pattern recognition and prediction, which are enhanced by deep learning's ability to learn from unstructured data. Generative AI then elevates these capabilities, producing

original content that mirrors human ingenuity, while LLMs channel this creative force into sophisticated, human-like language applications.

Now that we've explored each of these core AI components, let's take a step back to see the bigger picture, examining how these components interconnect and observing the synergy they share:

- AI is the grand umbrella term that encompasses all forms of computational systems that can perform tasks normally requiring human intelligence. This includes reasoning, learning, perception, problem-solving, and language understanding.
- Machine learning is a subset of AI. It involves the development of algorithms and models that enable computer systems to recognize patterns in data and use them to make informed decisions or predictions.
- Deep learning, a subset of machine learning, advances these principles. It uses neural networks with multiple layers (hence *deep*) to learn from vast amounts of diverse data, especially unstructured data. These neural networks are structured in a way that mimics the human brain's neural networks, hence the term *neural*. Deep learning allows the machine to learn from complex patterns and perform tasks such as image and speech recognition.
- Generative AI leverages deep learning techniques to focus on creating new content. Based on the patterns it has learned from the training data, it generates outputs that can be text, images, music, and so on. Generative AI models can produce original and creative content, and they are particularly useful in fields such as design, art, and content creation.

- LLMs are a specialized type of generative AI that processes and generates human-like text, at a level of sophistication that approaches human understanding and inventiveness. LLMs are built using deep learning techniques, particularly neural networks known as Transformers, which are adept at handling sequential data such as text. LLMs can perform a wide variety of NLP tasks, such as translation, summarization, question-answering, and conversation.



Important note

This perspective offers a simplified understanding of AI components. The field of AI is complex, encompassing other definitions that we have not discussed.

Having introduced AI and some of its core components, let's dig deeper into the practical applications of AI in the real world. In the next section, we will take a closer look at how Microsoft is leveraging AI to develop innovative solutions, particularly within the Microsoft Copilot family.

Introducing Microsoft Security Copilot

The Microsoft Copilot family consists of a variety of solutions that enhance productivity across different services. These include Microsoft 365 Copilot, Dynamics 365 Copilot, Copilot in Power Platform, Security Copilot, and GitHub Copilot. Each member of the Copilot family brings its own unique capabilities to the table.

Microsoft Copilot employs an LLM based on OpenAI's GPT framework to generate and interpret human-like text. This advanced model allows Copilot to understand and respond to user inputs with precision. Its conversational interface is crafted to be user-friendly and mirrors the interaction style of ChatGPT, ensuring an accessible chat experience for users.

In the next few sections, we'll dive into a selection of solutions from the Microsoft Copilot family. Keep in mind, though, that this is just a glimpse of Microsoft's rapidly growing Copilot ecosystem. The goal is to highlight a few flagship products that showcase the diverse applications of AI. It is important to be aware that Microsoft continues to introduce new enterprise Copilot offerings across a variety of platforms and services, while existing solutions are constantly evolving with new features and enhanced capabilities. By the time you're reading this, the Copilot lineup has likely expanded even further with additional updates. Furthermore, be aware that product names and branding may change over time, as is often the case with Microsoft's ever-evolving technology landscape.

Microsoft 365 Copilot

Microsoft 365 Copilot acts as a powerful personal assistant right within your Microsoft 365 apps – be it Word, Excel, PowerPoint, Outlook, Teams, and more. This personal assistant is seamlessly integrated into your daily work tools. It can help you to draft documents, summarize emails, create presentations, manage meetings, keep track of tasks, review content, analyze data, and conduct web research to name a few.

Let's say your inbox is overflowing with emails. You need to get to the gist of them, but reading through each one is time-consuming. Microsoft 365 Copilot can summarize your emails, giving you the key points in a concise

format. It's like having a personal assistant who sifts through your emails and gives you a brief on the important stuff.

Imagine you're in a Teams meeting with several colleagues discussing a new project. As the discussion unfolds, Microsoft 365 Copilot is there in real time, summarizing key points and suggesting action items. Suppose you attend the meeting late due to a prior engagement. Microsoft 365 Copilot can provide a summary of what you've missed, allowing you to catch up quickly and participate effectively. As the meeting draws to a close, Microsoft 365 Copilot helps wrap up by providing a summary of the key points discussed and identifying the next steps, including tasks assigned to specific people.

Microsoft 365 Copilot is also a powerful tool for task and project management. It assists you in managing your tasks by setting reminders for important deadlines, keeping track of your to-do list, and suggesting the most efficient order to complete your tasks.

Additionally, it aids in project management by providing realistic, AI-generated task plan recommendations, which can expedite the project creation process and ensure the timely completion of tasks.

There are some amazing examples and innovative ways to utilize Microsoft 365 Copilot out there. Whether you're drafting a report, crunching numbers, or brainstorming for your next big project, think of Microsoft 365 Copilot as your work assistant, always prepared to help, inspire, and simplify your workday.

Dynamics 365 Copilot

Dynamics 365 Copilot provides interactive, AI-powered assistance across business functions. It acts as a powerful personal assistant right within your Dynamics 365 apps, much like Microsoft 365 Copilot does within the Microsoft 365 apps. It is designed for professionals in sales, service, marketing, operations, and supply chain management, empowering individuals to focus more on the most rewarding aspects of their work and less time on mundane tasks.

Imagine you're a sales representative and you've just finished a productive meeting with a potential client. You have a lot of follow-up tasks to do, such as sending a personalized thank you email, updating the opportunity record with the latest discussion points, and scheduling a follow-up meeting.

Normally, this would take a considerable amount of time, but with Dynamics 365 Copilot, you can handle all these tasks effortlessly. *"AI helps write email responses to customers and can even create an email summary of a Teams meeting in Outlook. The meeting summary pulls in details from the seller's CRM such as product and pricing information, as well as insights from the recorded Teams call"* (Charles Lamanna (2023), Microsoft, *Introducing Microsoft Dynamics 365 Copilot, the world's first copilot in both CRM and ERP, that brings next-generation AI to every line of business*,

<https://blogs.microsoft.com/blog/2023/03/06/introducing-microsoft-dynamics-365-copilot/>). Lastly, you can instruct Copilot to find a suitable time for the next meeting based on your calendar availability and send a meeting request to the client, all done through natural language commands.

It's not just about sales. Dynamics 365 Copilot extends its capabilities across a variety of business functions. In customer service, it drafts

contextual answers to queries, providing agents with AI-powered expertise. For finance teams, it streamlines tedious accounting tasks. And in marketing, it helps create compelling content that resonates with the audience. Dynamics 365 Copilot, when integrated within Microsoft Supply Chain Center, can proactively monitor external factors such as weather and financial trends that could disrupt supply chains. It uses predictive insights to identify and alert on affected orders, and can draft emails to notify partners, enabling swift action to mitigate potential issues before they arise.

Copilot in Power Platform

Copilot in Power Platform is a suite of AI-powered tools that help you create apps, automate workflows, and analyze data, all with the ease of conversational language. It's like having a tech-savvy friend who can translate your ideas into reality, without you needing to know the nitty-gritty of coding. *"Now, if you can imagine your solution, you can simply describe it in everyday language, and copilot can create it for you via an intuitive and intelligent low code experience"* (Charles Lamanna (2023), Microsoft, *Power Platform is leading a new era of AI-generated low-code app development*, <https://www.microsoft.com/en-us/power-platform/blog/2023/03/16/power-platform-is-leading-a-new-era-of-ai-generated-low-code-app-development/>).

Let's say you run a small bakery, and you want to keep track of your daily sales, inventory, and customer feedback. You describe your needs to Copilot, and just like that, it whips up an app tailored for your bakery. This app not only logs sales and tracks inventory but also gathers customer sentiments through a friendly chatbot.

So, whether you're a seasoned developer or a business owner with no coding experience, Copilot in Power Platform is your ally, turning your ideas into digital solutions. It's not just about building apps; it's about empowering you to create, innovate, and solve problems in a way that liberates you from technical constraints such as coding.

GitHub Copilot

GitHub Copilot can be perceived as an AI-based coding assistant, a companion that helps you write better code by suggesting entire lines or blocks of code as you type, guiding you through the syntax and semantics, much like a seasoned navigator guiding a ship through uncharted waters.

Imagine you're working on a project, and you need to write a function to calculate the Fibonacci sequence, a series of numbers where each number is the sum of the two preceding ones. Instead of spending time trying to remember how to write this function from scratch, you turn to GitHub Copilot. GitHub Copilot, understanding your intent, suggests a complete function that does exactly that. It's like having a knowledgeable coding partner who not only understands what you want to do but also helps you do it faster.

Now, you might be wondering how GitHub Copilot compares to Copilot in Power Platform, as they both offer AI-based coding assistance. GitHub Copilot and Copilot in Power Platform serve different purposes and operate within distinct environments, catering to different user needs.

GitHub Copilot is an AI pair programmer that helps you write code faster, drawing context from comments and code to suggest individual lines or whole functions instantly. While GitHub Copilot is focused on assisting

with coding tasks, Copilot in Power Platform is about enabling users to build apps and workflows without requiring coding skills, or with minimal coding involved. Both tools leverage AI to simplify and expedite their respective tasks, but they cater to different aspects of the software development and app creation processes. GitHub Copilot is for writing code, and Copilot in Power Platform is for building no-code/low-code solutions.

In conclusion, the Microsoft Copilot family demonstrates how AI-driven solutions can enhance productivity across various platforms and services. From Microsoft 365 Copilot and Dynamics 365 Copilot to Copilot in Power Platform and GitHub Copilot, each member brings distinct capabilities to streamline workflows and improve efficiency. In the next section, let's turn our attention to Security Copilot, the digital security assistant leveraging AI to defend against cyber threats and enabling a rapid response.

Discovering Microsoft Security Copilot

In today's dynamic cybersecurity landscape, a security specialist needs to be highly skilled and knowledgeable across a wide range of areas. For instance, in incident response, the responder must be well versed in various attack techniques to effectively analyze vast amounts of data and logs to uncover subtle indicators of attack. The responder needs to be skilled in scripting languages, including PowerShell, Visual Basic Script, and JavaScript, and even embedded macros, as these tools are frequently leveraged by cyber adversaries. A good understanding of operating systems is crucial too, as the responder must be able to quickly recognize anomalies.

For instance, while `lsass.exe` is a normal Windows system process for managing and verifying user logins and security credentials, having multiple instances running could signal a potential threat. The responder must also be skilled at identifying malicious exploitation of Windows net commands, along with commonly abused tools such as scheduled tasks, PowerShell, or **PsExec** (<https://learn.microsoft.com/en-us/sysinternals/downloads/psexec>). Proficiency in **registry keys** is vital for detecting malicious code hiding in a registry key. This is merely the tip of the iceberg. From phishing scams to network breaches, and fileless attacks to driverless attacks, the breadth of knowledge required is staggering. No single person can master it all.

This is where Security Copilot steps in, to empower and assist security professionals. As an example, Security Copilot can analyze complex commands and scripts, summarize their actions, and provide clear explanations. This capability enables security teams to understand the script functionality without the need for manual reverse engineering. This ability to quickly grasp malicious scripts or commands allows the security teams to react promptly, make informed decisions, and minimize the damage. This capability is particularly beneficial since there are often very few people in the security teams who can quickly reverse engineer complex scripts, especially scripts that are obfuscated or encoded.

In addition to analyzing scripts, Security Copilot can also examine files. During an investigation, security analysts must sift through numerous files, particularly executable and less common ones, to pinpoint any malicious files. Leveraging Security Copilot significantly reduces investigation time and the risk of overlooking malicious files.

On top of this, Security Copilot has extensive knowledge about a wide array of attacks. This includes information about established and emerging attack methods, tactics, techniques, and procedures used by **threat actors**, **Indicators of Compromise (IOCs)**, **exploited vulnerabilities**, and contextual threat intelligence data from **Microsoft Defender Threat Intelligence**. Given the complexity and diversity of attack techniques, responders often face challenges in acquiring the depth of knowledge necessary to effectively identify all indicators of attack. Security Copilot can help support security professionals by providing extensive attack expertise.

As illustrated in the following screenshot, security analysts can turn to Security Copilot to uncover ways attackers might move laterally across an organization. The question posed to Security Copilot and its response are highlighted in the screenshot:

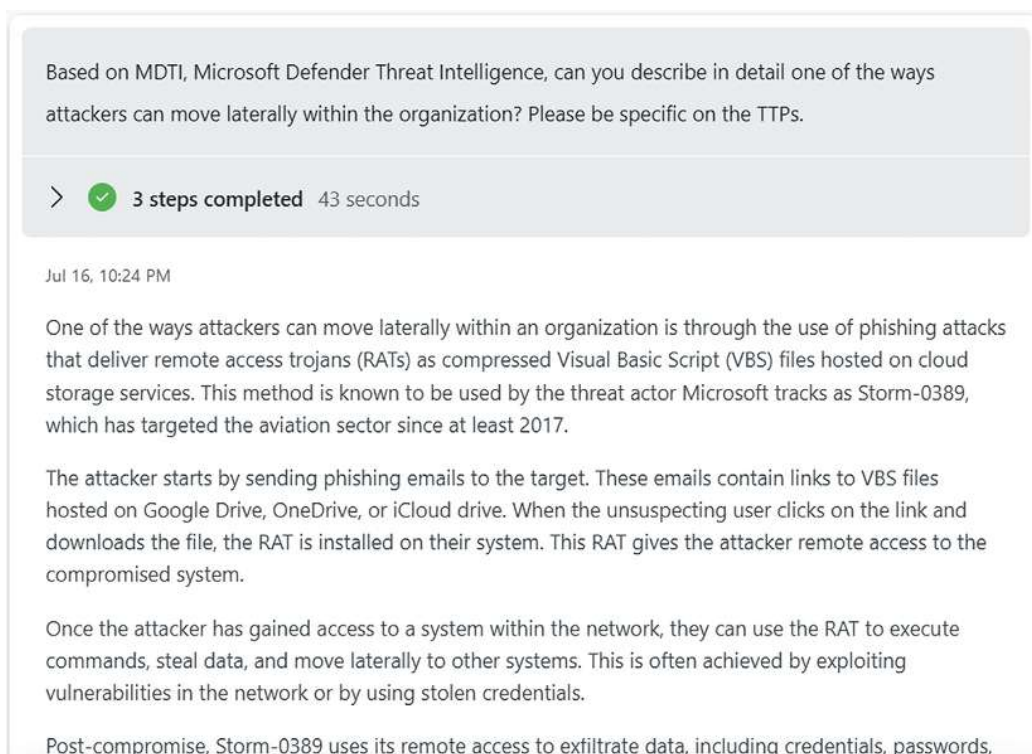


Figure 1.6 – Interacting with Security Copilot



Note

Keep in mind, Security Copilot is an AI solution that is always learning and improving. The responses you receive for the same prompt may differ from those shown here.

Alternatively, responders can request that Security Copilot analyze device events and look for anomalies. For instance, the following example illustrates Security Copilot’s ability to detect encoded PowerShell commands on a device. The following screenshot displays the question submitted to Security Copilot along with the initial part of its response:

Can you run the following KQL query then examine its output, especially the process command line output, to look for any encoded command line? Here is the KQL query: DeviceProcessEvents | where Timestamp between (datetime(2024-06-25) .. datetime(2024-06-27)) | where InitiatingProcessFileName contains "powershell.exe" and FileName contains "schtasks.exe" and DeviceName contains "avoriaz-win10e" | project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName, ProcessCommandLine

>  3 steps completed 1 minute 29 seconds

Jul 15, 9:19 PM

The KQL query that was run is:

```
1 DeviceProcessEvents
2 | where Timestamp between (datetime(2024-06-25T00:00:00Z) .. datetime(2024-06-27T23:59:59Z))
3 | where InitiatingProcessFileName contains 'powershell.exe' and FileName contains 'schtasks.exe'
4 | where DeviceName contains 'avoriaz-win10e'
5 | project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName, ProcessCommandLine
6
```

Figure 1.7 – Security Copilot examines device events

The following screenshot presents the remainder of Security Copilot’s response, including its findings and additional comments. Security Copilot notes: **The command lines are Base64 encoded and are part of a PowerShell command. This is a common technique used by attackers to obfuscate their actions and evade detection. It’s recommended to further investigate these events for potential security threats.**

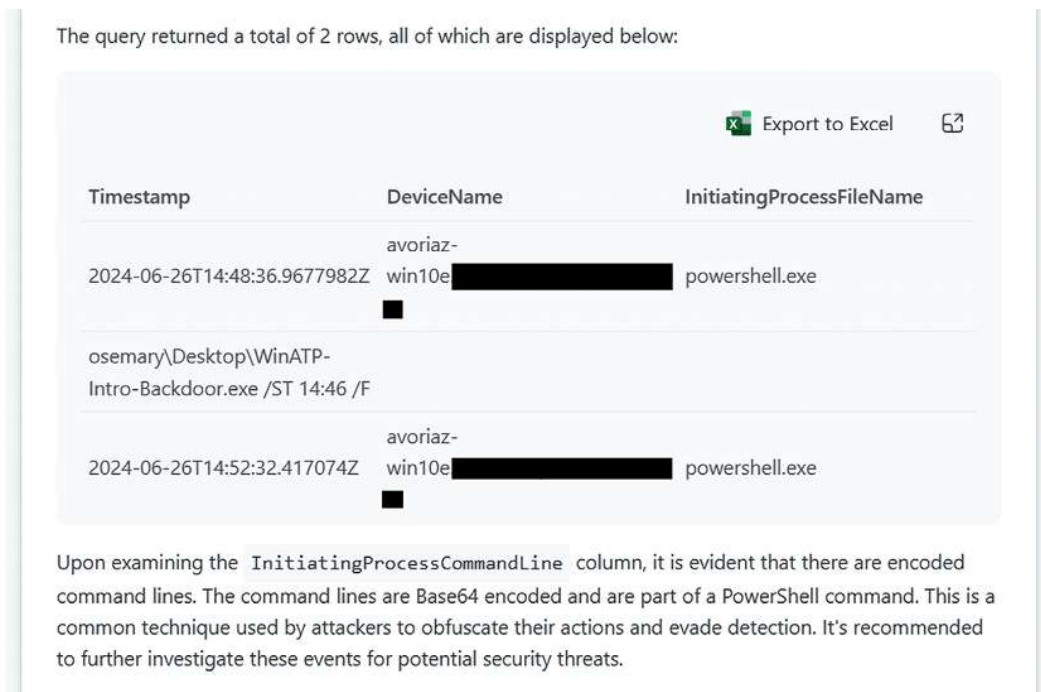


Figure 1.8 – Security Copilot detects an encoded command line

As an AI assistant, Security Copilot excels across many different areas. Its abilities in security incident investigation are only a small part of what it can do. This book provides an in-depth tour of its comprehensive features, enabling you to fully utilize Microsoft Security Copilot and enhance your cybersecurity measures with sophisticated AI tools. Through practical case studies, you’ll learn how to deploy advanced AI solutions for tackling security challenges and elevating your cyber defense tactics.

Summary

This chapter explored the evolution of AI, tracing its development from early machine learning techniques to the advanced field of generative AI. Key concepts such as deep learning, neural networks, and LLMs were introduced, highlighting how these advancements have transformed AI capabilities. It also showcased the integration of AI into various Microsoft solutions to drive the development of innovation and practical applications. Additionally, this chapter introduced Security Copilot, setting the stage for a more detailed exploration of its role and features in the following chapters.

Additionally, this chapter aimed to demystify AI by revealing the core concepts and underlying mechanisms that make it work. By gaining a clearer understanding of how AI operates behind the scenes, you recognize that AI is not a magical black box, but technologies grounded in clear, logical processes. This insight will enhance your confidence in using tools such as Microsoft Security Copilot, enabling you to apply your AI knowledge to use these tools more effectively.

In the next chapter, we will dive into the specifics of Security Copilot, demonstrating how it enhances security across various Microsoft platforms. Building on the foundational AI principles covered in this chapter, you'll gain a deeper understanding of AI's role in cybersecurity.

Further reading

- Microsoft, *What is deep learning?* – <https://azure.microsoft.com/en->

[us/resources/cloud-computing-dictionary/what-is-deep-learning](https://resources.cloud-computing-dictionary/what-is-deep-learning).

- Oceane Duboust (2023) Euronews, *Scientists discover the first new antibiotics in over 60 years using AI* – <https://www.euronews.com/health/2023/12/31/scientists-discover-the-first-new-antibiotics-in-over-60-years-using-ai>.
- Charles Lamanna (2023), Microsoft, *Introducing Microsoft Dynamics 365 Copilot, the world's first copilot in both CRM and ERP, that brings next-generation AI to every line of business* – <https://blogs.microsoft.com/blog/2023/03/06/introducing-microsoft-dynamics-365-copilot/>.
- Charles Lamanna (2023), Microsoft, *Power Platform is leading a new era of AI-generated low-code app development* – <https://www.microsoft.com/en-us/power-platform/blog/2023/03/16/power-platform-is-leading-a-new-era-of-ai-generated-low-code-app-development/>.
- PsExec – <https://learn.microsoft.com/en-us/sysinternals/downloads/psexec>.

Unlock this book's exclusive benefits now

Scan this QR code or go to
packtpub.com/unlock, then search
this book by name.

*Note: Keep your purchase invoice ready
before you start.*



[OceanofPDF.com](https://oceanofpdf.com)

2

Unveiling Security Copilot through Its Embedded Experience

This chapter formally introduces you to **Security Copilot**. You will witness it in action, uncover its powerful capabilities, and learn how it enhances your security operations. Throughout this chapter, you'll gain a solid understanding of Security Copilot's core features within its embedded experience, along with an introduction to its standalone experience. This will set the stage for a more in-depth exploration of its advanced functionalities in the upcoming chapters. Get ready to see how this smart assistant can transform your security operations and support your team's success.

In this chapter, as we delve into Security Copilot, we will cover the following key topics:

- Security Copilot – your ultimate security assistant
- Leveraging Security Copilot in Microsoft Defender
- Integrating Security Copilot with Microsoft Entra
- Exploring Security Copilot within Microsoft Purview
- Enhancing security with Microsoft Defender for Cloud

- Utilizing Security Copilot in Microsoft Intune
- From the embedded experience to the standalone experience



Want to try out the prompts, custom plugins, and promptbooks featured in this book? Take a look at the book's GitHub repository at <https://github.com/PacktPublishing/Micro-soft-Copilot-for-Security>.

Security Copilot - your ultimate security assistant

Security Copilot serves as a remarkably handy, resourceful, and intelligent assistant for security professionals. Whether you're seeking insights into the tactics and tools used by threat actors, trying to identify attacks, investigating incidents, or looking for actionable recommendations, Security Copilot can provide guidance and information that are insightful, clear, and easy to understand.

Security Copilot plays a key role in investigating security incidents, analyzing suspicious files or scripts, assessing risky users, and proactively hunting for threats. Once the investigation is complete, it generates detailed reports to document the findings!

Security Copilot is also highly effective at gathering threat intelligence, identifying anomalies, and pinpointing attack surfaces. Additionally, it supports insider risk management, aids in eDiscovery, provides device

details, assists device troubleshooting, helps with managing device policies and settings, and so much more.

Some of Security Copilot's capabilities are built right into Microsoft security solutions. This is known as the **embedded experience**. It acts like a smart assistant within the Microsoft solutions, providing real-time and context-specific insights, supporting security teams along the way without disrupting the workflow.

You can pivot from Security Copilot's embedded experience to the dedicated portal of Security Copilot, which offers a robust and comprehensive set of resources for in-depth analysis and security management. This is referred to as the **standalone experience**. It acts as a single pane of glass where you can access capabilities and features from all available solutions, including threat intelligence feeds, Microsoft security solutions, and third-party tools. It offers extensive data and insights for thorough analysis across a broad spectrum of information, with all features from the embedded experience also accessible within the standalone portal.

Whether it's the embedded or the standalone experience, Security Copilot acts as your royal assistant, guiding and supporting you at every step. To better understand what Security Copilot is and what it offers, let's start by exploring its core capabilities in the embedded experience. This will provide a solid overview of Security Copilot before we dive into its more advanced aspects.

Leveraging Security Copilot in Microsoft Defender XDR

Microsoft Defender XDR is an enterprise defense suite designed to offer integrated protection against advanced threats. It unifies detection, prevention, investigation, and response across endpoints, identities, emails, and applications to effectively safeguard against complex attacks. Think of it as a highly advanced, digital security guard that not only looks for potential threats but also takes action to stop them and helps recover any affected areas.

Security Copilot is seamlessly integrated into Microsoft Defender XDR to enhance security operations and incident response. Embedded directly in the Microsoft Defender XDR portal, Security Copilot leverages the power of AI to assist security teams to do the following:

- **Summarize incidents:** Compile details from all related alerts and analyst notes into a clear and concise incident summary. This allows a quick understanding of the scope and impact of security incidents, bringing the analyst up to speed with all pertinent information.
- **Use guided responses:** Guide the analyst through the recommended investigation and remediation actions based on the incident details.
- **Analyze scripts, codes, and registry keys:** Break down complex scripts, command lines, and registry keys, offering a clear and straightforward explanation that is easy to understand.
- **Analyze files:** Examine files for malicious content or suspicious behavior.
- **Generate KQL queries:** Create advanced queries to hunt for threats across the network.
- **Summarize device information:** Get an overview of a device's security posture and any unusual activities.

- **Summarize identities:** Get contextual insights into a user in the organization, including security concerns and potential anomalies.
- **Create incident reports:** Document findings and actions taken during an investigation.

Let's explore the features that Security Copilot adds to Microsoft Defender XDR. The following sections are designed to offer an understanding of how these functions enhance security operations and improve incident management efficiency.

Incident summary

As soon as you start examining a security incident in the Microsoft Defender XDR portal, Security Copilot is already present, seamlessly integrated, and ready to assist. It automatically generates a summary of the incident, providing a clear overview of the attack. The incident summary lays out the attack timeline, illustrates the stages of the attack, and highlights key details, all of which help you to quickly grasp the extent and progression of the attack that unfolded.

In the case of a particularly serious incident with many alerts involved, the incident summary generated by Security Copilot helps you understand the entire extent and nature of the attack, despite the complexity and volume of the alerts. For instance, as shown in the next screen capture, the incident involves 34 correlated alerts, affects 8 different assets, and includes over 50 suspicious entities. Security Copilot appears alongside the main incident page. It offers a concise summary that helps the security analyst quickly understand the full impact of the attack. Key events are clearly highlighted, helping to bring analysts up to speed with all relevant details:

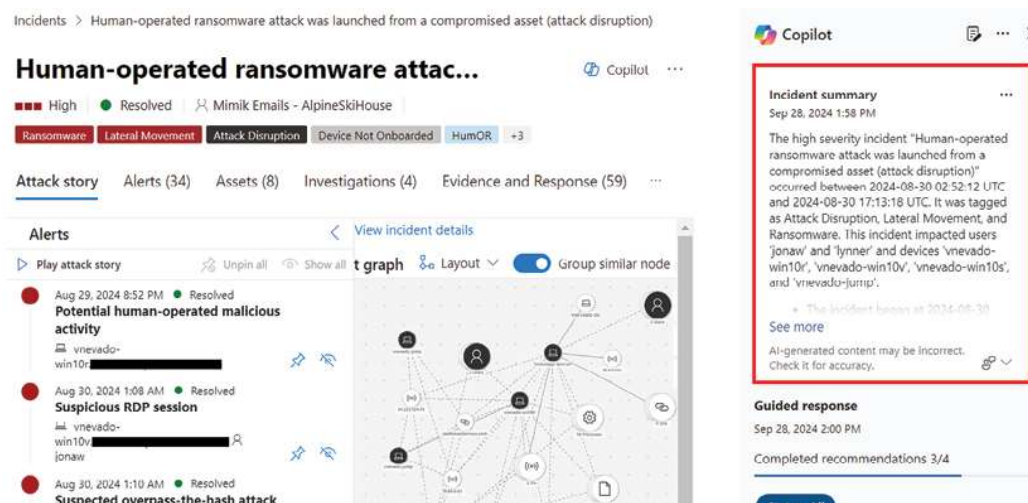


Figure 2.1 – Incident summary

 **Quick tip:** Need to see a high-resolution version of this image? Open this book in the next-gen Packt Reader or view it in the PDF/ePub copy.

 **The next-gen Packt Reader** and a **free PDF/ePub copy** of this book are included with your purchase. Scan the QR code OR visit packtpub.com/unlock, then use the search bar to find this book by name. Double-check the edition shown to make sure you get the right one.



In the full incident summary report shown next, you can see that the Security Copilot incident summary includes a high-level view of the attack,

outlining its nature as a human-operated ransomware attack, and its severity. It details the start and end times of the attack and the sequence of significant activities, broken down by the stages of the attack. Each stage is associated with specific timestamps and affected assets, showing how the attack progressed over time.

Incident summary

The high severity incident “Human-operated ransomware attack was launched from a compromised asset (attack disruption)” occurred between 2024-08-30 02:52:12 UTC and 2024-08-30 17:13:18 UTC. It was tagged as Attack Disruption, Lateral Movement, and Ransomware. This incident impacted users ‘jonaw’ and ‘lynnner’ and devices ‘vnevado-win10r’, ‘vnevado-win10v’, ‘vnevado-win10s’, and ‘vnevado-jump’.

The incident began at 2024-08-30 02:52:12 UTC with potential human-operated malicious activity on ‘vnevado-win10r’ (Windows 10). At 2024-08-30 07:03:47 UTC, ‘Orchestrator.ps1’ was created on ‘vnevado-win10v’ (Windows 10) by ‘SYSTEM’. Shortly after, at 2024-08-30 07:08:46 UTC, a suspicious RDP session was detected on ‘vnevado-win10v’, involving ‘mimikatz.exe’, ‘powershell.exe’, and IP 10.0.0.132.

- **DefenseEvasion:** At 2024-08-30 07:10:19 UTC, ‘lynnner’ attempted to authenticate against ‘VNEVADO-DC’ from ‘vnevado-win10v’, indicating a suspected overpass-the-hash attack.
- **Execution:** At 2024-08-30 07:10:34 UTC, a suspicious PowerShell command line was executed on ‘vnevado-win10v’, followed by the creation of ‘mimidrv.sys’, ‘mimikatz.exe’, ‘mimilib.dll’, ‘mimilove.exe’, and ‘mimispool.dll’ by ‘powershell.exe’.

- **CredentialAccess:** At 2024-08-30 07:10:39 UTC, 'mimikatz.exe' accessed 'lsass.exe' on 'vnevado-win10v', and Defender detected 'HackTool:Win32/Mimikatz!pz'. At 2024-08-30 07:11:42 UTC, 'mimikatz.exe' modified the LSASS process memory. At 2024-08-30 07:14:46 UTC, Defender terminated and quarantined 'mimikatz.exe'.
- **LateralMovement:** At 2024-08-30 07:24:37 UTC, possible lateral movement was detected involving IP 10.60.0.63 on 'vnevado-jump' (Windows Server 2016). At 2024-08-30 07:48:23 UTC, suspicious remote activity was detected on 'vnevado-win10s' (Windows 10) involving 'vssadmin.exe' and 'net.exe'. At 2024-08-30 07:49:07 UTC, possible ransomware activity was detected on 'vnevado-win10r', involving 'unsmoking.txt.lockbit' and IP 10.60.0.63.
- **CredentialAccess:** At 2024-08-30 07:49:20 UTC, there was a possible attempt to access the Primary Refresh Token (PRT) on 'vnevado-win10s' and 'vnevado-win10r' using 'BrowserCore.exe' and 'powershell.exe'.
- **LateralMovement:** At 2024-08-30 07:51:07 UTC, a hands-on-keyboard attack involving multiple devices was detected, impacting 'vnevado-win10r'. At 2024-08-30 07:56:11 UTC, lateral movement using SMB remote file access was blocked on 'vnevado-win10s'.

Guided responses

After the incident summary, Security Copilot offers tailored guidance for responding to the incident through its guided responses feature: *“Copilot in Defender uses AI and machine learning capabilities to contextualize an incident and learn from previous investigations to generate appropriate response actions”* (Microsoft, *Triage and investigate incidents with guided*

responses from Microsoft Copilot in Microsoft Defender, <https://learn.microsoft.com/en-us/defender-xdr/security-copilot-m365d-guided-response>). The guided responses capability empowers security teams to apply response actions with confidence and speed, reducing the time and effort needed to resolve incidents.

Guided responses offer recommendations across four response categories: **Triage**, **Containment**, **Investigation**, and **Remediation**.

The **Triage** category within the guided responses feature offers recommendations on the appropriate incident classification. As illustrated in the next screenshot, Security Copilot suggests classifying an incident as a **true positive** because it recognizes that the organization has previously categorized similar incidents in this manner. To provide further clarity on this recommendation, Security Copilot also lets you view similar incidents:

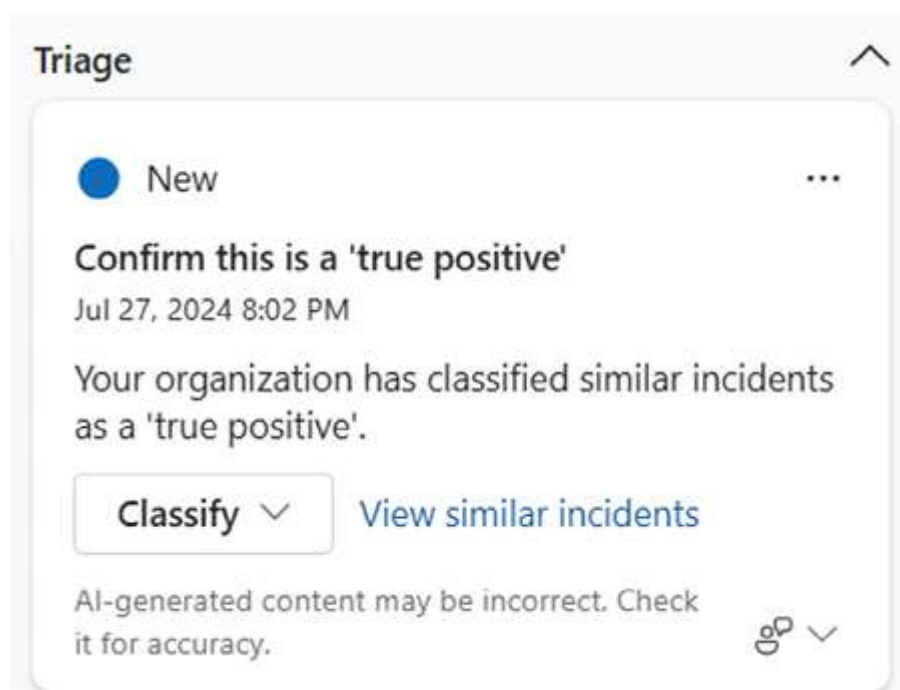


Figure 2.2 – Triage within the guided responses

The **Containment** category within guided responses provides recommended actions to limit the damage caused by the compromise, preventing the attack from affecting other systems, networks, or data within the organization. For example, as shown in the following screenshot, Security Copilot suggests isolating devices from the network as part of the containment strategy. Again, it provides a rationale and explanation for this recommendation:

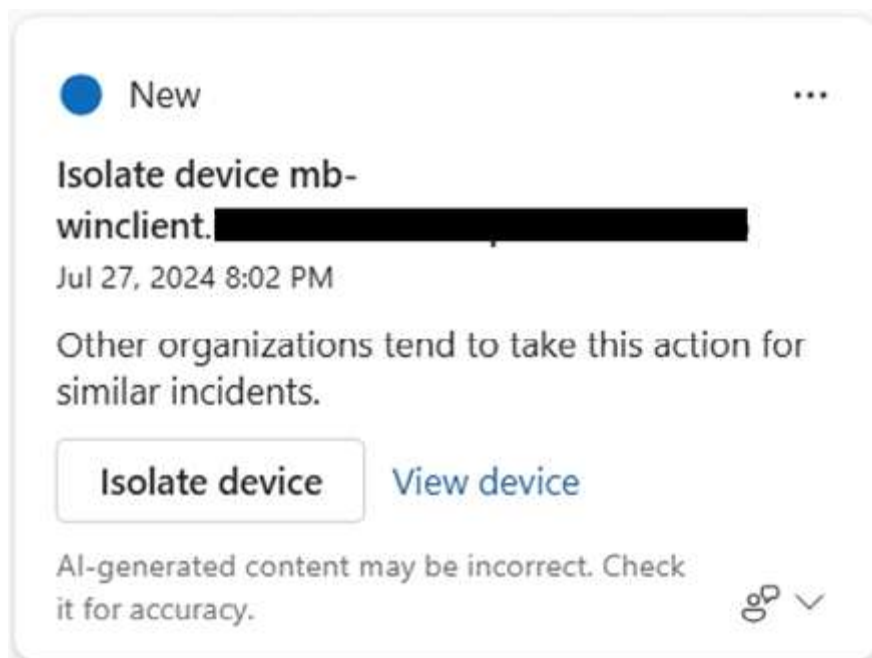


Figure 2.3 – Containment within the guided responses

The **Investigation** category within guided responses provides suggested actions for gathering more insights and conducting further investigations. As shown next, Security Copilot advises reaching out to the user to confirm their activity as the next step in the incident investigation.

It also prepares a message to send to the user that includes detailed information from the incident to provide additional context:

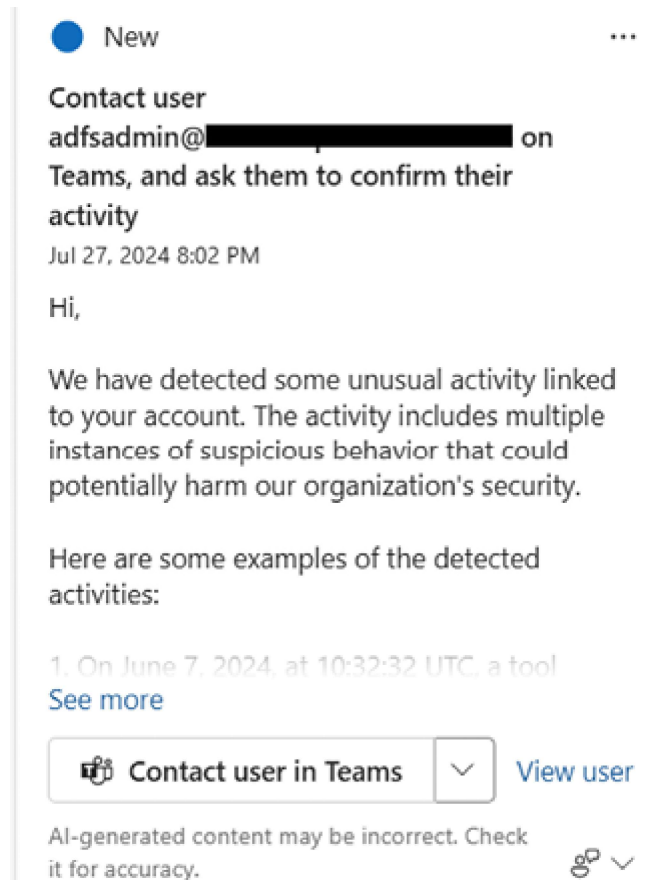


Figure 2.4 – Containment within the guided responses

The **Remediation** category in the guided responses feature suggests response actions to address or resolve threats identified during the incident. Security Copilot can recommend resetting the user password to prevent the attacker from accessing the compromised account. This step is crucial in halting further damage or data exfiltration. Security Copilot can also advise disabling the user account, as seen in the next screenshot. Disabling a compromised account prevents both the user and any attacker using that account from accessing systems and data. This immediate action is vital for containing the incident and stopping any ongoing malicious activities:

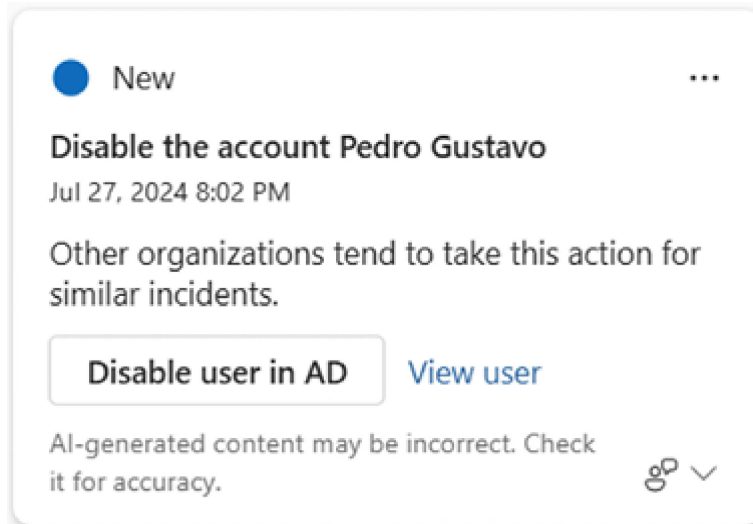


Figure 2.5 – Remediation within the guided responses

The guided responses feature of Security Copilot assists the security team throughout the incident investigation cycle, enhancing their efficiency and effectiveness. However, it's important to note that recommendations provided as a part of guided responses are not meant to be inclusive of all the possible steps an analyst should take. They're meant to serve as a starting point. Besides, guided responses, Security Copilot offers more advanced capabilities to support investigative efforts. Let's continue exploring in the next few sections.

Scripts, command lines, and registry keys analysis

The script analysis feature in Security Copilot allows for the examination of scripts, command lines, and registry keys. This capability enables security teams to thoroughly examine and comprehend complex scripts, malicious command lines, and more, that are frequently employed in sophisticated cyber-attacks.

During an investigation, an incident responder often relies on Defender for Endpoint's **Timeline** feature to review events that occurred on a device. *Defender for Endpoint is one of the security solutions within Microsoft Defender XDR.* It enables the responder to examine process activities to identify the malicious execution of files. Along with process events, Defender for Endpoint also records the associated process command-line information. This often provides crucial context for determining whether the process is being used for malicious purposes. For instance, while PowerShell is utilized by IT teams, security professionals, and attackers alike, simply discovering its execution is not sufficient to determine whether it is used for malicious purposes. Instead, an examination of the PowerShell command line helps to recognize its intent and identify potentially harmful actions.

Understanding PowerShell commands requires a solid grasp of PowerShell and considerable experience. In this context, Security Copilot becomes an invaluable tool. It examines the PowerShell command line, providing a simple and direct explanation of the PowerShell commands in question. This feature aids security analysts in promptly determining whether the PowerShell execution is being employed for malicious activities.

What's even more impressive is that Security Copilot can analyze obfuscated or encoded scripts and command lines. This capability greatly helps security analysts by saving them the time and effort needed to decode such complex commands. De-obfuscation and decoding demand specialized skills that are often scarce within security teams.

As shown in the next screenshot, the PowerShell command line is lengthy and appears to be encoded. Security Copilot translates and summarizes this complex command line into a clear, easily understandable description:

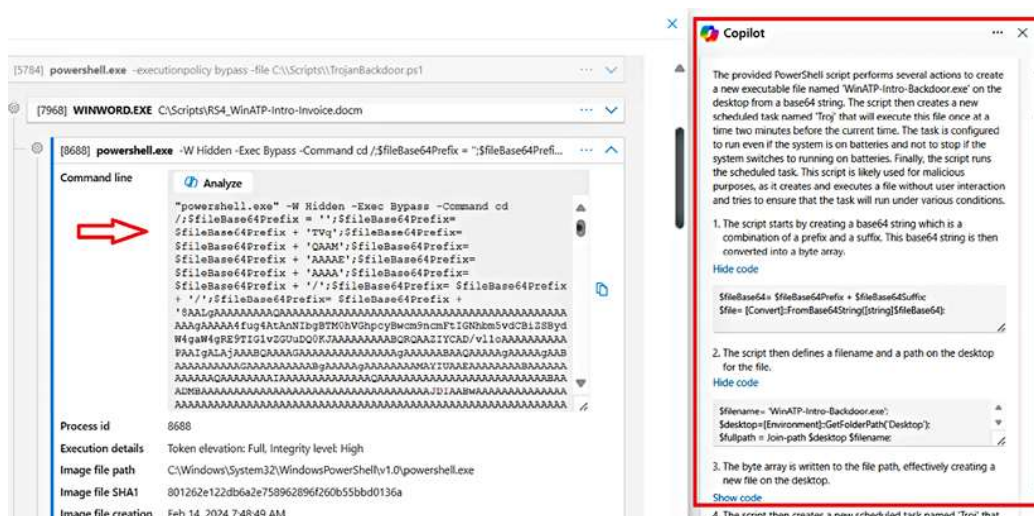


Figure 2.6 – Encoded command-line analysis

Here is a complete copy of the analysis from Security Copilot. You can see that it breaks down the encoded PowerShell commands and makes them easier to understand. This detailed explanation uncovers the intent behind the script, which helps security analysts quickly grasp its purpose:

The provided PowerShell script performs several actions to create a new executable file named 'WinATP-Intro-Backdoor.exe' on the desktop from a base64 string. The script then creates a new scheduled task named 'Troj' that will execute this file once at a time two minutes before the current time. The task is configured to run even if the system is on batteries and not to stop if the system switches to running on batteries. Finally, the script runs the scheduled task. This script is likely used for malicious purposes, as it creates and executes a file without user interaction and tries to ensure that the task will run under various conditions.

The script starts by creating a base64 string which is a combination of a prefix and a suffix. This base64 string is then converted into a byte array.

1. The script then defines a filename and a path on the desktop for the file.
2. The byte array is written to the file path, effectively creating a new file on the desktop.
3. The script then creates a new scheduled task named 'Troj' that will execute the newly created file. The task is set to run once at a time two minutes before the current time.
4. The script modifies the settings of the scheduled task to allow it to start even if the system is running on batteries and not to stop if the system switches to running on batteries.
5. Finally, the script runs the scheduled task.

The **Script analysis** feature in Security Copilot is available for any process with a command line in Defender for Endpoint. This feature greatly assists security analysts while they review process execution events during an investigation. As analysts are sifting through a large number of device events, they can ask Security Copilot to quickly analyze the command line of a process, review the analysis summary, understand its purpose, and then decide whether the process appears suspicious or not.

As another example, in the next screenshot, there is a device event where `svchost.exe` created the process `gpupdate.exe`. The command line for `svchost.exe` reads: `svchost.exe -k netsvcs -p -s Schedule`. To quickly understand the function of this command, the responder can click the **Analyze** button in the **Command line** section of the process, allowing Security Copilot to generate a summary of the command:

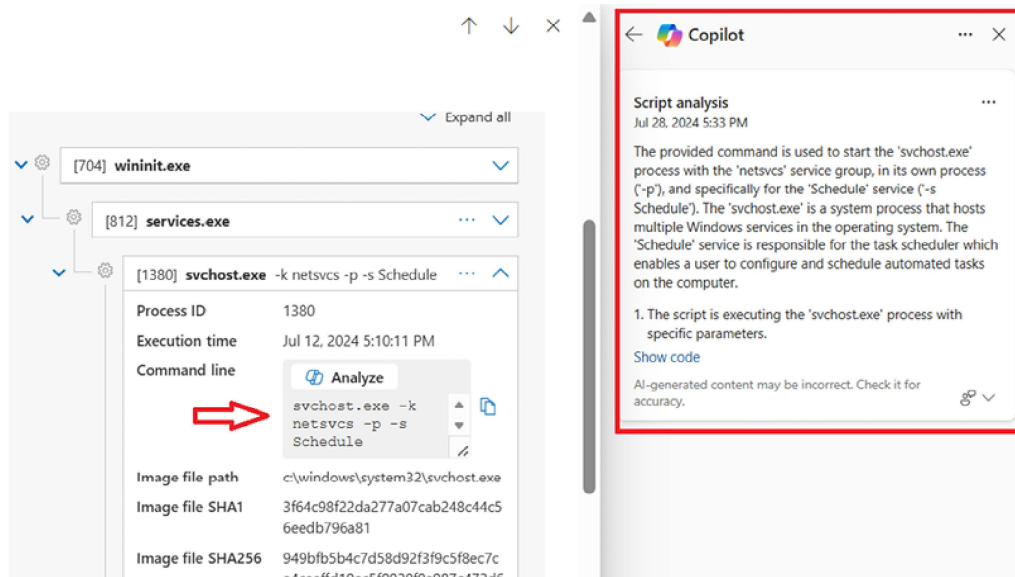


Figure 2.7 – Command line analysis with Security Copilot

For your reference, here is the Security Copilot analysis copied from the previous screenshot:

The provided command is used to start the 'svchost.exe' process with the 'netsvcs' service group, in its own process ('-p'), and specifically for the 'Schedule' service ('-s Schedule'). The 'svchost.exe' is a system process that hosts multiple Windows services in the operating system. The 'Schedule' service is responsible for the task scheduler which enables a user to configure and schedule automated tasks on the computer.

1. The script is executing the 'svchost.exe' process with specific parameters.

`svchost.exe` is a Windows system process that manages multiple Windows services. Since it handles many crucial background tasks, it's often targeted by malware. Attackers might exploit or disguise their malicious software within this process to avoid detection. In these situations, having Security

Copilot quickly analyze its behavior can be very helpful for security analysts.

Optionally, the Script analysis feature also highlights the MITRE ATT&CK techniques identified within the script, helping analysts to quickly understand the adversarial tactics being used and assess the potential impact of malicious activities.

In addition to analyzing scripts and command lines, Security Copilot can also examine registry keys and their values, as seen in the next screenshot:

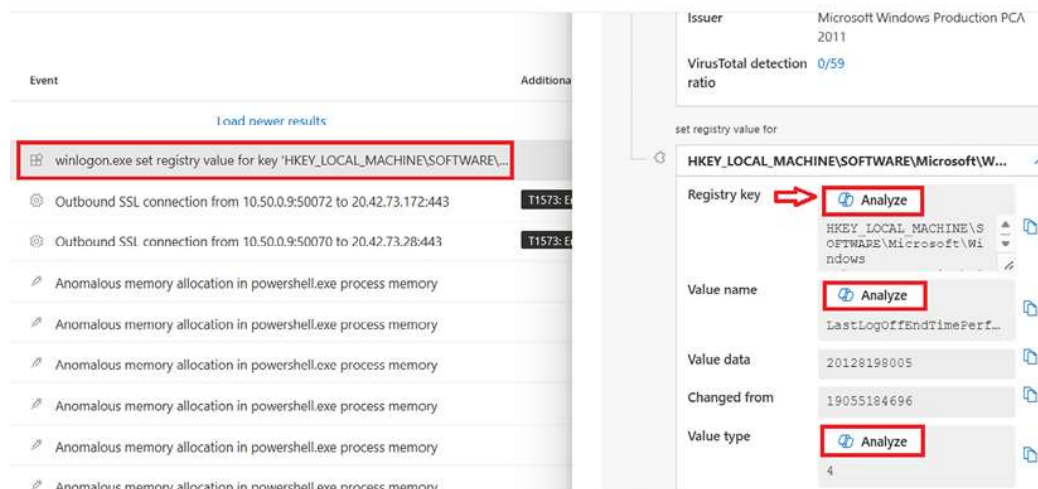


Figure 2.8 – Registry key analysis

Registry keys are another area commonly exploited by attackers. Threat actors may create or modify registry keys to ensure their malware survives reboots. For example, they might add entries to the `Run` or `RunOnce` registry keys to launch malicious programs automatically when the device starts.

By altering registry keys, attackers can change system settings or permissions to gain higher privileges. For example, they might modify registry values related to user permissions to escalate their access level. Malicious actors can hide their activities by altering registry keys that

control system visibility and notifications. For instance, they might disable security alerts or hide the presence of malicious files and processes from the user.

It's challenging to be familiar with every registry key to quickly and accurately detect malicious usage. Security Copilot, as your assistant, provides analysis on registry keys that allows for a more thorough and rapid inspection of the behaviors and configurations that could be indicative of security threats or breaches.

In the case when the registry key is used for malicious purposes, Security Copilot not only explains its function and behavior but also warns that this registry location is a common location used by malware for persistence. The next screen capture depicts the analysis of a suspicious registry key event:

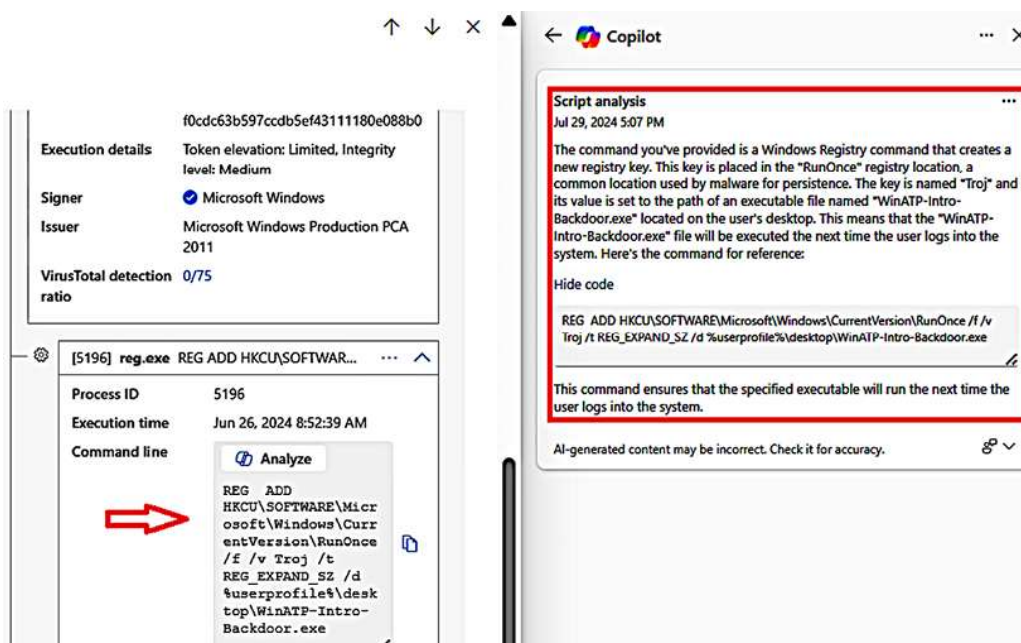


Figure 2.9 – Registry key analysis

File analysis

The incident summary generated by Security Copilot provides a foundation for understanding the scope of an incident. The guided responses feature within Security Copilot then offers actionable steps to triage, contain, investigate, and remediate incidents. On top of this, Security Copilot presents script analysis options to support further in-depth investigative efforts. Furthermore, once suspicious files are identified, Security Copilot helps security teams quickly evaluate and analyze them with its file analysis feature.

The file analysis feature lets the security analyst pick a file in Microsoft Defender and have Security Copilot examine and analyze it. A detailed report is then generated. This analysis report provides an overview of the file, including any detection names if it is flagged as malicious. The report typically includes essential details such as certificates and signers, as well as a summary of the file's contents that contributed to its evaluation. It often highlights strings within the file, lists the API calls it makes, and provides information on relevant certificates. This thorough analysis equips the security analyst with the necessary insights to effectively evaluate the file's impact and intent, making it easier to determine whether the file poses a threat. This is particularly useful for tracking and resolving attacks that use malicious files to mimic legitimate or system files to evade detection.

For example, Microsoft Defender reports a file named `mimikatz.exe` as malware. The security analyst needs to validate Microsoft Defender's verdict and ensure that the file is indeed malicious. Rather than spending excessive time manually analyzing the file, the analyst can turn to Security Copilot to quickly and thoroughly evaluate the file. As shown in the next screen capture, you can request Security Copilot to generate a detailed analysis report for the `mimikatz.exe` file:

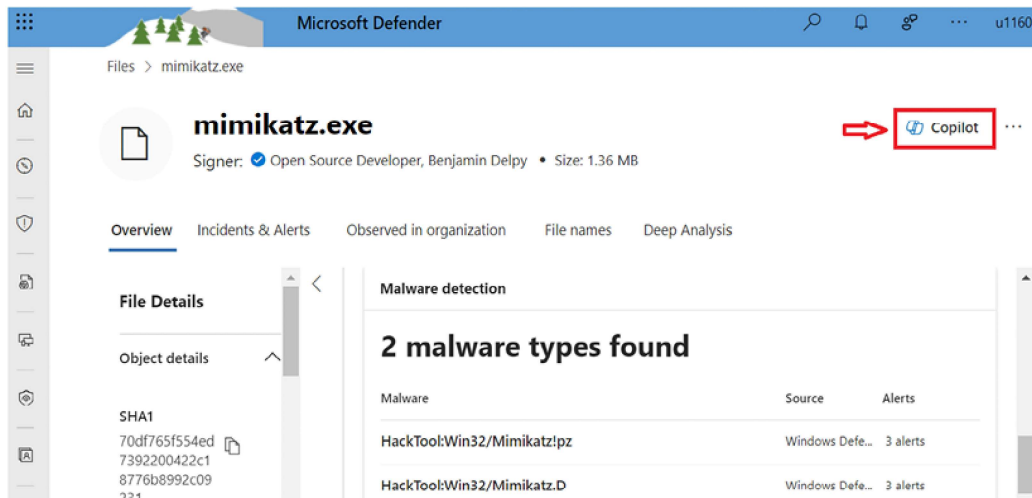


Figure 2.10 – File analysis

The report from Security Copilot indicates that the file is detected as malicious by 63 out of 74 engines in VirusTotal, including Microsoft's, and is flagged as `HackTool:Win32/Mimikatz!pz`. The file has a valid certificate from Open Source Developer but importing functions with potential security risks, such as unauthorized data access and privilege escalation. You can view part of the analysis report here as a reference:

Overview

The file has been detected as malicious by 63 out of 74 engines in the VirusTotal static scan, including by the Microsoft engine as `HackTool:Win32/Mimikatz!pz`. The digital certificate is valid and signed by Open Source Developer, Benjamin Delpy, with a thumbprint of `30258528ee8476dc9b68486668959cff820e8e3b`. The malware determination confirms the file as malware. The PE metadata reveals an image size of 1351680 and the company name as gentilkiwi (Benjamin DELPY).

API calls

The file under scrutiny imports several functions from DLLs, some of which have potential security implications.

The file imports 'CDLocateCSystem' from 'cryptdll.dll', typically used to locate cryptographic systems. Misuse could lead to unauthorized data access or cryptographic system manipulation.

'BuildSecurityDescriptorW' from 'advapi32.dll' is also imported. This function builds a security descriptor, a data structure with security information for a securable object. Misuse could lead to privilege escalation or unauthorized access.

The file imports 'SCardGetAttrib' from 'winscard.dll', used to retrieve current reader attributes. Misuse could lead to unauthorized smart card data access.

'I_NetServerTrustPasswordsGet' from 'netapi32.dll' is also imported. This function retrieves server trust passwords, which could be exploited for unauthorized network resource access.

Lastly, the file imports 'CryptImportKey' from 'advapi32.dll', used to import cryptographic keys. Misuse could lead to unauthorized encrypted data access.

These functions could lead to security risks such as unauthorized data access, privilege escalation, or security mechanism bypassing. Further investigation is recommended to assess potential security implications.

Based on this report, the security analyst can likely determine that the file is indeed malicious.

From this demonstrated example, you can see that the file analysis feature in Security Copilot enables security teams to quickly conduct in-depth

examinations of potentially malicious files. This capability empowers analysts from all levels to complete their investigation with a shorter turnaround time, significantly boosting efficiency, particularly when time is critical in addressing security incidents.

Whether the file is seen in the Defender for Endpoint timeline, accessed through its file page, or flagged as suspicious in an incident, the security analyst can request Security Copilot to analyze the file and generate a detailed report.

Device summary

Once a security analyst identifies something suspicious about a device, they can request Security Copilot to generate a device summary. This summary provides details on the device's security posture, vulnerable software, and any unusual behaviors. With this information, the analyst can quickly evaluate the device's risk level and understand potential threats from vulnerabilities, misconfigurations, or other anomalies.

Additionally, the device summary may offer extra context that supports incident investigation, enabling security teams to act promptly to address potential threats and decide on appropriate response actions.

When you navigate to the device page in Microsoft Defender, Security Copilot automatically generates the **Device summary** information and displays it in the **Copilot** side pane on the right:

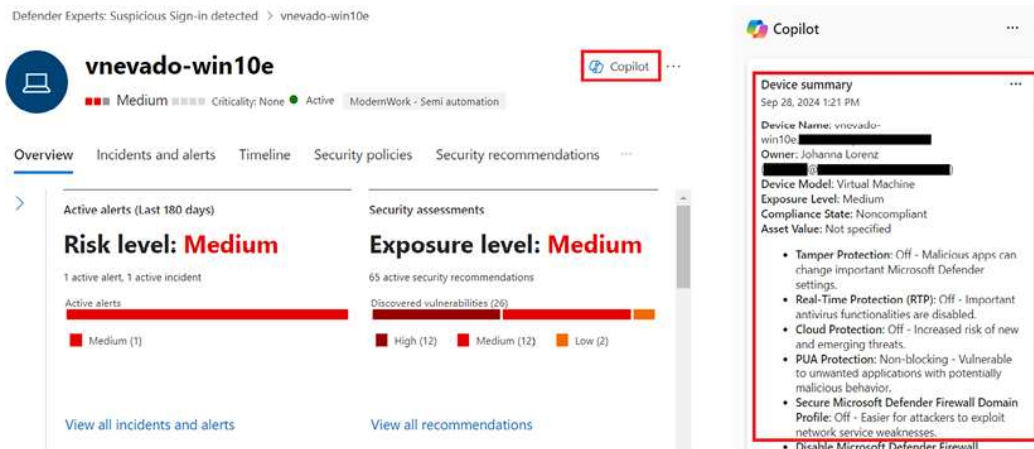


Figure 2.11 – Device summary

For instance, from the detailed device summary shown next, Security Copilot points out a couple of concerns: key settings, such as **Tamper Protection**, **Real-Time Protection**, **Cloud Protection**, and **Microsoft Defender Firewall**, are all disabled, leaving the system vulnerable to malware and network attacks. Additionally, the device has high-severity vulnerabilities in Firefox and OpenSSL, increasing the risk of exploitation:

Device Name: vnevado-win10e. [REDACTED]

Owner: Johanna Lorenz ([REDACTED]@[REDACTED])

Device Model: Virtual Machine

Exposure Level: Medium

Compliance State: Noncompliant

Asset Value: Not specified

- **Tamper Protection:** Off - Malicious apps can change important Microsoft Defender settings.
- **Real-Time Protection (RTP):** Off - Important antivirus functionalities are disabled.

- **Cloud Protection:** Off - Increased risk of new and emerging threats.
- **PUA Protection:** Non-blocking - Vulnerable to unwanted applications with potentially malicious behavior.
- **Secure Microsoft Defender Firewall Domain Profile:** Off - Easier for attackers to exploit network service weaknesses.
- **Disable Microsoft Defender Firewall notifications (Domain profile):** Off
- **Disable Microsoft Defender Firewall notifications (Private profile):** Off
- **Disable merging of local Microsoft Defender Firewall connection rules (Public profile):** Off
- **Attack Surface Reduction (ASR):** Off - Increased risk from common attack techniques and malicious software.

Vulnerable software

- **Firefox 128.0.0.0:** High severity
- **OpenSSL 3.3.0.0:** High severity

Intune policies

The device is noncompliant due to the Device Risk policy. Specifically, the setting

Windows10CompliancePolicy.DeviceThreatProtectionRequiredSecurityLevel is noncompliant.

In conclusion, the device summary from Security Copilot gives analysts a quick overview of a device's security posture when suspicious activity is detected. It highlights vulnerable software and unusual behaviors, enabling rapid risk assessment and identification of potential threats.

Advanced hunting using KQL

Kusto Query Language (KQL) is a query language used to retrieve and analyze data in various Microsoft solutions such as Microsoft Defender and Microsoft Sentinel. It is designed to handle large volumes of data efficiently and allows users to perform complex queries and analytics on log and telemetry data. KQL is known for its powerful querying capabilities, including filtering, sorting, aggregating, and joining data.

Advanced hunting is a feature in Microsoft Defender XDR designed to identify and investigate threats throughout an organization's environment. It utilizes KQL to search through large datasets for signs of suspicious or malicious activities. It enables security analysts to create custom queries to detect and investigate potential threats, trends, and anomalies that might not be captured by standard security alerts or automated processes.

Advanced hunting is very powerful, but to fully leverage its capabilities, a good understanding of KQL is necessary. Threat hunters or security analysts who are not yet proficient in KQL can turn to Security Copilot to draft KQL queries for them. Additionally, Security Copilot offers detailed explanations of the query to show the underlying logic. This cuts down the time needed to create a hunting query from scratch, allowing security teams to concentrate more on identifying and investigating threats.

When you open the **Advanced hunting** page in Microsoft Defender, Security Copilot appears on the right-hand side, offering several sample Copilot instructions called **prompts** to assist you in crafting and refining your queries.

If you choose a sample prompt such as **Show the top 5 devices with the most network connection failures**, Security Copilot then generates a KQL

query as shown in the next screenshot:

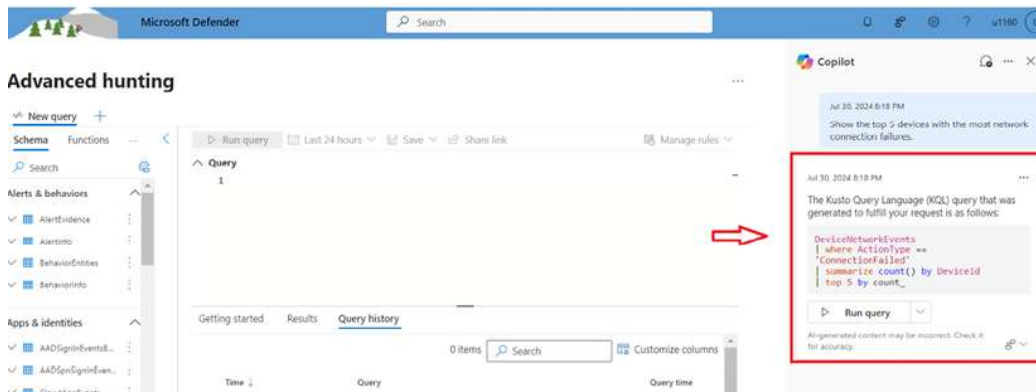


Figure 2.12 – Security Copilot generates a KQL query

Once you click the **Run query** option, Security Copilot transfers this KQL query into the **Advanced hunting** pane and executes it:

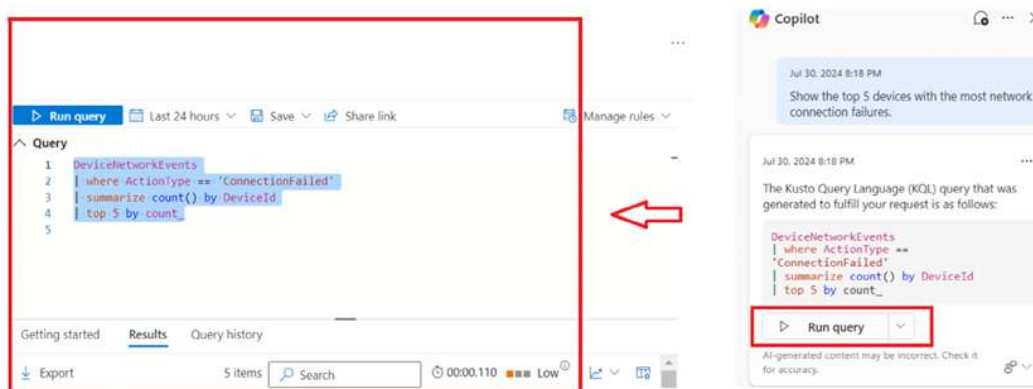


Figure 2.13 – Security Copilot executes a KQL query

In Security Copilot, you can input your own **natural language prompt** to request a new KQL query to be generated. For example, you can ask:

From the DeviceEvents, can you summarize all the action types an

As shown next, Security Copilot generates a KQL query for you, which is then executed in **Advanced hunting**. The result output displays a list of action types from the `DeviceEvents` data table, sorted in ascending order, which matches the request specified in your prompt:

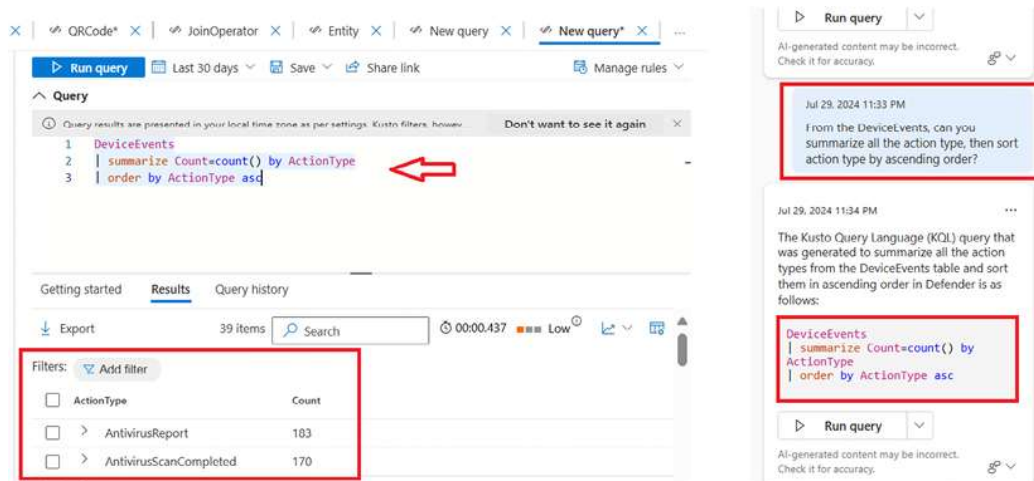


Figure 2.14 – Security Copilot generates and then executes the KQL query

It's important to note that Security Copilot does not always produce the correct KQL query. You can use the query generated by Copilot as a starting point or reference, but you need to verify its accuracy. For more information about KQL or to master it, you can refer to its documentation repository at <https://learn.microsoft.com/en-us/kusto/?view=microsoft-fabric>.

Incident reports

Writing incident reports can be a dreaded task for many security professionals. It's often time-consuming and tedious, requiring a thorough review and the compilation of all relevant logs. In some cases, preparing the incident report can take longer than the actual investigation. This is why

many security analysts are thrilled that Security Copilot now generates detailed incident reports for them!

Using Security Copilot, security teams can generate an incident report with a single click by selecting the report icon in the **Copilot** side panel. Security Copilot creates a detailed report that includes key timestamps such as incident creation and closure, as well as the timing of the first and last events. The report outlines the investigation and remediation actions taken, including specific actions such as device isolation, disabling a user, and soft deletion of emails. It also details the analysts involved in the response, the classification of the incident, and the reasons for this classification. Follow-up steps such as recommendations, open issues, or next actions noted by the analysts are also included in the report.

The incident report can be copied to the clipboard, posted to the activity log, or exported as a PDF. When exporting the incident report as a PDF, you have the option to customize the report by including or excluding information such as the overview, attack story, scope, evidence and response, and supporting data.

The following screenshots of the incident report are provided as a reference to highlight some of its details. The complete incident report is available in the GitHub repository for this book and can be accessed at

<https://github.com/PacktPublishing/Microsoft-Copilot-for-Security/blob/main/Other/Incident%20Report%20-%20Chapter%202.pdf>.

The first screen capture displays the detailed incident summary in the incident report:

Incident summary

The high severity incident titled 'Multi-stage incident involving Execution & Lateral movement on multiple endpoints reported by multiple sources' occurred between 2024-06-07 09:16:21 UTC and 2024-06-07 10:39:50 UTC.

- At 2024-06-07 09:00:19 UTC, on the device 'mb-adfs' (WindowsServer2022), the 'SenseCM.exe' process (running as SYSTEM) created multiple files including 'PolicyEnforcer.ps1', 'AntiVirus.psm1', and 'EDR.psm1'.
- At 2024-06-07 09:16:18 UTC, on the device 'mb-windclient' (Windows10), the 'powershell.exe' process created the file 'Midnight182.ps1' under the user 'kdickens'.
- **Discovery:** At 2024-06-07 09:16:21 UTC, a suspicious sequence of exploration activities was detected on 'mb-windclient' involving the IP 10.2.0.4 and processes including 'powershell.exe' and 'whoami.exe', impacting users 'pgustavo' and 'kdickens'.
- **DefenseEvasion:** At 2024-06-07 09:16:21 UTC, a process was injected with potentially malicious code on 'mb-windclient', involving the file 'Midnight182.ps1' and the IP 10.2.0.4, impacting users 'pgustavo' and 'kdickens'.
- **Execution:** At 2024-06-07 09:16:22 UTC, a malicious PowerShell Cmdlet was invoked on 'mb-windclient' involving the file 'Midnight182.ps1' and impacting user 'kdickens'.
- **LateralMovement:** At 2024-06-07 09:16:22 UTC, suspicious hands-on keyboard user behavior was detected on 'mb-windclient' involving the process 'powershell.exe' and impacting user 'kdickens'.

Figure 2.15 – Incident summary in the incident report

The incident report also includes a graph that illustrates the attack story, as demonstrated in the next screenshot:

Attack story graph

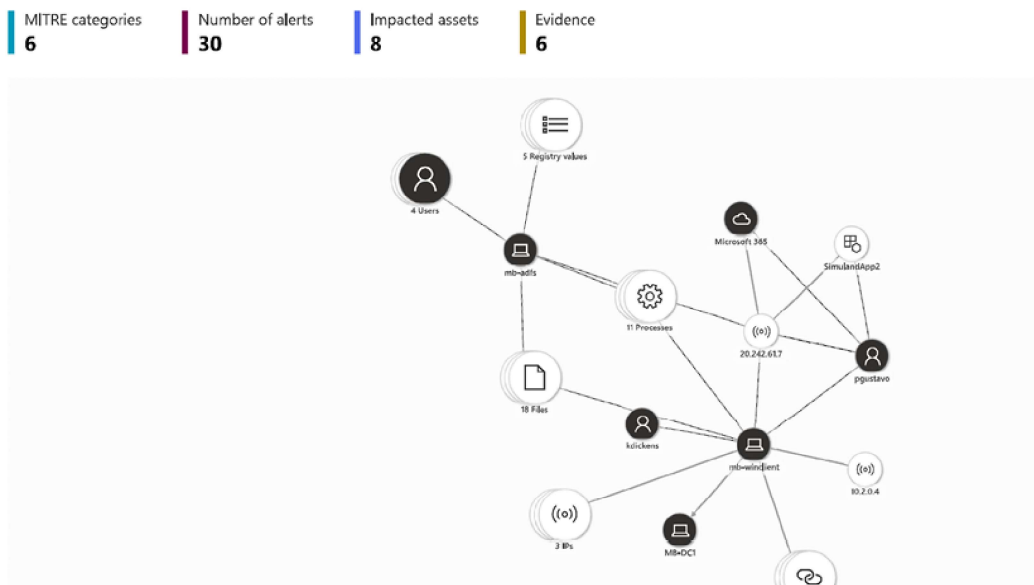


Figure 2.16 – Attack story graph in the incident report

The incident report displays alerts and their threat categories, organized according to **MITRE ATT&CK** tactics:

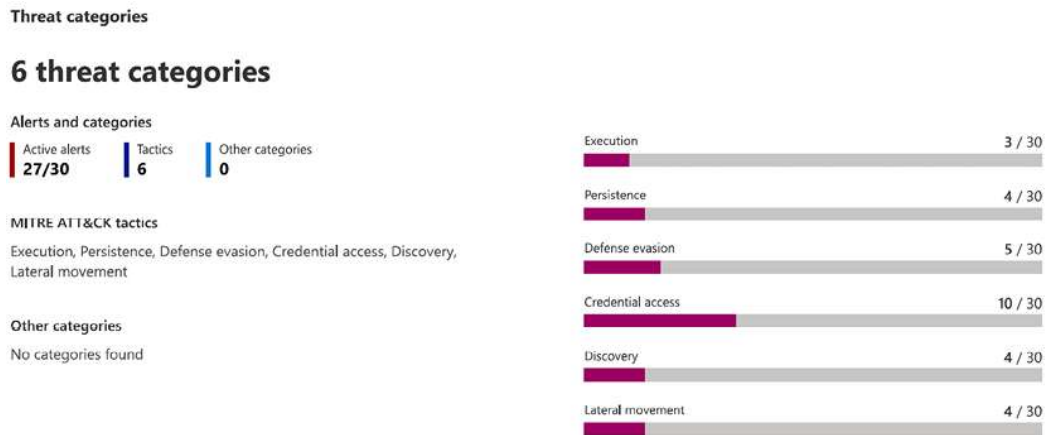


Figure 2.17 – Threat categories in the incident report

After observing how Security Copilot integrates with Microsoft Defender XDR to enhance security operations and incident response, you likely appreciate the power of AI in increasing the effectiveness and efficiency of security teams. Next, let's explore how Security Copilot integrates with **Microsoft Entra** to further support and strengthen security measures.

Integrating Security Copilot with Microsoft Entra

Microsoft Entra is designed to help organizations manage and secure who has access to their digital resources. It simplifies the process of verifying user identities and controlling their access to various systems and information. Think of it as a digital gatekeeper that ensures only authorized individuals can get into the right places, helping to protect sensitive data and support secure operations. Microsoft Entra includes a range of products designed to secure access for a variety of identities, including employees, external partners, and customers, from anywhere, to any resource across clouds and on-premises.

Microsoft Entra ID Protection is a part of the broader Microsoft Entra suite. Microsoft Entra ID Protection identifies when a user's behavior or login attempts seem suspicious or unusual, which could signal a possible threat. For instance, if a user suddenly tries to access sensitive information from an unexpected location, Entra ID Protection can flag this as *risky* and help the organization take steps to prevent any potential security breaches.

If a user account is compromised and appears on the internet, such as on the dark web, Microsoft Entra ID Protection triggers a *leaked credentials* alert. This alert indicates that the user's account and credentials may no longer be trusted, as they could be used by attackers to gain access. Consequently, Entra ID Protection flags this user as risky: *"This risk detection indicates that the account's valid credentials leaked. The leak can occur when someone uploads the credentials in public code artifact on GitHub, or when the credentials are leaked through a data breach. When the Microsoft leaked credentials service acquires credentials from GitHub, the dark web, paste sites, or other sources, they're checked against current valid credentials in Microsoft Entra ID to find valid matches"* (Microsoft, *Securing workload identities*, <https://learn.microsoft.com/en-us/entra/id-protection/concept-workload-identity-risk>).

In addition to these two scenarios just described, Microsoft Entra ID Protection can identify a user as risky in various other situations. To assist security analysts in managing and understanding these diverse scenarios, Security Copilot, embedded in Entra, provides a summary for each risky user. This summary includes an explanation of why the user is deemed risky and a list of recommended next steps for investigation and preventing future

incidents. Access to additional help and documentation is also provided by Security Copilot.

As an example, the *Risky user* report in Entra ID Protection provides a list of users who have been flagged as risky due to suspicious or potentially harmful activities. By selecting a user from the *Risky user* report, you can then navigate to that user's **Risky User Details** page. Security Copilot is already present there, providing the user summary for you.

In this example, the summary by Security Copilot highlights that user Cameron has been flagged for three recent high-risk activities, detected through Microsoft Entra threat intelligence, and signs of suspicious behavior such as anonymous IP addresses and password spray attacks. Each risky sign-in lacked multi-factor authentication and involved unfamiliar IP addresses and locations:

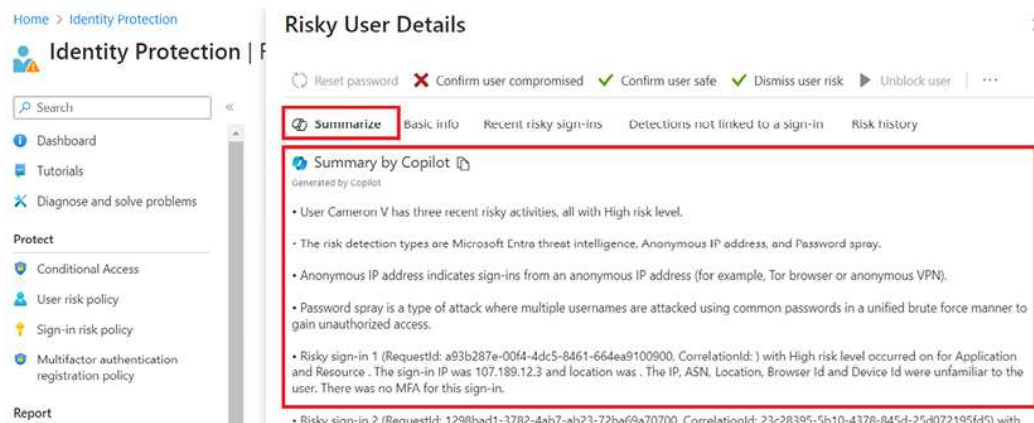


Figure 2.18 – Risky user summary

In the Microsoft Entra admin center, clicking the **Copilot** button by the navigation bar opens up the Security Copilot side panel. As shown in the next screenshot, Security Copilot offers suggested questions to ask such as **List user sign-ins that failed in the last 24 hours** or **How does Microsoft**

determine Risky Users?. There is also an option to provide your own questions to get tailored insights:

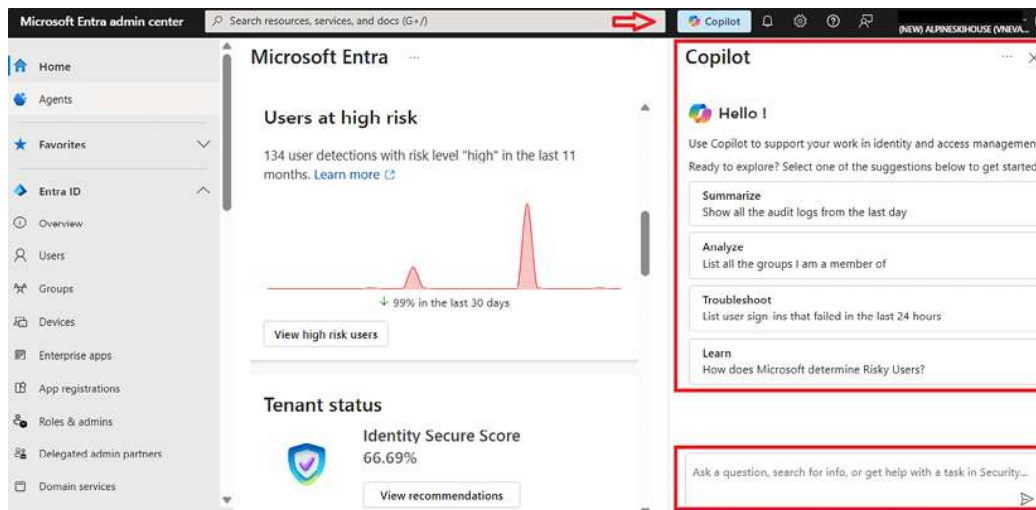


Figure 2.19 – Security Copilot embedded in Entra admin center

Additionally, with the Security Copilot Entra **plugin**, analysts can also access user details, sign-in logs, audit logs, group information, and more to support their investigations and identify other suspicious activities. Further details on Security Copilot plugins (including the Entra one) will be covered in [Chapter 4](#). A detailed case study highlighting additional capabilities and features of the Security Copilot Entra plugin will be presented in [Chapter 9](#).

Now that you’ve observed how Security Copilot integrates with Microsoft Defender to improve security operations and incident response, and how it helps security analysts manage and understand risky users in Microsoft Entra, let’s explore how Security Copilot applies the same capabilities to data and compliance within **Microsoft Purview**.

Exploring Security Copilot within Microsoft Purview

Microsoft Purview is a tool designed to help organizations in managing and protecting their data. It tracks where data is stored, and ensures it is organized, secure, and meets regulatory requirements. It acts as a smart assistant by keeping data organized and secure, while also simplifying the management and protection of important information. It is a comprehensive solution for data governance, security, and compliance.

Purview provides a range of essential features to assist organizations in managing their data efficiently. Its **Data loss prevention** feature helps to prevent sensitive information from being accidentally shared or leaked by automatically detecting and protecting at-risk data. **Communication compliance** ensures that users' messages and interactions adhere to company policies and regulations, helping maintain proper standards. **Insider risk management** identifies and addresses potential threats from within the organization by monitoring for unusual activities that might indicate internal risks. And **eDiscovery** simplifies the process of finding and retrieving important information during legal investigations or audits, making it easier to search through large volumes of data for relevant documents and evidence. These are just some of the many features offered by Purview; there are additional capabilities designed to further enhance data management and security.

Security Copilot brings the same set of capabilities we have seen for security operations to the world of data and compliance. Integrated directly into Purview, it equips data governance and compliance experts with generative AI capabilities, significantly enhancing the efficiency and speed

of their investigations. Now, let's take a closer look at these features and how they can be utilized.

Data loss prevention alert investigation

The **data loss prevention (DLP)** feature in Microsoft Purview helps protect sensitive information from being accidentally shared or leaked. It works by monitoring and controlling how data is used and shared across the organization. If it detects that sensitive information, such as personal details or financial data, might be at risk, it can block or alert the security teams to prevent potential leaks. Essentially, DLP ensures that important information stays secure and only reaches the people who should have access to it.

Investigating DLP alerts can feel like solving a jigsaw puzzle, with pieces scattered across various data sources including applications, cloud services, emails, endpoints, and chat. The process is further complicated by the various rules and conditions of each policy that must be analyzed and understood. This can be challenging for data security analysts.

One way Security Copilot can assist is by offering a comprehensive summary of the DLP alert. It provides key details, including policy rules, sources, files involved, and more. Additionally, the summary pulls the user risk levels from **Insider risk management**, providing integrated insights across data security solutions. These summaries provide the analysts with a good starting point for further investigation.

On the **Alerts** page of the **Data loss prevention** solution in Purview, you can select the **Get a summary from Security Copilot** option to generate a summary of the alert, as seen in the next screen capture:

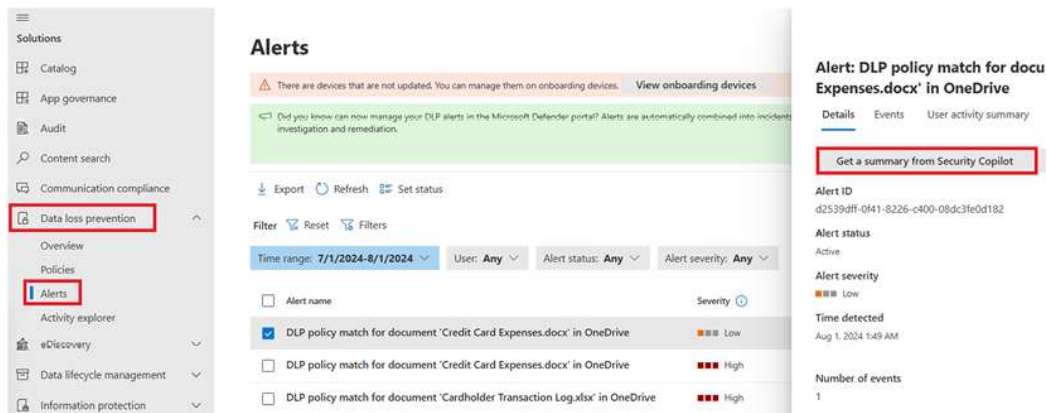


Figure 2.20 – Getting a summary of a DLP alert

For instance, with the **DLP policy match for document ‘Credit Card Expenses.docx’ in OneDrive** alert, the summary shown in the next screen capture provides key information that helps the analyst to quickly understand the impact and specifics of the issue. It identifies the alert as low severity for a document in OneDrive that is linked to the user Natasha. The summary includes details about the specific policy and rule that triggered the alert. It also notes that the file contains content that is blocked from sharing under this policy. This concise overview helps the analysts understand the context and scope of the alert, enabling them to assess and address the issue effectively:

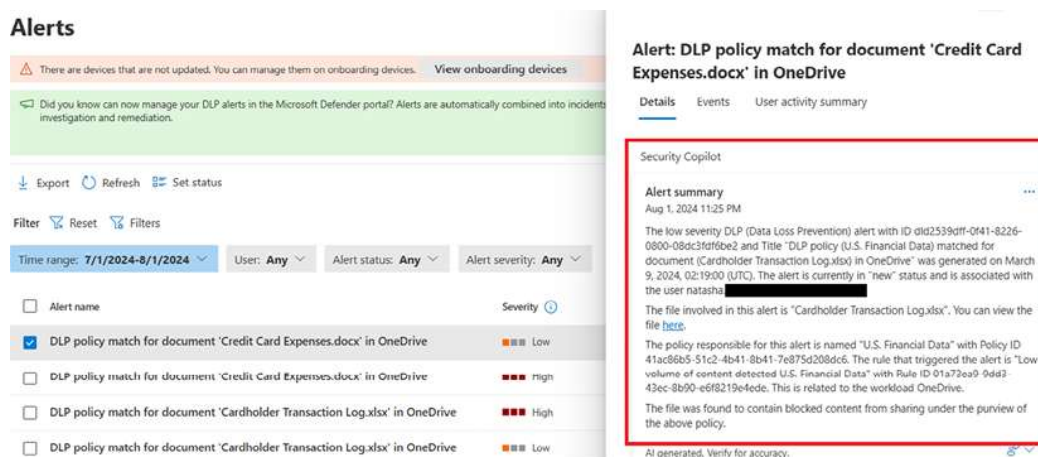


Figure 2.21 – The summary of a DLP alert

The specific policy and the rule that triggered the alert, as documented in the Security Copilot summary, are provided next for your reference:

The policy responsible for this alert is named “U.S. Financial Data” with Policy ID 41ac86b5-51c2-4b41-8b41-7e875d208dc6. The rule that triggered the alert is “Low volume of content detected U.S. Financial Data” with Rule ID 01a73ea9-9dd3-43ec-8b90-e6f8219e4ede. This is related to the workload OneDrive.

The file was found to contain blocked content from sharing under the purview of the above policy.

eDiscovery

The **eDiscovery** feature in Purview helps organizations locate and manage critical information for legal or compliance purposes. For instance, if a company is involved in a legal dispute and needs to find all emails and documents related to the specific project, eDiscovery in Purview can quickly search through all its digital content to identify and gather the relevant files.

This ensures that important information is not overlooked. Essentially, eDiscovery streamlines the process of tracking down and organizing data needed for legal cases or compliance audits.

Legal investigations can take hours, days, or even weeks to sift through the list of evidence collected in review sets. This process often requires expensive resources, such as outside counsel, to manually review each document and assess its relevance to the case.

With Security Copilot, analysts can quickly obtain a comprehensive summary of the conversations in the review set with just a single click. Review sets typically range from a few dozen to several thousand files, especially in large-scale investigations. By providing a contextual summary of items in a review set, Security Copilot greatly helps the analyst to quickly identify relevant information, saving valuable time and making the investigation process more efficient.

For example, the snippet in the next screenshot shows a portion of a review set in eDiscovery:



Figure 2.22 – A portion of a review set in eDiscovery

Imagine the time needed to read through the emails in this review set to piece together and understand what happened. In contrast, Security Copilot provides a contextual overview of the items in the review set. This summary, as illustrated next, saves analysts significant time by quickly

highlighting useful information and capturing the key details from the review set:

The conversation you provided involves two individuals, Seungin and Nina. They discuss a confidential acquisition of two companies, BitDefender and Frostvision, by another company named Contoso. Seungin shares this insider information with Nina, predicting that this acquisition will cause a surge in Contoso's stocks. They plan to capitalize on this information by purchasing stocks in BitDefender and Frostvision. Seungin advises Nina to keep this information confidential and not to act too hastily. Nina agrees to this plan and offers to split the profits with Seungin, intending to move the funds to offshore accounts. They both agree to keep their agreement a secret.

Additionally, Security Copilot offers prompts to assist in identifying relevant details, key participants, or important topics for further investigation. Here are a few examples of the prompts you may encounter:

- **Please identify key participants**
- **Please identify key topics**
- **Please identify action items**

Insider risk management

Insider risk management (IRM) in Microsoft Purview helps organizations to identify and address potential risks that come from within the company. It monitors activities and behavior to spot any unusual or suspicious actions that might indicate internal threats, such as data theft or policy violations. For example, if an employee is accessing a large volume of sensitive

information they don't normally work with or is trying to share confidential data outside the company, IRM can flag these activities for further review. By analyzing patterns and behaviors, it helps organizations detect and manage these risks before they become serious problems, ensuring a safer and more secure work environment.

Investigating an insider risk alert involves a significant amount of effort due to the extensive details that must be reviewed. Analysts need to sift through a variety of logs, including the activities that triggered the alert, user information, and historical data. To fully understand why a user was flagged as high risk, they must examine detailed records and risk factors, often navigating through a large amount of information. Additionally, it can be difficult to know where to begin the investigation, especially when risky activities span over a long period.

Again, the comprehensive summary provided by Security Copilot offers key details, including alert severity, user details, and much more! These summaries help accelerate investigations by helping the analysts quickly gain context into user intent and timing of risky activities, enabling the analysts to tailor the investigation with specific dates in mind and quickly pinpoint sensitive files at risk.

For example, from the alert summary shown next, Security Copilot indicates that this high-severity alert involves a user flagged as high risk due to substantial activities related to potential data theft. Key information includes the specific policy triggered by an HR offboarding event and the nature of the user's activities, such as cumulative exfiltration of sensitive data. The summary details the specific risk factors, such as sending 30 emails with attachments and accessing 14 sensitive SharePoint files, along with an HR event marking the user's resignation date. This organized

presentation of relevant data allows analysts to quickly assess the situation, understand the severity, and focus their investigations on the most pertinent issues.

For your reference, here's the Security Copilot summary for the Purview IRM alert:

The alert with Id: 86e52569-5953-4272-82b4-c8dae7e8cc0d is a High severity Insider Risk Management alert involving isaiah detected on April 21, 2023 21:39:29 (UTC). The policy "Potential data theft – Employee Departure" was triggered when an HR Offboarding event was detected. The user's activity that led to this alert getting generated was identified as Cumulative Exfiltration. The alert is in Confirmed state and is being investigated. The alert also has a case "Case 034: Potential data leak" associated with it.

The user is considered High risk based on the following risk factors:

- **Emails with attachments sent outside the organization (March 6, 2024 23:59:59 UTC)** - User is found to be sending 30 emails with attachments outside the organization. The emails contained priority content and were sent to 1 recipient. A total of 30 emails were sent and 1 of them contained sensitivity info.
- **Sensitive SharePoint files accessed (March 6, 2024 23:59:59 UTC)** - User is found to be accessing 14 sensitive SharePoint files. The files contained priority content and were accessed from 1 SharePoint site with sensitivity label applied. A total of 5 instances of sensitivity info were found in the files.

Additionally, an HR event was detected on March 8, 2024 (UTC) indicating that the user's resignation date has been set.

Communication compliance

Microsoft Purview's **Communication compliance** feature helps organizations ensure that their employees' communications meet company policies and legal regulations. It monitors emails, chats, and other messages to make sure they follow the rules and standards set by the organization. For instance, if an employee uses inappropriate language or makes discriminatory remarks in a company chat, the system will flag this as a potential violation. Compliance teams are then alerted to review and address the issue. This feature helps maintain professional communication practices and prevents issues by ensuring all interactions comply with organizational guidelines.

Reviewing communication violations can be time-consuming, particularly with lengthy content such as meeting transcripts, email attachments, Teams files, or extensive text. Although **Communication compliance** helps by identifying timestamps and highlighting matched conditions, there's still a significant amount of text for the analyst to sift through. However, with Security Copilot, the analyst can get a comprehensive summary of an alert with just a single click!

The summary generated by Security Copilot helps to speed up the investigation by highlighting high-risk communications. The next screen capture demonstrates using the prompt:

Summarize this message and supported attachments in the context

Communication compliance > Policies > Regulatory compliance

Pending (14) Resolved (676) Exports

Filter Save the query Reset Filters

Body/Subject: Any Date: Any Sender: Any Tags: Any

	Subject	Tags	Sender	Recipients	Sentiment	Date (UTC)
☐	Falcon Heights Eng...		David Robbins <da...	WG-FalconHeights...	Positive	Jun 11, 2024
☐	Happy new year va...		jenli@woodgrove...	jenli@woodgrove...	Not available	Jun 8, 2024
☒	Happy new year va...				Not available	
☐	Happy new year va...				Not available	
☐	Happy new year va...				Not available	
☐			Jenny Li <jenli@wo...	Patrick David <pad...	Positive	Jun 8, 2024
☐	[EXTERNAL] A Vuln...		DefenderCloudnor...	tamuto@woodgro...	Negative	Apr 26, 2024

1 of 14 selected

Security Copilot

Summarize this message and supported attachments in the context of Stock manipulation category detected

Copilot

Aug 1, 2024, 11:34 PM

The content you provided appears to be a conversation where the speaker, who claims to be from Contoso Incorporated, is offering the listener an opportunity to invest in certain stocks that are expected to rise significantly. The speaker specifically recommends PSL stock, stating that it was acquired by a large company and their merger is almost complete, which will supposedly double the listener's earnings.

What content in the message was flagged as Stock manipulation category?

Generate a simple summary of this message

Ask a question or describe what you'd like to do.

Figure 2.23 – Summarize the message and supported attachments

For example, the alert summary, as illustrated next, helps the analyst by providing key details about the conversation. It highlights that the speaker is recommending specific stocks with promises of significant returns. The statements flagged in the example suggest potential stock manipulation, as they guarantee substantial gains and hint at insider information about a merger. By outlining these crucial points, the Security Copilot summary allows the analyst to quickly assess the nature of the communication and determine whether it violates compliance policies or regulations, streamlining the review process:

The content you provided appears to be a conversation where the speaker, who claims to be from Contoso Incorporated, is offering the listener an opportunity to invest in certain stocks that are expected to rise significantly. The speaker specifically recommends PSL stock, stating

that it was acquired by a large company and their merger is almost complete, which will supposedly double the listener's earnings.

This conversation could potentially be seen as an attempt at stock manipulation, as the speaker is making recommendations to buy certain stocks with the promise of significant returns. The lines, 'I am offering you this deal ahead of time. So you can get that latest and greatest even among our valued customers. The stocks I recommend are guaranteed to rise to the moon soon.' and 'Here's the first recommendation. I'll give you PSL stock. PSL was acquired by large company and between you and me, their merger is almost complete. If you add it in your investment portfolio, you will double the earnings that you are currently seeing.' support this rationale.

You can also ask Security Copilot follow-up questions – for example, **Does this violation indicate unauthorized disclosure?** As shown next, Copilot confirms that it does appear to disclose confidential information that is not yet public knowledge. Yet again, this helps accelerate the investigation time!

The content you provided does seem to indicate a potential violation of the 'Unauthorized disclosure' category. The speaker mentions, "PSL was acquired by large company and between you and me, their merger is almost complete. If you add it in your investment portfolio, you will double the earnings that you are currently seeing." This statement appears to disclose confidential or internal information about a merger that is not yet public knowledge, which could be considered unauthorized disclosure.

Additionally, Security Copilot provides prompts or suggested questions that you can ask for further clarification – for instance, `What content in the message was flagged as Stock manipulation category?`

At this point, we have demonstrated that Security Copilot, when integrated with Microsoft Purview, enhances security analysts' ability to analyze large volumes of security data with greater efficiency and speed. This refined analysis greatly assists in identifying potential threats and unusual activities. Now, let's explore how Security Copilot can further support you within **Microsoft Defender for Cloud**.

Enhancing security with Microsoft Defender for Cloud

Microsoft Defender for Cloud is a comprehensive security solution designed to protect cloud environments. It acts as a guardian for businesses, continuously monitoring and evaluating the security of their cloud-based systems and data. It helps identify potential threats and vulnerabilities, offering insights and recommendations to strengthen security posture and resilience.

Microsoft Defender for Cloud significantly enhances security and compliance by continuously assessing cloud resources against best practices and regulatory standards. It provides actionable recommendations to address vulnerabilities and compliance gaps, such as enabling encryption or adjusting network settings.

Embedded in Defender for Cloud, Security Copilot offers powerful ways to manage and address security recommendations displayed on Defender for Cloud's recommendations page, assisting security teams in analyzing them.

You can ask Security Copilot to do things such as **Display risks for publicly exposed resources**, **reveal risks for critical resources**, or perform other specific tasks. The results help us to narrow down the recommendations and to focus on the most relevant ones. The following screen capture shows a selection of suggested prompts you can request Copilot to execute:

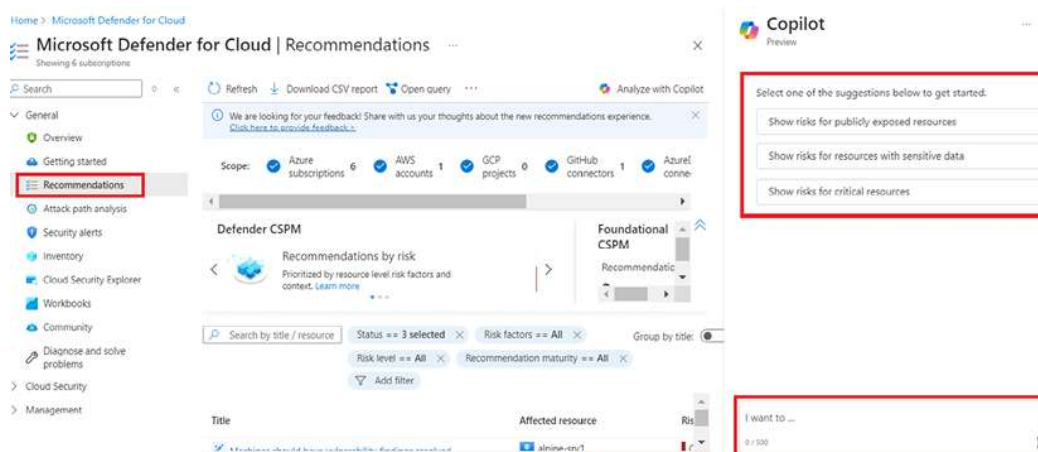


Figure 2.24 – Security Copilot prompt suggestion in Defender for Cloud

For any specific recommendation, Security Copilot can summarize it to offer a clear overview of the associated risks and vulnerabilities. The next screenshot demonstrates how to request a summary from Security Copilot with a single click:

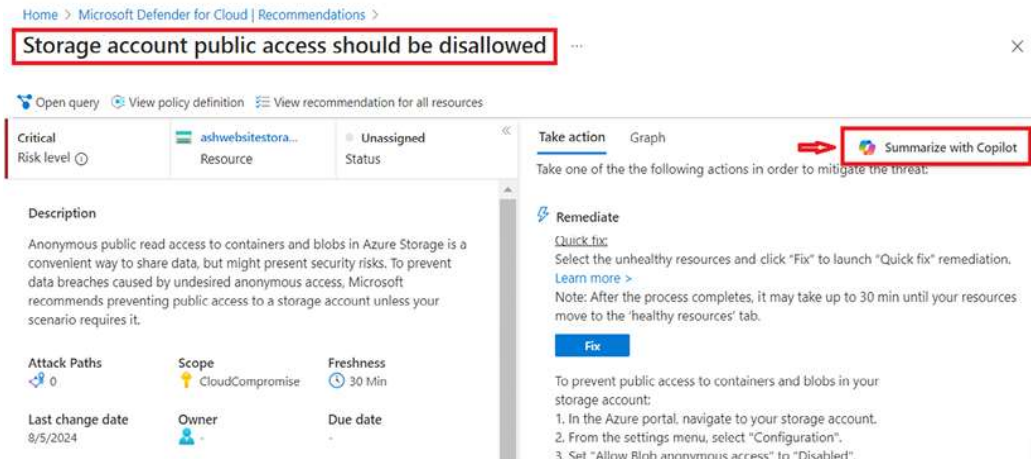


Figure 2.25 – Summarize recommendation with Copilot

The summary generated by Security Copilot presents the recommendation information in an easy-to-understand manner, allowing security teams to quickly grasp the key details and prioritize remediation efforts effectively. For your reference, the next screenshot captures the recommendation summary generated by Security Copilot:

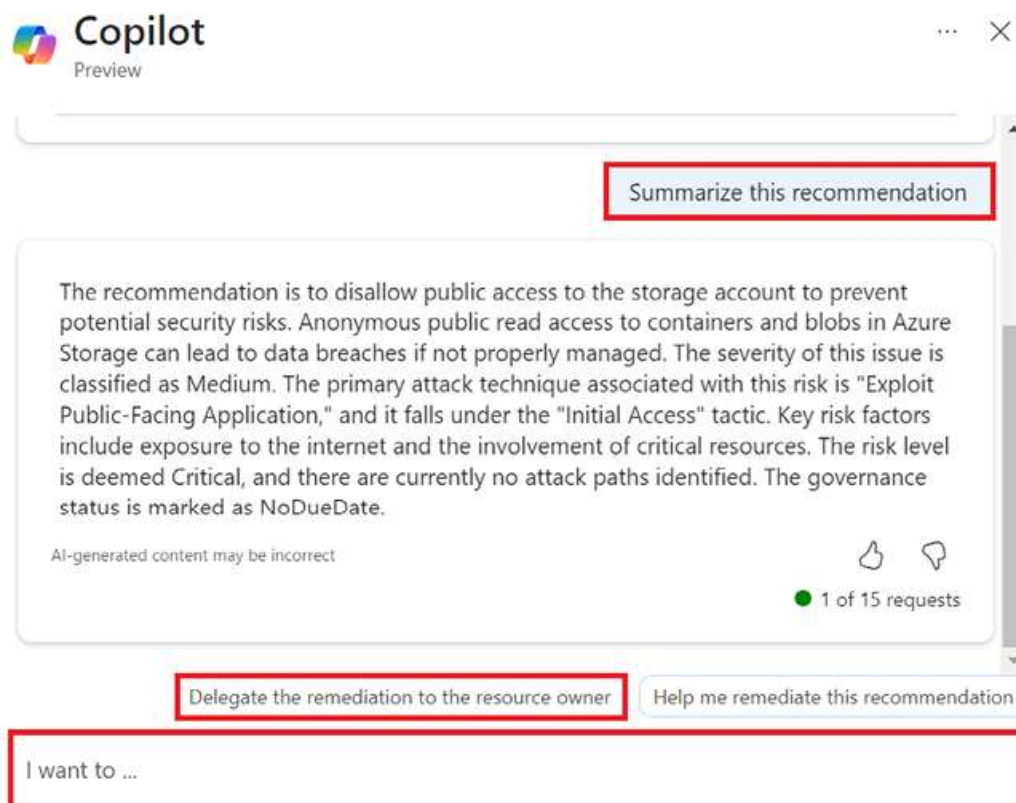


Figure 2.26 – Recommendation summary generated by Security Copilot

As shown in the previous screenshot, if needed, you can always supplement the Copilot summary with additional prompts or questions for Security Copilot. Furthermore, after Security Copilot summarizes a recommendation, it then assists the security teams with the remediation process. Security Copilot provides suggested prompts, such as **Help me remediate this recommendation**, allowing the analysts to request further action from Copilot. The security teams can then review the suggested remediation details and follow the provided instructions to address the recommendation. If there are uncertainties or additional guidance is needed, Security Copilot can be queried for further information using additional prompts.

If a script is included in the remediation step, the security analyst can choose the **Run** option inside the Security Copilot panel to apply the remediation, as illustrated in the next screen capture:

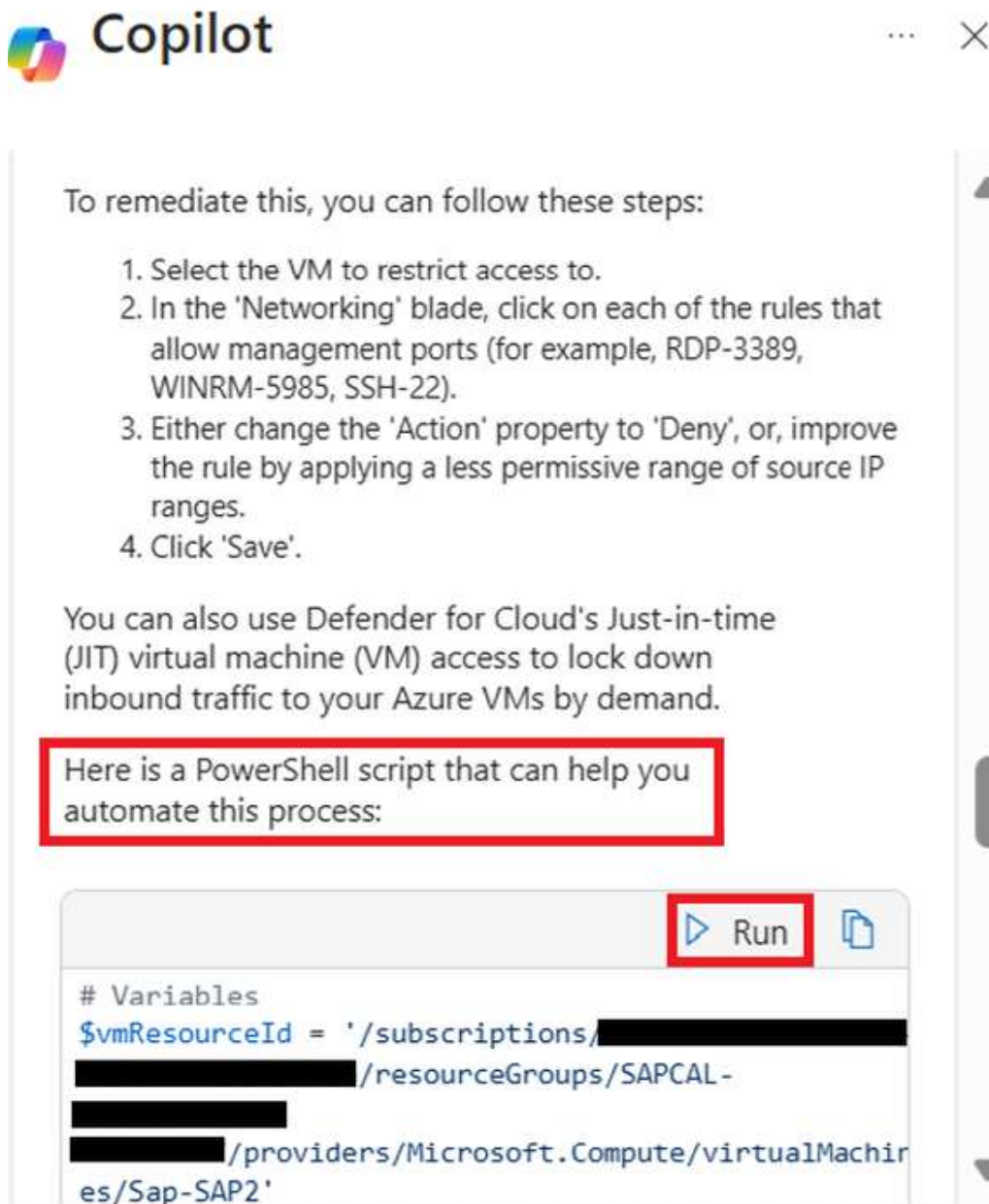


Figure 2.27 – Running the script to apply the remediation

Additionally, within Security Copilot, recommendations can be assigned to other team members, ensuring that specific issues are handled by the appropriate experts:

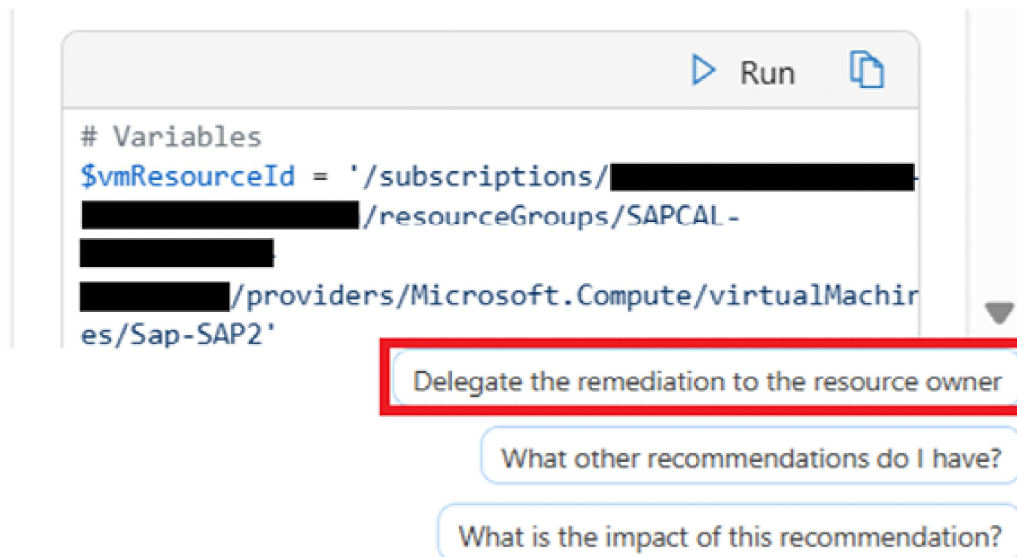


Figure 2.28 – Delegating the remediation

In summary, Security Copilot can analyze all the recommendations, enabling you to leverage these analytical insights to focus on specific recommendations in Defender for Cloud. Security Copilot also provides concise summaries of these recommendations, making it easier to understand and prioritize them. It supports the remediation process and allows for delegating tasks to the appropriate team members, ensuring that the right experts address the identified issues effectively. Next, we will explore how Security Copilot assists the security and IT teams when it is integrated into **Microsoft Intune**.

Utilizing Security Copilot in Microsoft Intune

Microsoft Intune is a solution that helps organizations manage and secure their employees' devices and applications. Think of it as a central control panel that allows a company to ensure that smartphones, tablets, and computers are used safely and effectively. It helps administrators set up policies to protect sensitive information, manage which applications can be used, and ensure that all devices comply with security standards. By using Intune, companies can maintain control over their technology while making sure that employees have the tools they need to do their jobs securely and efficiently.

Endpoint security policies, such as those for Defender Antivirus, Attack Surface Reduction, App Control for Business, disk encryption, Windows firewall, and others, can be defined and configured within Intune. These policies are designed to enhance device security and reduce risk.

Embedded within Intune, Security Copilot supports security teams in managing policies and settings. It provides summaries of policies, evaluates their impact on users, devices, and overall security, and explains specific configuration settings within Intune. Additionally, it excels at identifying potential policy conflicts. Security Copilot also helps IT admins manage and troubleshoot devices efficiently.

Policy and settings management

For any existing Intune policies, Security Copilot provides a summary that offers an overview of the policy details. This summary covers the policy's configurations, the users and groups it applies to, and its specific settings. This information provides insights into what the policy entails and how its

configurations impact users and devices. The next screenshot displays the summary generated by Security Copilot:

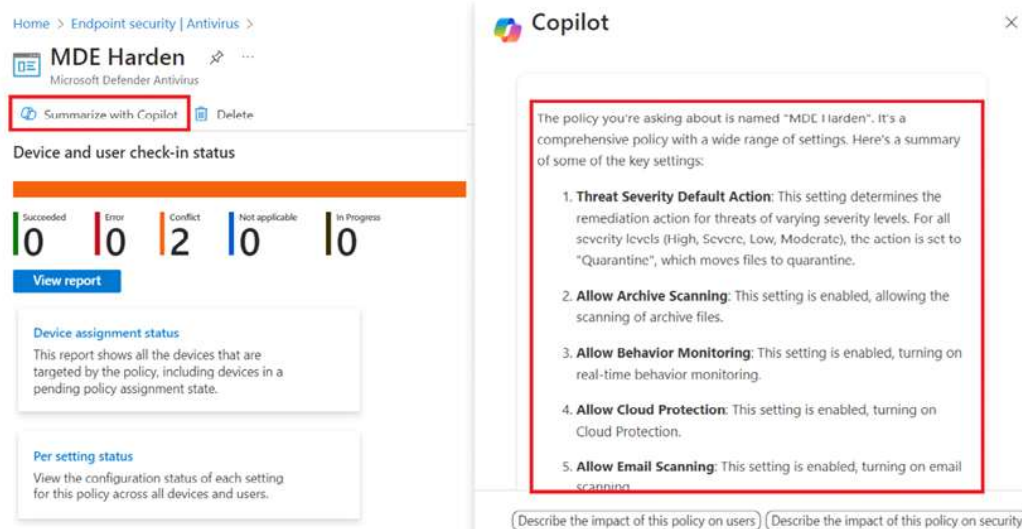


Figure 2.29 – Summary of an Intune policy

For the same Defender policy, Security Copilot offers additional commands, known as prompts, that can be used to request further actions or information. For instance, you can ask Security Copilot to describe the impact of this policy on users. As illustrated in the following snippet, Security Copilot dutifully provides a detailed assessment of how this policy affects user experience:

The policy “MDE Harden” has a wide range of settings that could impact users in various ways. Here’s a detailed analysis:

1. **Threat Severity Default Action:** All threats, regardless of their severity level, are set to be quarantined. This means that any detected threats will be moved to a secure location, preventing them from causing harm. However, this could potentially lead to false

positives being quarantined, which might disrupt user activities if legitimate files are incorrectly flagged.

2. **Allow Archive Scanning:** This setting is enabled, allowing the scanning of archive files. This enhances security by detecting threats within compressed files, but it might slightly increase the time required for scans.
3. **Allow Behavior Monitoring:** This setting is enabled, providing real-time behavior monitoring. This can detect and stop malicious activities based on their behavior, but it might cause performance impacts if many activities need to be monitored.

You can then request Security Copilot to explain the impact of this policy on security. A sample of Copilot's response is provided next:

The policy "MDE Harden" has a wide range of settings that could significantly impact the security of your system. Here's a detailed analysis:

1. **Threat Severity Default Action:** This setting quarantines threats of all severity levels. This can improve security by promptly dealing with threats, but it could potentially disrupt user activities if legitimate files are incorrectly flagged.
2. **Allow Archive Scanning:** This setting scans archive files, enhancing security by detecting threats within compressed files. However, it might slightly increase the time required for scans.
3. **Allow Behavior Monitoring:** This setting turns on real-time behavior monitoring, which can detect and stop malicious activities

based on their behavior. However, it might cause performance impacts if many activities need to be monitored.

You can also ask Security Copilot to explain a specific configuration setting in an Intune policy, as illustrated in the next screenshot:

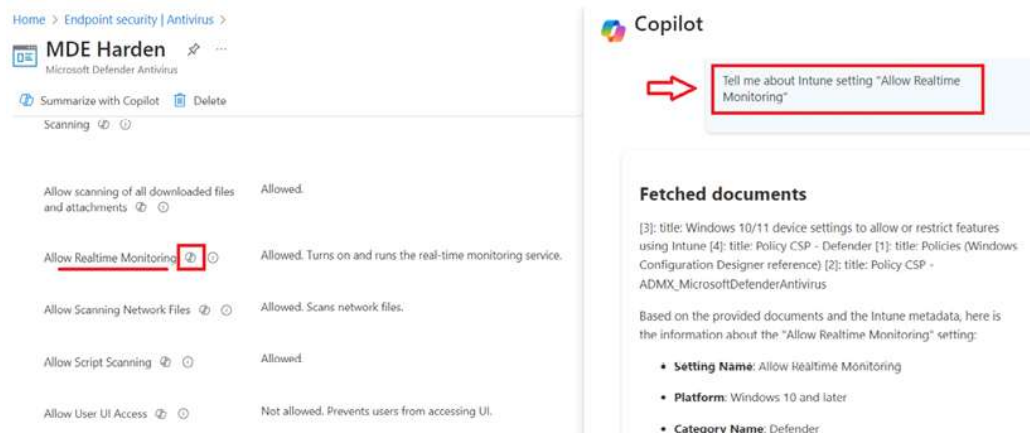


Figure 2.30 – Asking Security Copilot about a specific configuration setting

Again, Security Copilot provides detailed information about the configuration setting along with reference links. This reduces the time and effort required to search through a large number of online documents for similar information, which is often less comprehensive than the insights provided by Security Copilot.

In the Security Copilot window, there are many more pre-drafted commands or questions, known as prompts, available for use. Users can access these prompts by selecting the prompt guide and choosing from the existing list of options. For instance, you can pick **Has this setting been configured in any other policies?** from the prompt guide to look for potential policy conflicts within Intune. This makes it even easier to navigate and manage settings. More Security Copilot features for Intune will be covered in [Chapter 9](#) through a detailed case study.

Device details and troubleshooting

With Security Copilot integrated into Microsoft Intune, IT administrators can effectively manage and troubleshoot devices. When accessing a specific device in Intune's device blade, Security Copilot appears on the device's **Overview** page, ready to assist. It provides three main features: **Explore device**, **Compare to another device**, and **Analyze error code**, as seen in the next screenshot:

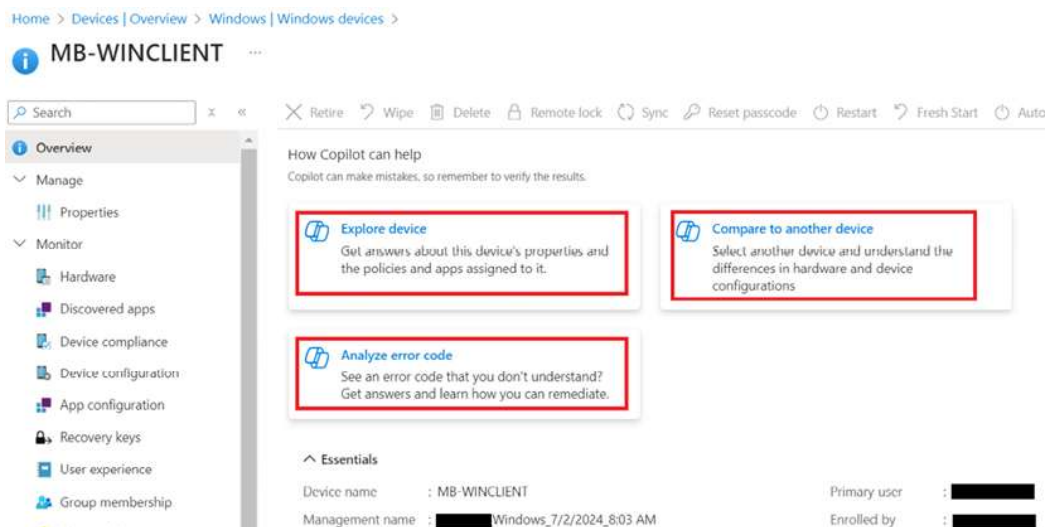


Figure 2.31 – Security Copilot embedded in the device page

You can leverage Security Copilot to explore a device, gather detailed information such as installed apps and group membership, and more. Additionally, you can request Security Copilot to compare this device with another sometimes similar or identical device, to identify differences and guide your investigation. Security Copilot can also be used to analyze error codes.

Through the **Explore device** option, you can ask Security Copilot to provide a device summary, policies assigned to this device, apps on this device, primary user, group membership, and more, as shown next:

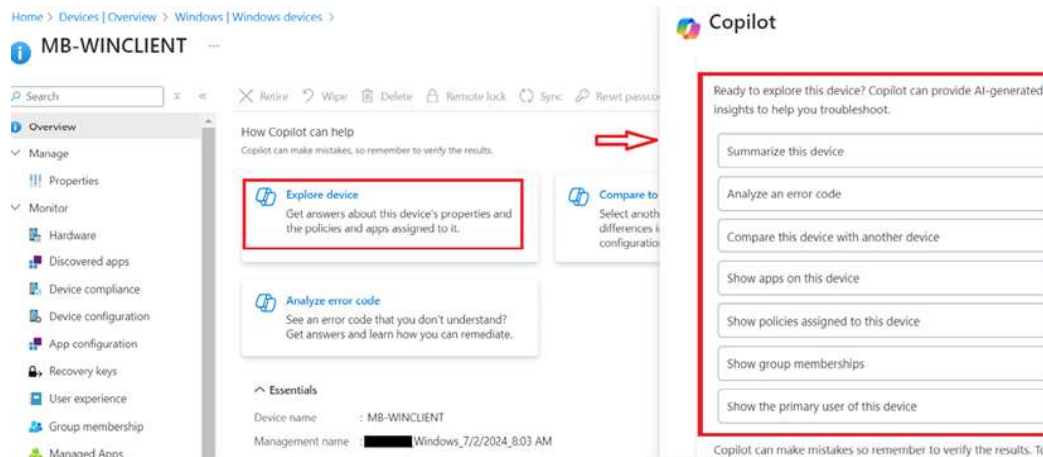


Figure 2.32 – Security Copilot provides device insights

The device summary provides detailed information about the device, including its OS, model, type, user, compliance status, and reasons for non-compliance. Security Copilot can also display either managed apps or discovered apps for this device. It also lists configuration profiles, compliance policies, or app configuration policies on this device.

Security Copilot helps to resolve issues with specific devices by comparing working and non-working devices. By comparing a functioning device with a malfunctioning one, you can pinpoint differences and troubleshoot the problematic device. Alternatively, when examining a suspicious device, you can compare it with a similar or identical device to understand discrepancies and to guide your investigation. There are a few comparison types, as illustrated in the next screenshot:

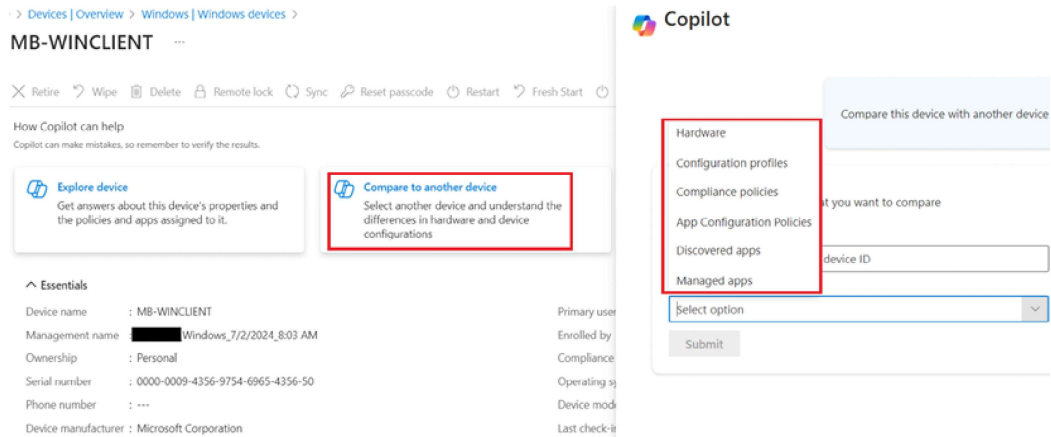


Figure 2.33 – Options to compare to another device in Security Copilot

Security Copilot interprets error codes and offers detailed explanations and troubleshooting steps to assist IT professionals in resolving issues related to device configuration profiles, compliance policies, app installations, and more. For instance, when inquiring about error code `0xC7D14FBA`, Security Copilot explains that this error occurs because the app installation failed due to the necessary file being deleted before the process finished. This typically happens if there is a significant delay between downloading the app and attempting to install it. Security Copilot additionally provides troubleshooting steps.

In summary, we've looked into how Security Copilot, embedded within Intune, empowers security and IT teams by simplifying policy and setting management, summarizing their impact on users and devices, and identifying potential conflicts. It also enables IT admins to manage and troubleshoot devices more efficiently.

The Security Copilot features you have reviewed so far are built right into the Microsoft security solutions. This is referred to as the embedded experience. As you've seen, these Copilot capabilities enhance the functionality of the Microsoft products they are integrated with and act as

an assistant to security teams, offering support and guidance to analysts while they're using the solution.



Note

Due to fast-paced Security Copilot development, these features are representative of some of the capabilities within the embedded experiences and new features are continuously being added to improve functionality and usability.

In addition to the embedded experience, you can pivot to the dedicated Security Copilot portal, known as the standalone experience. This standalone environment offers even more advanced features and capabilities. In the next section, let's take a quick look at it and get acquainted with its features.

From the embedded experience to the standalone experience

The Security Copilot capabilities embedded within a specific Microsoft product are designed to work exclusively with that solution. Consequently, with the embedded experience, you can only access the Security Copilot knowledge and capabilities that are directly relevant to the product you're working with. For example, if you're using Security Copilot within the Microsoft Defender XDR solution, the Copilot features available are specific to Defender's capabilities.

While the embedded experience is product-specific, you can switch to Security Copilot's standalone experience, which allows you to access and make use of different security solutions simultaneously through a unified interface. This consolidated platform provides an integrated and streamlined experience for you. It enables you to leverage the full range of Security Copilot capabilities from Microsoft and non-Microsoft solutions, eliminating the need to switch between different technologies or interfaces. Additionally, the standalone experience not only offers all the capabilities found in the embedded mode but also provides many additional advanced and powerful features not present in the embedded experience.

As we explore the standalone experience available at <https://securitycopilot.microsoft.com/>, it's essential to get familiar with the key concepts and terminologies that are commonly encountered there. For the next few sections, let's review these terms to get a better understanding of the standalone experience.

Plugin

In Security Copilot, a **plugin** provides a set of specialized AI functionalities that extend the core capabilities of Security Copilot. These plugins enable Security Copilot to access and utilize features and data from integrated security solutions, offering more comprehensive and tailored security insights and support. For example, there is the Microsoft Defender XDR plugin in Security Copilot, as well as plugins for Intune, Microsoft Entra, and third-party solutions such as ServiceNow or AbuseIPDB.

Plugins transform Security Copilot from a static product into a dynamic, customizable platform. First, plugins allow Security Copilot to connect with a wide range of security solutions, from both Microsoft and third-party

providers. You can easily enable or disable plugins within Security Copilot. When a plugin is turned off, Security Copilot will no longer use that solution. This modular approach allows you to tailor the platform to your needs. Furthermore, it offers greater flexibility and adaptability over time as new plugins, including your own custom ones, are introduced.

The screenshot shown next showcases various Microsoft plugins:

Manage sources

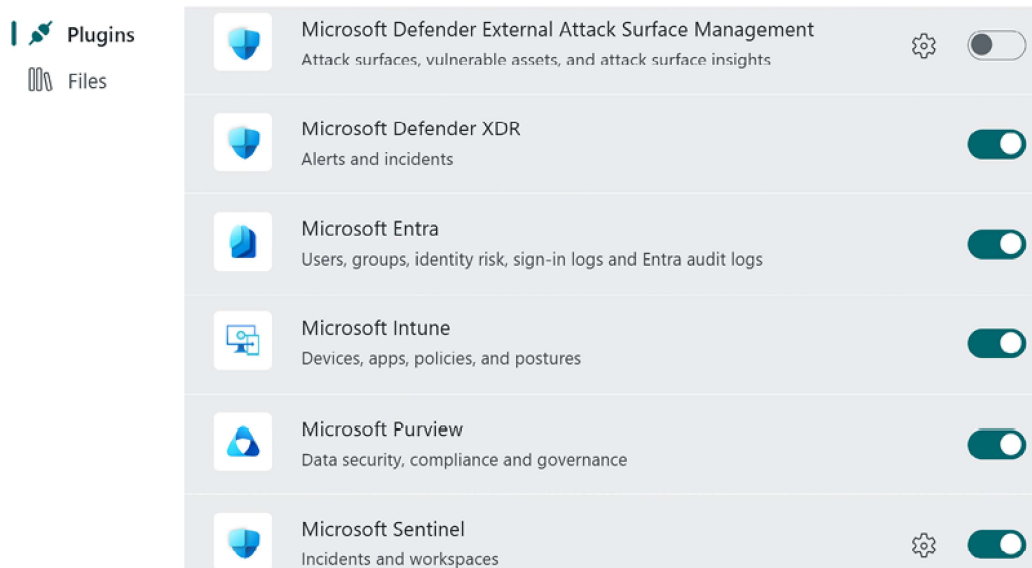


Figure 2.34 – Microsoft plugins

Capability/skill

A **capability**, also referred to as a **skill**, is a specific feature or function that a plugin provides. It highlights what the plugin can do. For instance, the Microsoft Defender XDR plugin includes capabilities such as incident summarization, guided response, scripts and code analysis, KQL query generation, incident report creation, and more.

Each plugin allows Security Copilot to access capabilities or skills tied to the particular data source to which the plugin is connected. These unique capabilities or skills enhance Security Copilot's overall functionality, making it more flexible and adaptable to different needs.

Prompt

A **prompt** is a specific instruction given to Security Copilot to generate a response, perform a task, or take action based on the input provided. For instance, a prompt could request Security Copilot to summarize a policy, create a hunting query in KQL, or address a recommendation. Essentially, the prompt directs Security Copilot's capabilities to address specific needs, allowing you to get targeted insights and relevant support.

The following screenshot shows several of the prompts suggested by Security Copilot in the embedded experience:

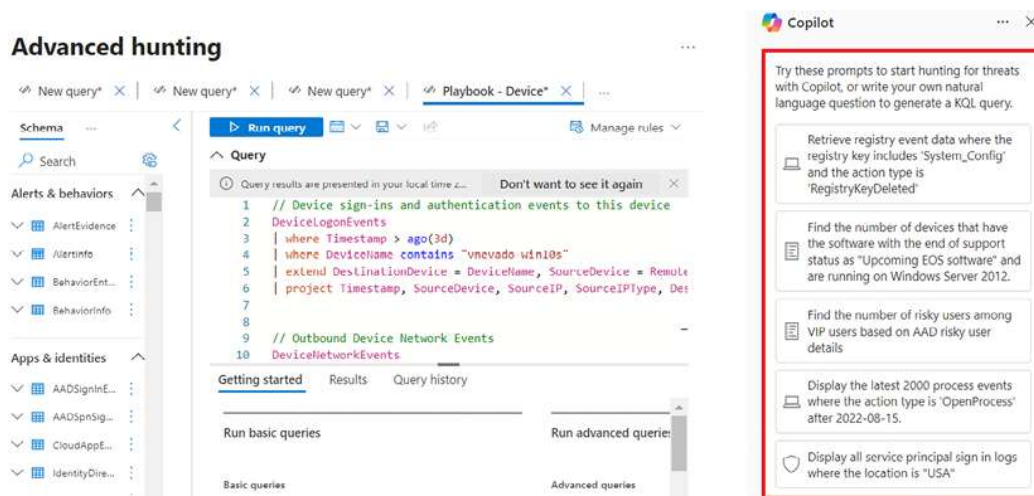


Figure 2.35 – Security Copilot prompts

Prompts are used in both the embedded and the standalone experiences. In the embedded experience, prompts can be automatically generated by

Security Copilot or entered by users. In the standalone environment, user-entered prompts are the primary method for interacting with Security Copilot, although suggested prompts are also available on the main landing page and throughout your working sessions in Copilot.

There are various collections of sample prompts you can reference online. One is the main Microsoft Security Copilot **prompt library** at <https://github.com/Azure/Security-Copilot/tree/main/Sample%20Prompts>. Another good online resource is <https://aka.ms/CfSPromptLibrary>. All the prompts featured in this book can be found at <https://github.com/PacktPublishing/Microsoft-Copilot-for-Security/tree/main/Prompts>.

Promptbook

A **promptbook** is a collection of prompts that have been put together to accomplish a set of specific tasks. Think of it as a playbook with a ready-to-use template that runs a series of prompts in sequence to complete various tasks for analysts.

Here is an example of a promptbook that analyzes an IP address using different threat intelligence sources such as **Microsoft Defender Threat Intelligence (MDTI)**, VirusTotal, CrowdSec, and Shodan. Notice this promptbook requires the user to provide input:

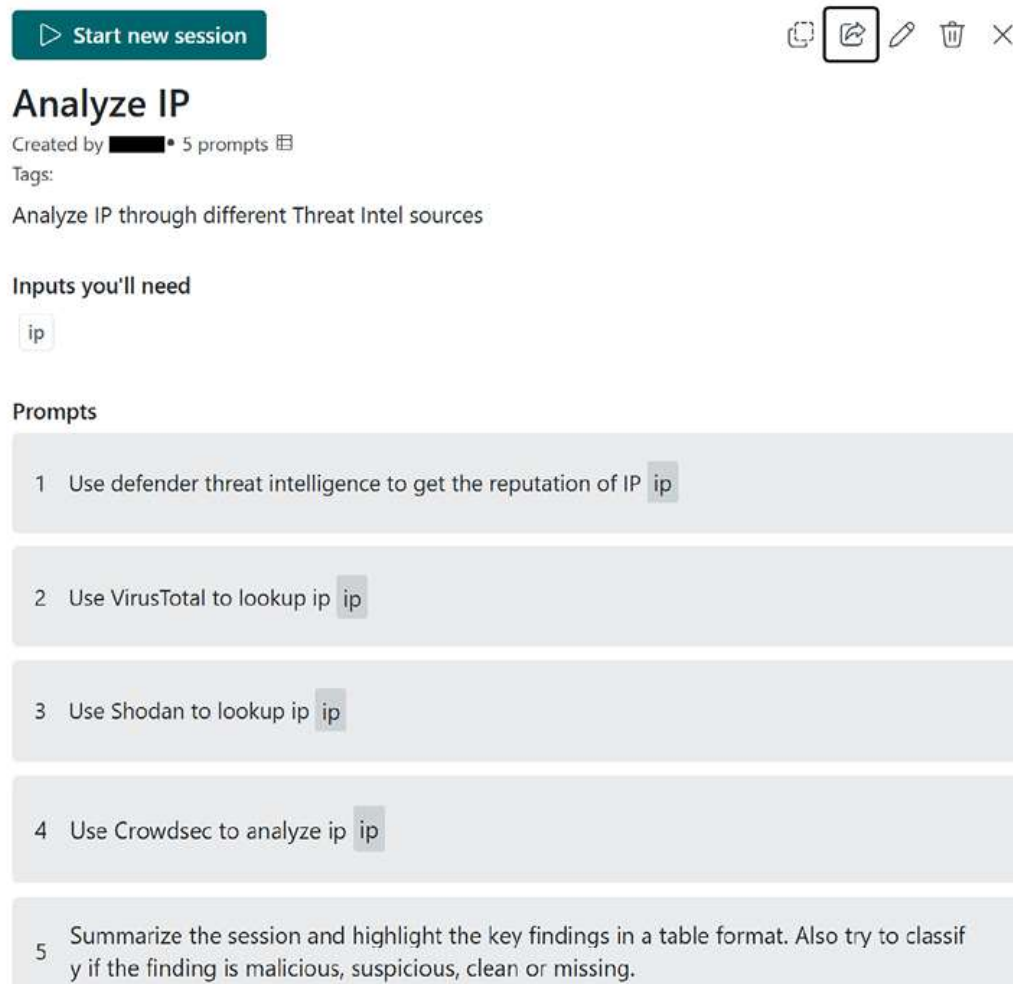


Figure 2.36 – Security Copilot promptbook

The promptbook first asks the user to enter the IP address to be analyzed. Then, the first prompt in the promptbook queries MDTI to obtain the IP's reputation. Additional prompts then use other security tools, such as VirusTotal and Shodan, to further investigate the IP. The last prompt asks Security Copilot to generate a report and highlight key findings.

Session

A **session** is a distinct interaction period with Security Copilot, where an analyst's engagement is tracked and managed. It captures the sequence of

the analyst’s prompts and responses. Sessions are designed to provide continuity, allowing analysts to pick up where they left off, review previous interactions, and maintain context throughout their work.

As analysts enter prompts and receive responses from Security Copilot, they may have follow-up requests based on the information provided. Copilot maintains the context within the session, allowing it to provide relevant answers to these subsequent requests. *This context-aware interaction ensures that the conversation flows logically and that each response builds upon the previous ones, creating a cohesive and efficient experience for the user.*

In the standalone experience of Security Copilot, you can manage your sessions with search and filter options, and rename or delete sessions. You can also view sessions created by embedded experiences. This ensures a consistent and integrated experience across both the embedded and standalone platforms.

The next screenshot displays a list of various sessions, including those that have been renamed:



My sessions			+ New session
All Recent			
Delete			
☐ Name	Last updated	Created	
☐ 8-25-2024 - KQL Analysis Testing	9:57 AM	Sunday	
☐ 8-25-2024 - Incident 889 Investigation	Sunday	Sunday	
☐ 8-25-2024 - Prompt Testing	Sunday	Sunday	
☐ File analysis for 3da48595922c3932382e90aee27898fdbe18b708c466bf99f0b64c584ef5635	Sunday	Sunday	
☐ Guided response for incident 889	Sunday	Sunday	

Figure 2.37 – Security Copilot sessions

The Security Copilot session can be shared with others. Sharing a session enhances collaboration within security teams. It enables multiple users to work together, review information, and make decisions. Session sharing is particularly useful for security reviews and incident investigations, as it allows for input from various team members. Additionally, session sharing serves as an effective training tool to show new team members how to manage different security scenarios.

Furthermore, sessions are retained indefinitely. As the list grows, you may want to consider deleting obsolete sessions or renaming older ones to make it easier to find the specific session later on. Alternatively, you have the option to convert commonly used sessions into promptbooks. Details on how to do this will be covered in [Chapter 6](#).

At this point, we have covered the key concepts and terminologies of the standalone environment. To fully showcase its advanced features, a more in-depth approach is needed. Therefore, throughout this book, we will gradually dive into these features, providing detailed explanations and practical illustrations along the way.

Summary

This chapter has provided an introduction to the capabilities and features of Security Copilot, giving you a better understanding of what it is and how it operates, especially when it is embedded in Microsoft security solutions.

The thorough introduction allows you to see how Security Copilot can serve as a smart assistant, transforming security operations and empowering your team's success. This foundational knowledge of Security Copilot's core features and benefits will prepare you for a more in-depth exploration of its advanced functionalities in the upcoming chapters.

With a solid understanding of Security Copilot in place, in the next chapter, we will focus on its onboarding and setup. You'll be guided through the onboarding process and be introduced to Security Copilot's user interfaces, assisting you to navigate the tool effectively. Lastly, to help you become more familiar with how Security Copilot works in practice, you will go through a case study and experience firsthand how Security Copilot can be applied in a real-life security incident investigation.

Unlock this book's exclusive benefits now

Scan this QR code or go to
packtpub.com/unlock, then search
this book by name.

*Note: Keep your purchase invoice ready
before you start.*



OceanofPDF.com

3

Navigating the Security Copilot Platform

The previous chapter highlighted some of the key capabilities and features of **Security Copilot**, formally introducing the tool to you. It provided a detailed explanation of what the tool is and how it functions. You were able to see Security Copilot in action when it is embedded within various Microsoft security solutions. You also became familiar with essential concepts and terminologies relevant to Security Copilot's standalone experience. This introduction showcased how Security Copilot can serve as a handy, resourceful, and smart assistant, transforming security operations and empowering security professionals.

After becoming acquainted with Security Copilot and exploring its functionalities, you may be eager to set it up and start enjoying its benefits. To get started, in this chapter, we will go through Security Copilot's onboarding process and review its user interfaces, enabling you to navigate the tool more efficiently and effectively. By understanding the setup and customization of the tool, you will be better equipped to meet your specific security needs and ensure that you can maximize its AI capabilities.

In the final section of the chapter, we will present a case study to showcase how Security Copilot can be used in an actual security incident

investigation. This will give you a more interactive demonstration of how the tool functions in real-world scenarios, helping you gain a better understanding of its application and how it supports security operations in practice.

With this in mind, the upcoming sections of this chapter will navigate you through the journey:

- Setting the stage – technical requirements and onboarding
- Navigating the user interfaces
- Case study – harnessing Security Copilot in defending against cyber threats



Want to try out the prompts, custom plugins, and promptbooks featured in this book? Take a look at the book's GitHub repository at <https://github.com/PacktPublishing/Micro-soft-Copilot-for-Security>.

Setting the stage - technical requirements and onboarding

Before setting up Security Copilot, there are a few prerequisites to keep in mind. First, you will need an active Azure subscription, as Security Copilot is hosted in Azure. Additionally, you must ensure that you have the necessary permissions and access rights within your Azure environment to

configure and manage the service. It's also important to estimate the expected usage of Security Copilot.

If any of this seems overwhelming or confusing, don't worry; we'll explore them in more detail next to help you get started and guide you through the setup process.

Getting ready for onboarding

To start the onboarding process, you'll need an Azure subscription, which operates much like a utility account but for Microsoft's Azure cloud services. Just as a utility account handles billing and management for electricity or water, an Azure subscription manages and pays for the Azure services used. With Security Copilot hosted on Azure, the subscription is essential for accessing and setting up the service.

Security Copilot operates on a provisioned capacity model. Its costs are incurred based on the number of **Security Compute Units (SCUs)** allocated and any additional overage usage. Each task performed by Security Copilot consumes a specific amount of SCUs. The more complex or numerous the tasks, the more SCUs are consumed. To help with managing the cost, you can estimate the expected SCU usage by monitoring the overall usage dashboard available in the Security Copilot portal.

SCUs can be purchased either through the Security Copilot portal or via Azure, during the initial setup or at a later time. *"Microsoft recommends provisioning 3 SCUs per hour to start your Security Copilot exploration"* (Microsoft, *Microsoft Security Copilot pricing*:

<https://azure.microsoft.com/en-us/pricing/details/microsoft-copilot-for->

[security/](#)). Your actual SCU needs vary depending on the Security Copilot features you use and the number of users. Typically, each embedded experience requires one SCU, while running prompts in the standalone experience requires at least three additional SCUs. If you're using promptbooks and logic apps, you should plan for three to five more SCUs.

During the initial phase, as you use Security Copilot and begin integrating it into your daily processes, you'll gain a better understanding of your actual SCU requirements. SCUs can be easily scaled up or down to adjust to your processing needs.

Besides SCUs, you might frequently encounter the term **capacity**. In the context of Security Copilot, capacity refers to an Azure resource that contains SCUs. It denotes the amount of computing power allocated for managing and analyzing security tasks, encompassing the SCUs required to perform these operations effectively.

A more in-depth discussion of the Security Copilot pricing structure, the role of SCUs in cost management, and the usage dashboard can be found in [Chapter 11](#). For now, let's move on to the onboarding process for Security Copilot.

Onboarding Security Copilot

Onboarding to Security Copilot involves a two-step process: first, provisioning the capacity, and second, setting up the default environment.

Step 1 - provision capacity

There are two options for provisioning capacity: either directly within Security Copilot or through Azure. Regardless of the option you choose,

you'll need to enter the same information and fill out the same fields with each method. Although the user interfaces differ, the details you provide, such as Azure subscription name, capacity name, and other relevant information, are consistent across both methods.

You can follow the steps outlined next to reach the capacity provisioning page in Azure:

1. Go to Azure at <https://portal.azure.com/>.
2. In the Azure search bar, type `security copilot` and then select the Azure service, **Microsoft Security compute capacities**, as illustrated here:

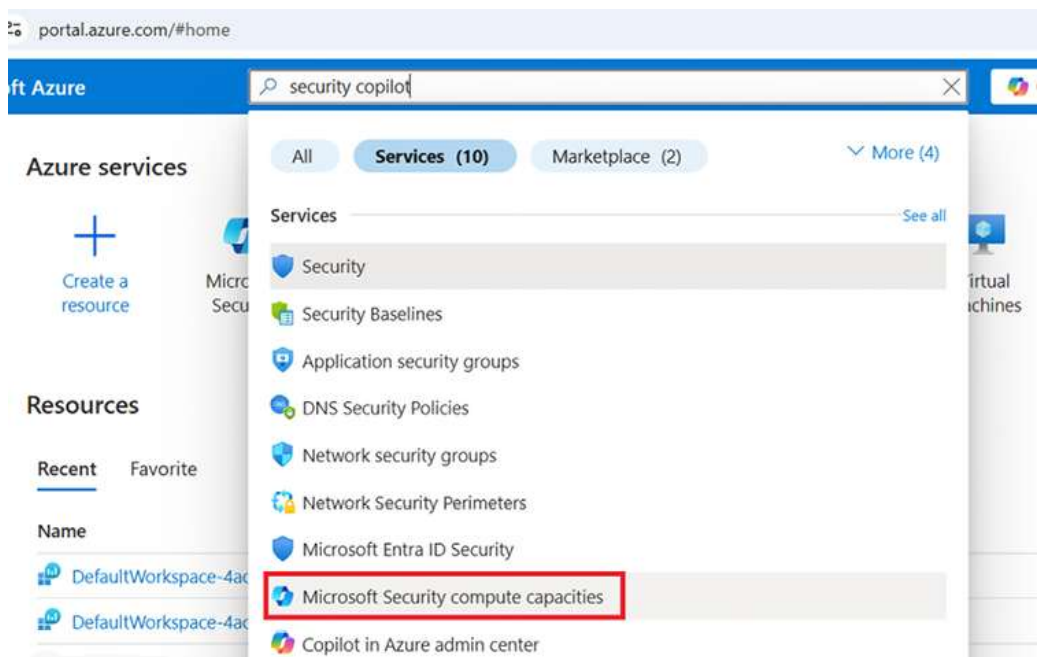


Figure 3.1 – Microsoft Security Copilot compute capacities

3. The Security Copilot capacity provisioning page, as shown next, then appears:

This capacity will provide the computing power that drives the Microsoft Security Copilot experience.

Project Details

Subscription * ⓘ

Resource group * ⓘ [Create new](#)

Capacity details

Name your capacity and select a location

Capacity name * ⓘ
This name must be unique and contain only lowercase letters and numbers with no spaces.

Prompt evaluation location * ⓘ

☐ If this location is busy, allow Copilot to evaluate prompts anywhere in the world (recommended for optimal performance).

Capacity region ⓘ US East

Security compute units

Security compute units provide the computing power that drives the Security Copilot experience (USD 4 per unit). Read more about [security compute units](#) and the recommended number based on your organization's size and probable usage.

Security compute units per hour * ⓘ
Estimated monthly cost \$2880/month

Overage Capacity Setup ☒ Enable Overage Capacity

☐ I acknowledge that I have read, understood, and agreed to the [Terms and Conditions](#)

Figure 3.2 – Security Copilot capacity provisioning in Azure

To get to the capacity provisioning page directly within Security Copilot, simply visit the Security Copilot portal at <https://securitycopilot.microsoft.com>.

4. The capacity provisioning wizard then appears to guide you through the process. The main sections of the wizard page are displayed in the next screenshot:

Set up your security capacity

Security Copilot is a generative AI-first platform with asset mapping, tiered storage, policy services, integration services, and more. It powers all workloads of the security platform.

Azure Subscription * ⓘ

Subscription name ▼

Resource group * ⓘ

Select a resource group ▼

Create a new resource group

Capacity name * ⓘ

[Suggested Default name]

This name must be unique and contain only lower case letter and numbers with no spaces.

Prompt evaluation location * ⓘ

[Geo] ▼

☐ If this location has too much traffic, allow Copilot to evaluate prompts anywhere in the world (recommended for optimal performance).

Capacity region * ⓘ

Figure 3.3 – Capacity provisioning in Security Copilot

5. The last section of the wizard page is displayed next. It lets you select the number of SCUs:

Select the number of units

Security compute units are billed per hour and are needed for Security Copilot to work across your Microsoft Security products. There are two kinds: provisioned and overage. [Help me decide](#)

Provisioned security compute units *
\$ 4 USD per unit

☒ **Use overage units when needed**
\$ 6 USD per unit

How overage units work

Overage units will be used after you've run out of provisioned units. You'll only pay for the overage units that you use.

Number of on-demand units

☒ No limit

☐ Set a max-limit

Figure 3.4 – The last section of the wizard page

As you navigate through the capacity provisioning wizard, there are specific details you need to provide to complete the process:

- **Azure Subscription:** The name of the Azure subscription where you host and manage your Security Copilot resources and associated costs.
- **Resource group:** The name of the Azure resource group where the Security Copilot resources will be deployed. A resource group is a container that holds related resources for an Azure solution and allows you to manage them collectively, including their lifecycle, permissions, and policies.
- **Capacity name:** Capacity is a specific resource within Azure that deals with the provisioning of SCUs for Security Copilot. You will provide a unique name for it. This capacity will be displayed in the

Security Copilot portal and Azure portal. Make sure it is unique and identifiable. Changing its name later can be difficult.

- **Prompt evaluation location:** This is the location where your prompts will be evaluated. As mentioned in the previous chapter, a prompt is the instruction you give to Security Copilot for it to generate a response.
- **Capacity region:** This is the geographic region where the capacity will be hosted. It determines the physical location of your resources.
- **Security Compute Units (SCUs):** This is where you enter the estimated number of SCUs you expect for Security Copilot usage. SCUs represent the units of resources needed for the reliable performance of Security Copilot. Microsoft recommends starting with a baseline of three SCUs. However, it's important to estimate your expected usage prior to setting up Security Copilot. Note, you'll be able to increase or decrease the number of units at any time.
- **Overage units:** If your provisioned SCUs are exhausted during unexpected Security Copilot workload spikes, the overage amount you configure ensures additional SCUs are available to handle the demand.

With the information you provide, the provisioning process creates a resource group for the Microsoft Security Copilot service within your Azure subscription. The SCUs are then allocated as an Azure resource within that resource group.

As you can see from the previous three screenshots, the provisioning process is simple and straightforward. Microsoft recommends provisioning the capacity within the Security Copilot portal.

Important note



Since capacity provisioning is handled through Azure, you need to be an Azure subscription owner or contributor to provision capacity, regardless of whether you are using Security Copilot or Azure to do so.

Note that having a *Global Administrator* role in Microsoft Entra does not automatically grant access to Azure subscriptions or resources. Entra roles (such as *Global Administrator*) and Azure RBAC roles (such as *Owner* or *Contributor*) are separate and managed independently. If you're provisioning with a *Global Administrator* account and encounter errors, be sure to verify that your account has the necessary Azure subscription permissions.

After you've completed the capacity provisioning process, the next step is to configure the default environment for Security Copilot.

Step 2 - setting up the default environment for Security Copilot

To set up the default environment, you need to be at least a *Security Administrator* or a *Global Administrator*, and you need to provide the following key information:

- **SCU capacity:** Select the capacity of SCUs previously provisioned
- **Data storage:** Confirm the geographic location where your collected data will be stored
- **Data sharing options:** You can opt in or opt out of data sharing options, as shown in the following screenshot:



Figure 3.5 – Security Copilot data sharing options

- **Roles:** Select the roles that are authorized to access Security Copilot, as shown in the next screenshot:

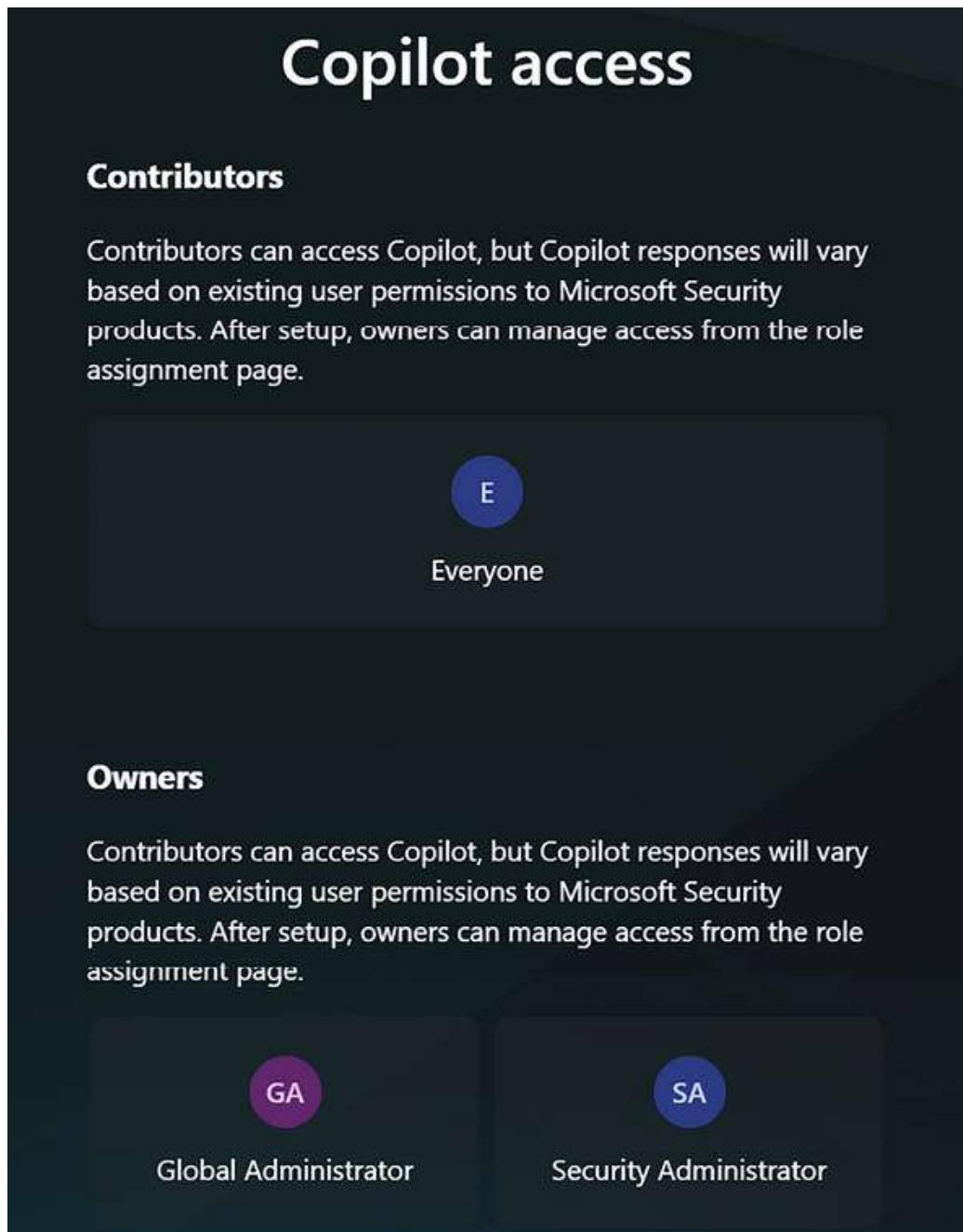


Figure 3.6 – Security Copilot default roles



Note

Role assignments in Security Copilot are not permanent and can be updated to reflect changes in responsibilities or



organizational needs.

Once all the required information has been provided, the setup process is then complete. You can begin using Security Copilot immediately.

With Copilot ready for you to explore, the next section will provide you with a detailed look at its user interfaces to help you navigate them more effectively.

Navigating the user interfaces

The user interfaces in Security Copilot's embedded experience and standalone environment differ significantly in their design and functionality. In the embedded experience, Copilot's user interface is integrated within the specific security solution, providing a streamlined and compact view that aligns with the host environment's layout. This integration often limits customization options and restricts access to only the Security Copilot's core functionalities necessary for the embedded context.

In contrast, the standalone experience of Security Copilot provides a dedicated environment that operates independently. It is not influenced or limited by the design or functionality of an external application. This independent interface allows for greater customization options. It lets you access a broader range of advanced features and functionalities that go beyond those available in the embedded experience. This flexibility enables a more tailored user experience, with a layout that supports a comprehensive view of features and facilitates more adaptable workflows.

The embedded experience - key aspects explained

The previous chapter focused on Security Copilot's embedded experience, providing a detailed walkthrough of its features and capabilities within various Microsoft security solutions. In the process, you have likely become familiar with many of the user interfaces of the embedded experience.

Rather than revisiting them in detail, this section will focus on their key aspects to help you retain and review the important points. This will help you navigate and utilize these user interfaces more effectively for optimal performance.

For instance, within the embedded experience, you will often notice the Copilot icon appearing within certain features of that solution. This icon signifies that Security Copilot is ready to offer assistance and insights.

As illustrated in the next screenshot, the Copilot icon indicates that Security Copilot is embedded in the **Microsoft Entra ID Protection** solution. It provides the **Summarize** option, which offers a summary of the risky user details for a potentially compromised user account:

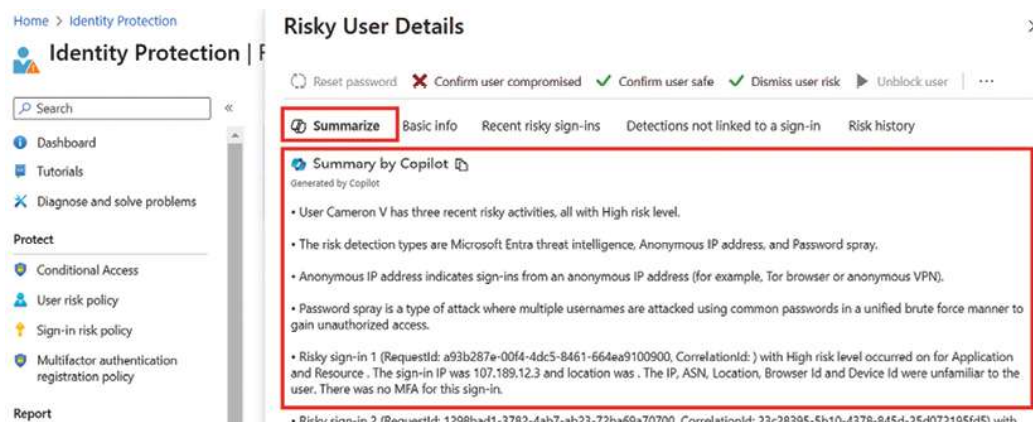


Figure 3.7 – Security Copilot embedded experience



 **Quick tip:** Need to see a high-resolution version of this image? Open this book in the next-gen Packt Reader or view it in the PDF/ePub copy.

 **The next-gen Packt Reader** and a **free PDF/ePub copy** of this book are included with your purchase. Scan the QR code OR visit packtpub.com/unlock, then use the search bar to find this book by name. Double-check the edition shown to make sure you get the right one.



In some instances, such as with the Security Copilot's incident summary feature in **Microsoft Defender XDR**, Security Copilot can be automatically activated. More often, however, you'll need to manually click the Copilot icon to initiate its function. The next screenshot demonstrates this manual process: when you click the Copilot icon next to a security setting, the **Copilot** pane on the right side will display a prompt such as, **Tell me about Intune setting 'Allow Realtime Monitoring'**. Security Copilot then retrieves the relevant documents for that specific setting:

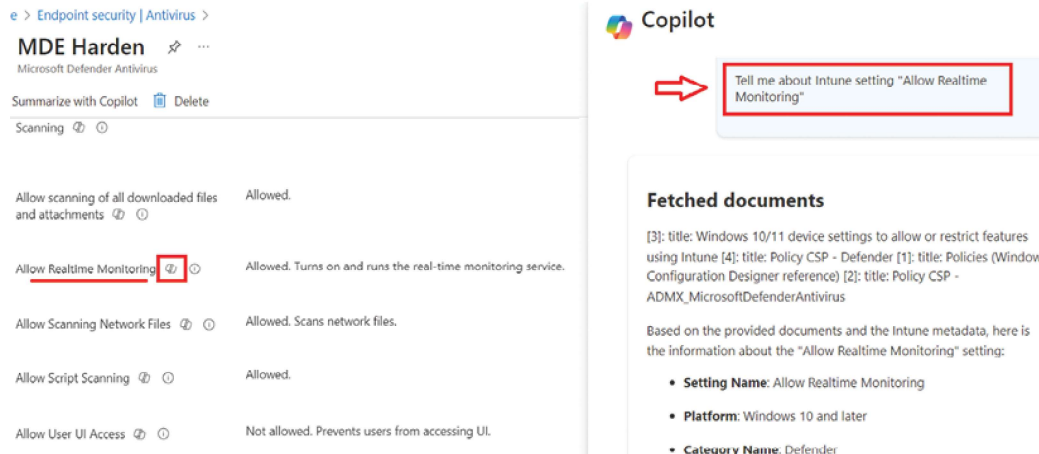


Figure 3.8 – Manually starting Security Copilot by clicking its icon next to a security setting

Sometimes, Security Copilot not only delivers the requested information but also follows up with additional recommended prompts that you can use to interact further with Copilot, such as the annotated prompts shown in the next screenshot:

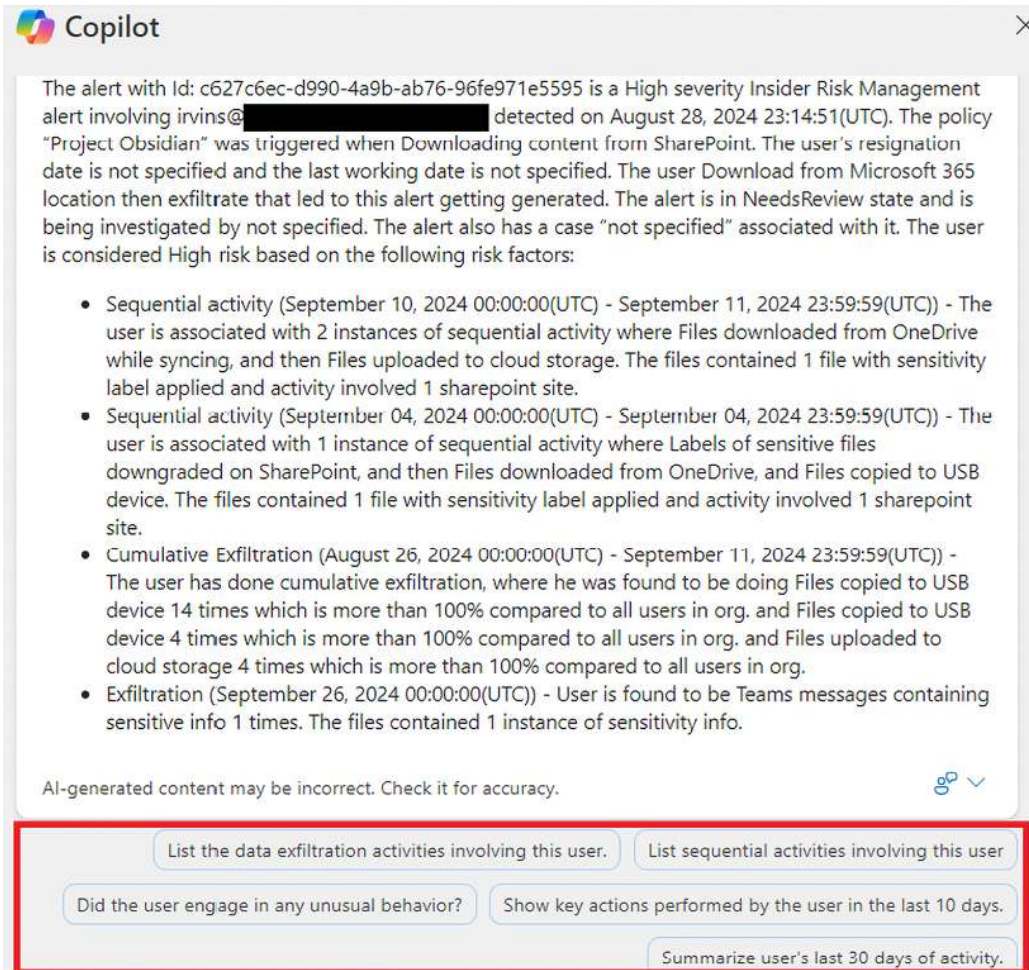


Figure 3.9 – Additional recommended prompts from Security Copilot

In certain cases, you are also able to interact directly within the **Copilot** pane, as seen in the next screenshot:

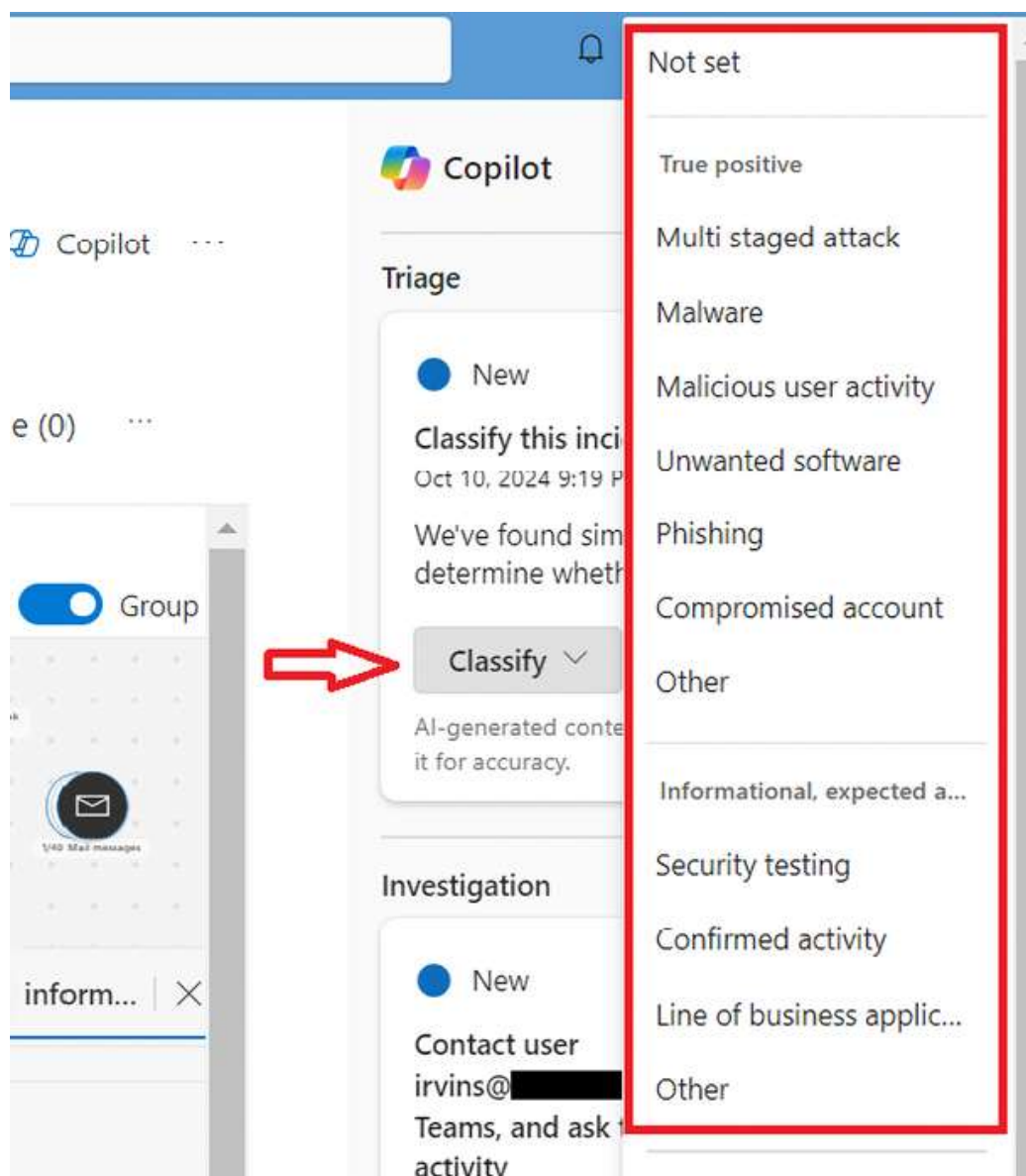


Figure 3.10 – Interacting with Security Copilot

You might have noticed that there is usually an ellipsis right inside the **Copilot** pane. As illustrated in the next screenshot, clicking on the ellipsis reveals additional options, such as the ability to copy Copilot's response for further review. You can also request Copilot to regenerate its response if needed:

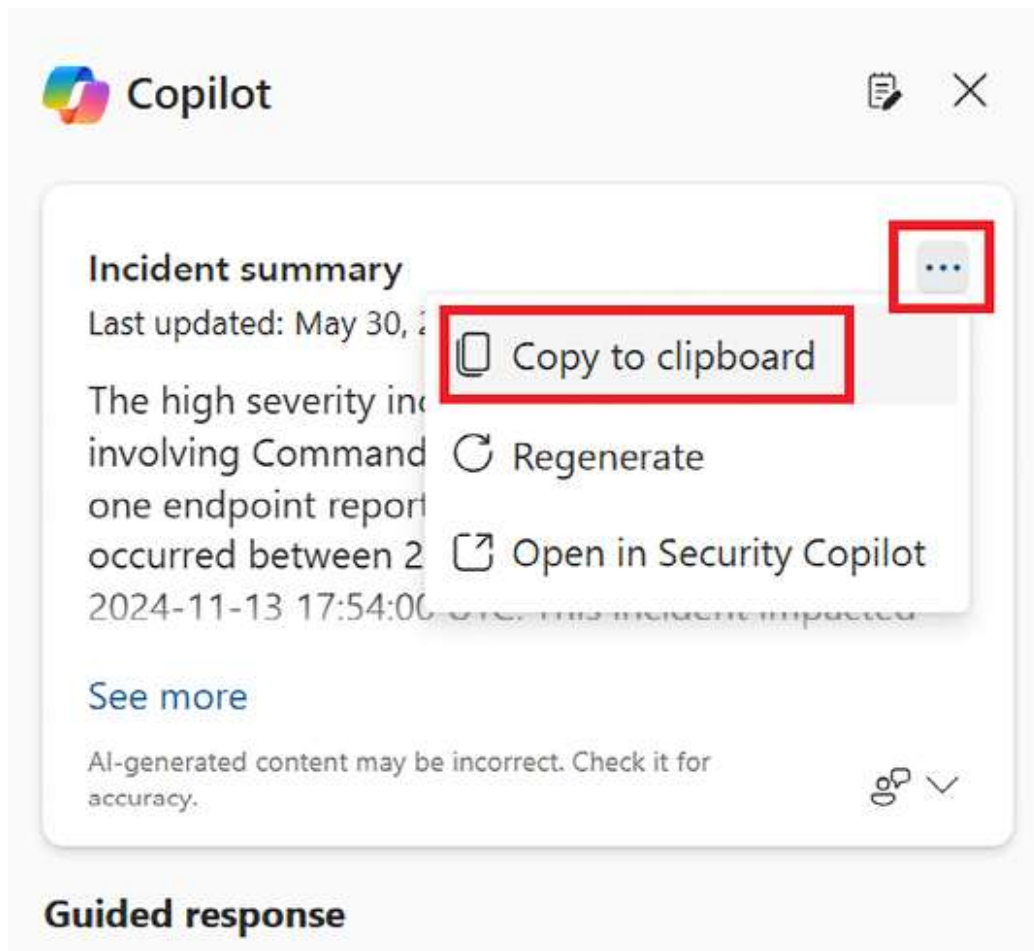


Figure 3.11 – Security Copilot ellipsis

You can effortlessly transition from Security Copilot’s embedded experience to its standalone environment by choosing **Open in Security Copilot**, as illustrated in the next screenshot:

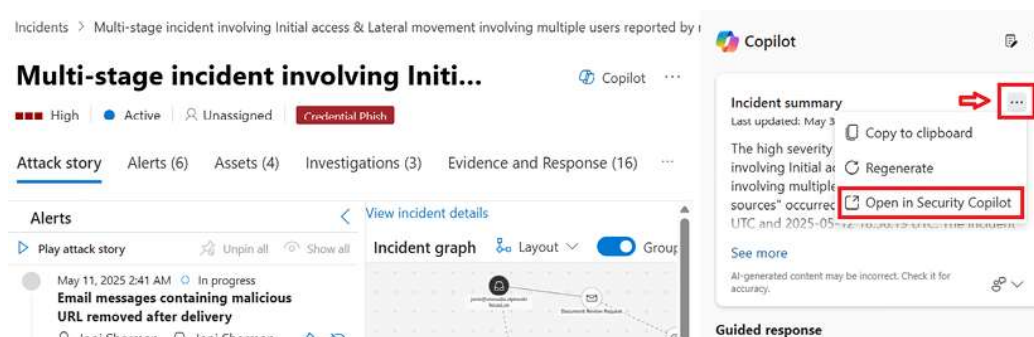


Figure 3.12 – Pivoting from Copilot’s embedded experience to its standalone mode



Note

In the embedded experience for Security Copilot, its user interfaces are designed to be simple and straightforward. Customization options are typically limited, as the interface is intended to integrate seamlessly with the host application. This design ensures that the **Copilot** interface is consistent with the host environment, making key Security Copilot functionalities easily accessible without extensive personalization. While this approach prioritizes a seamless user experience and focuses on essential features, it offers fewer opportunities for modification compared to the standalone experience.

The standalone experience

The design and layout in Security Copilot's standalone environment are quite different from the embedded experience. In the standalone mode, its interface is more customizable, allowing for a tailored and flexible experience, with options to adjust the layout to better meet individual needs. This setup allows a dedicated space for the user to fully explore and leverage Copilot's advanced features.

When you sign in to the standalone environment of Security Copilot at <https://securitycopilot.microsoft.com/>, the home screen, shown in the next screenshot, presents a list of prompts or promptbooks for you to explore:

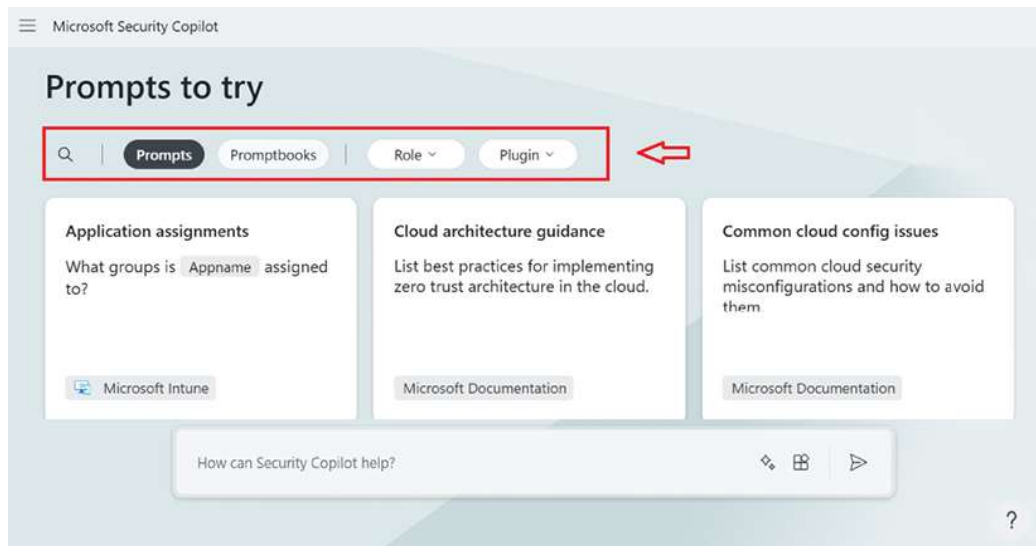


Figure 3.13 – Security Copilot standalone experience home screen

You can further narrow down the prompts or promptbooks by filtering them according to the plugin involved and/or the analyst's role. The next screenshot illustrates how the recommended prompts are filtered using two selected plugins, **Incident Analysis** and **Microsoft Defender XDR**:

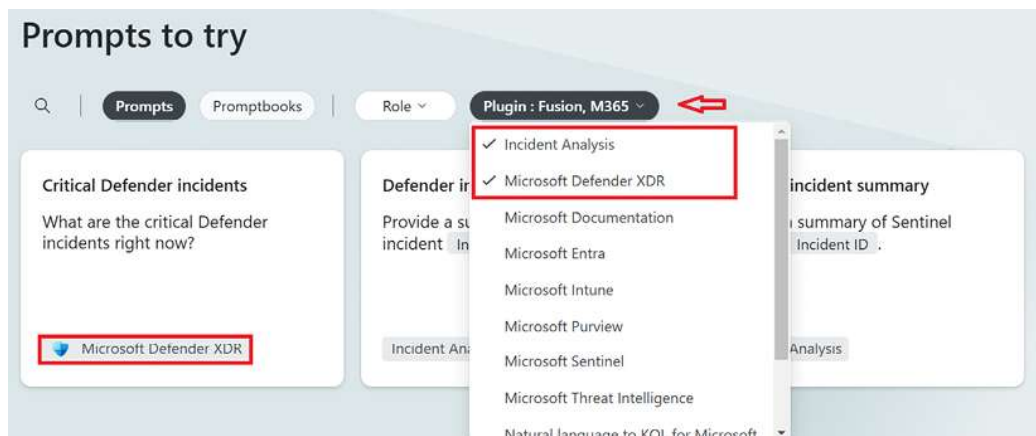


Figure 3.14 – Prompts filtered by selected plugins

In addition, the following screenshot shows that a specific promptbook named **Microsoft User Analysis** appears on the home screen when the **Identity Administrator** role is selected:

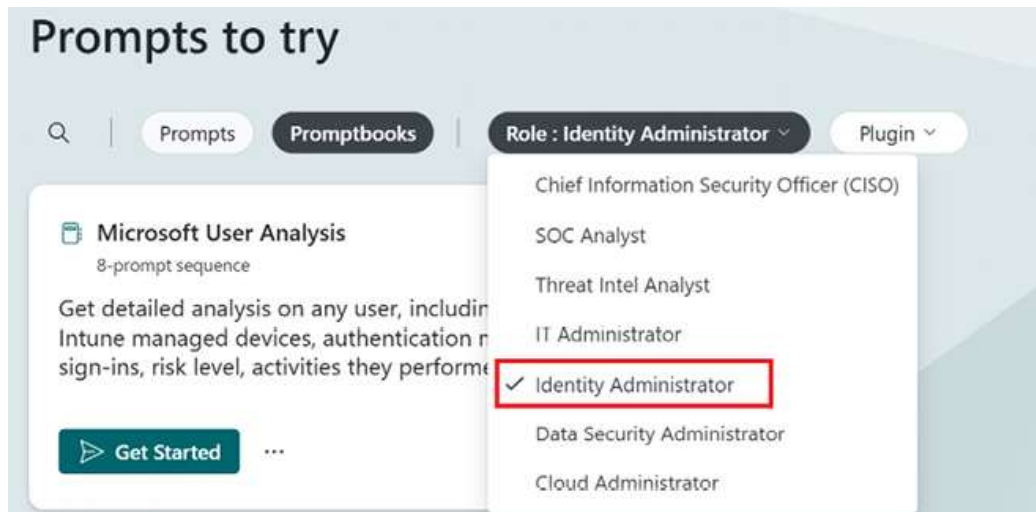


Figure 3.15 – Narrowing down promptbooks by the analyst's role

On the home screen, let's explore three main menu options:

1. Home menu
2. Prompt bar
3. Additional resources (represented by a question mark icon)

They are outlined and can be seen in the next screenshot:

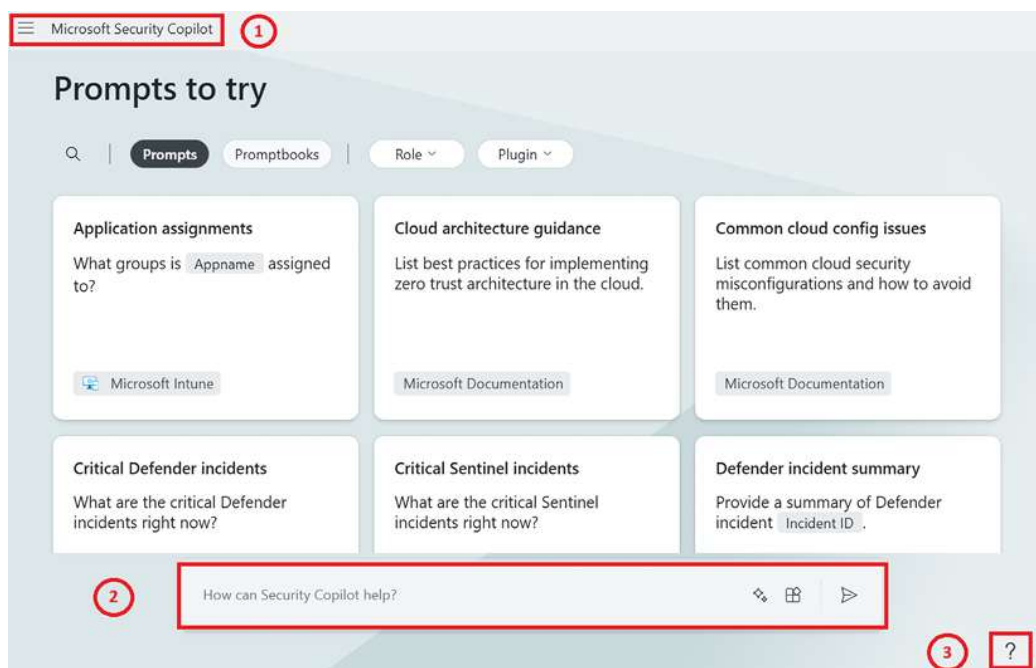


Figure 3.16 – Main menu options on the home screen

The home menu is located in the upper-left corner of the home screen. It provides access to the main features and settings of Security Copilot. This is illustrated in the next screen capture:

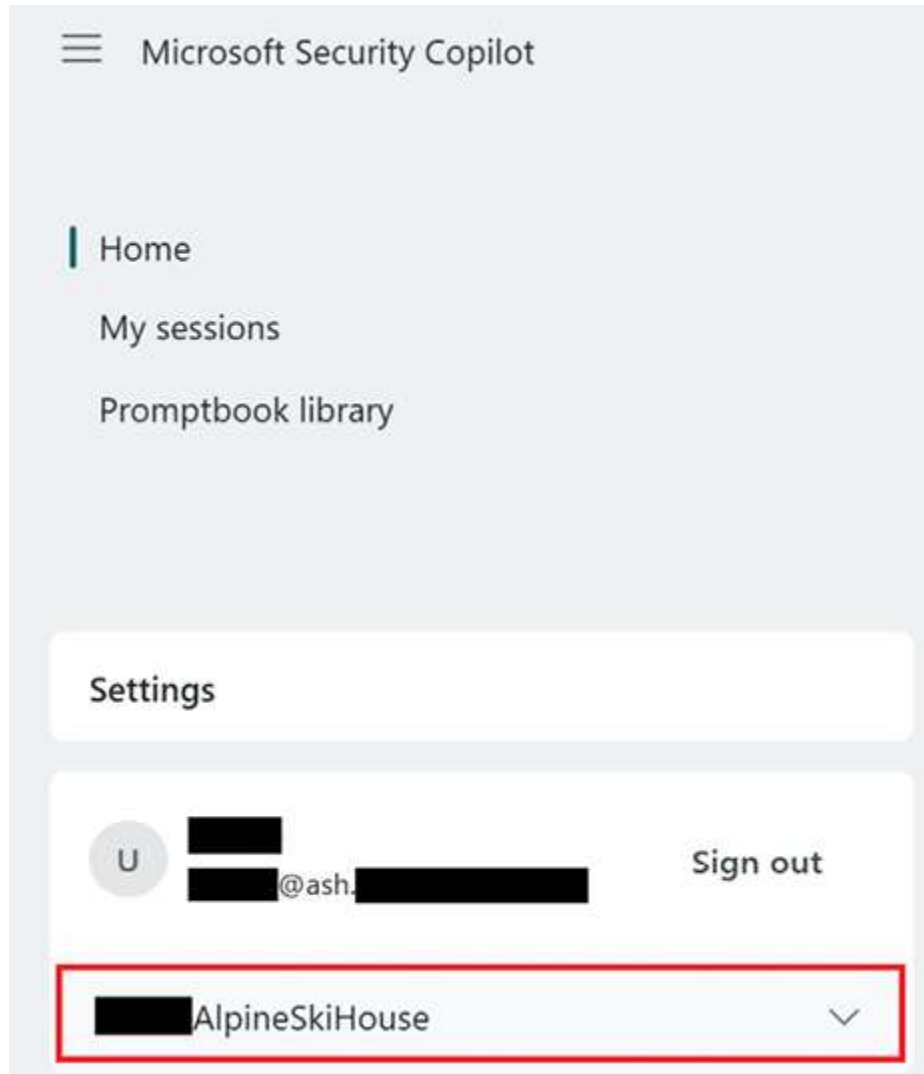


Figure 3.17 – The home menu

The configuration settings available in the home menu are as follows:

- **Home** takes you back to the main home screen page, where you can start drafting a new prompt.

- **My sessions** displays a list of your past Security Copilot sessions, including those from embedded experiences. In there, you can manage your sessions using search and filter options, as well as rename or delete sessions as needed.
- **Promptbook library** lists your own promptbooks, those shared within your organization, and Microsoft promptbooks. Within this section, you can search for specific promptbooks, duplicate existing ones, and share promptbooks as needed. We will explore promptbooks and the promptbook library in greater detail in [Chapter 6](#).
- **Settings** include three categories: **Preferences**, **Data and Privacy**, and **About**. The **Preferences** section allows you to configure configurations such as choosing a theme (light, dark, or high contrast) for your Copilot user interface and setting your time zone and language preferences.
- At the bottom of the home menu is the current tenant (outlined in the previous screenshot). You can switch the tenant to access security data in a different tenant. This feature allows authorized external or guest accounts to conduct sessions using your tenant data.

The prompt bar is located at the bottom of the home screen. You can use it to enter prompts to direct Copilot to perform tasks. The prompt bar also features two additional menu icons: **Prompts** and **Sources**. The next screenshot shows the **Prompts** icon:



Figure 3.18 – The Prompts icon

The **Sources** icon is shown in the following screenshot:



Figure 3.19 – The Sources icon

The **Prompts** option helps you to get started by offering a selection of promptbooks. These promptbooks provide structured guidance and examples to assist you in creating and using prompts effectively within Security Copilot. Additionally, clicking on the **Prompts** option leads to the **SYSTEM CAPABILITIES** function. This is illustrated next:

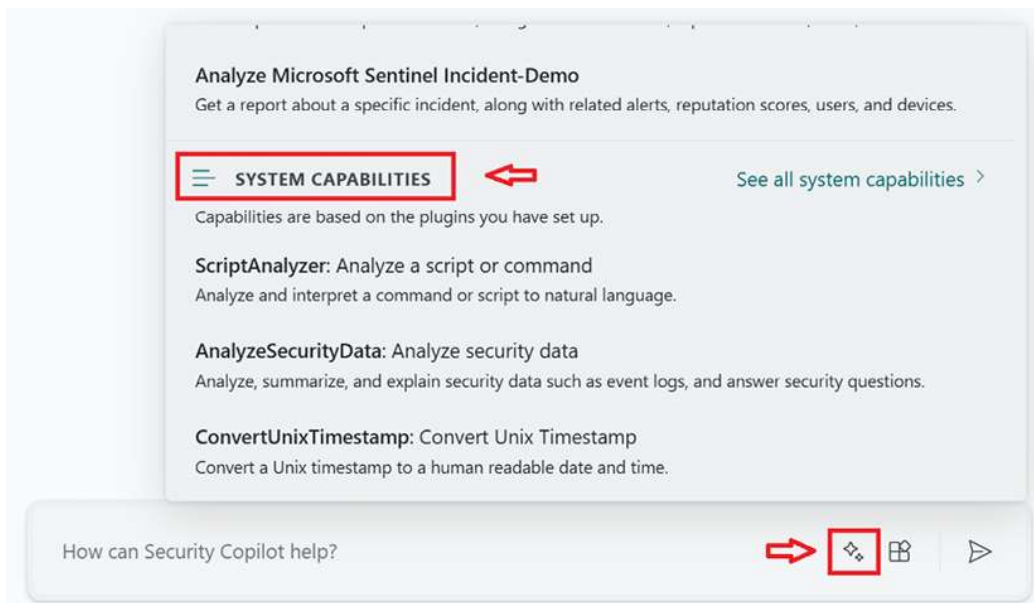


Figure 3.20 – The SYSTEM CAPABILITIES function in the standalone experience

Whenever a new tool is introduced, there's often curiosity about its capabilities and the value it can provide. With the embedded experience of Security Copilot, its functions are clearly displayed and presented to you through the user interfaces. In the standalone experience, you're tapping

into its vast amount of knowledge and information to gain insights and support. But exactly what does Security Copilot know? What questions can you ask Copilot through its standalone experience?

This is where the **SYSTEM CAPABILITIES** function becomes your guide for getting acquainted with Security Copilot. It showcases the knowledge and information Copilot possesses, highlights the features Copilot offers, and provides a detailed overview of what Copilot can accomplish with each plugin. It can serve as your starter guide to understanding the full extent of Security Copilot's capabilities, particularly those not covered in the embedded experiences.

The screenshot of the **SYSTEM CAPABILITIES** function, as shown next, highlights some of Copilot's capabilities, especially those not featured in the embedded experience:

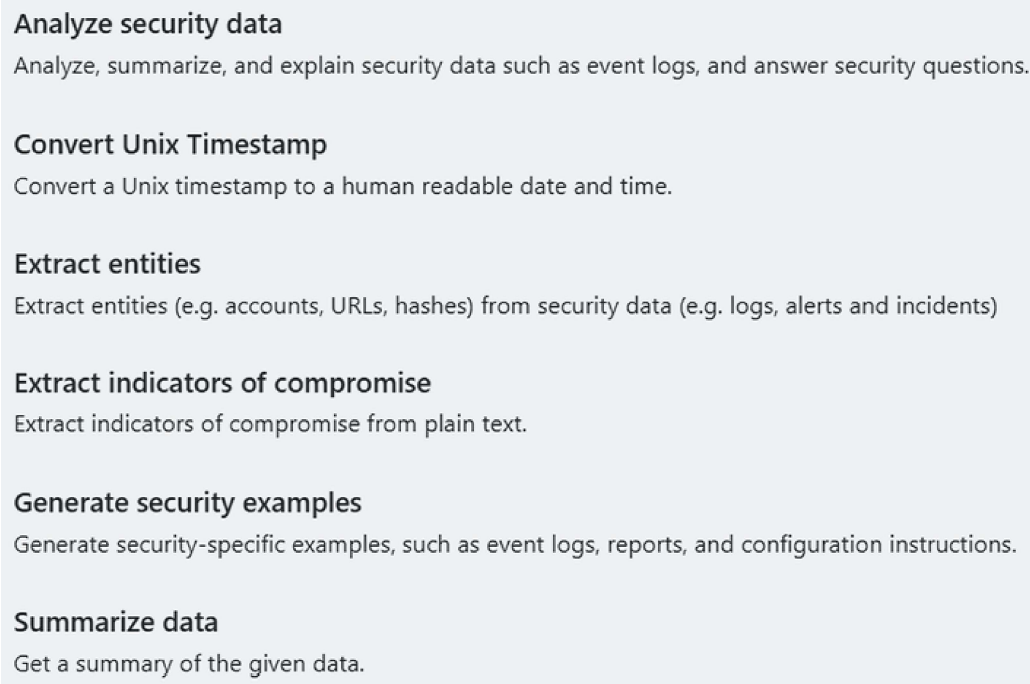
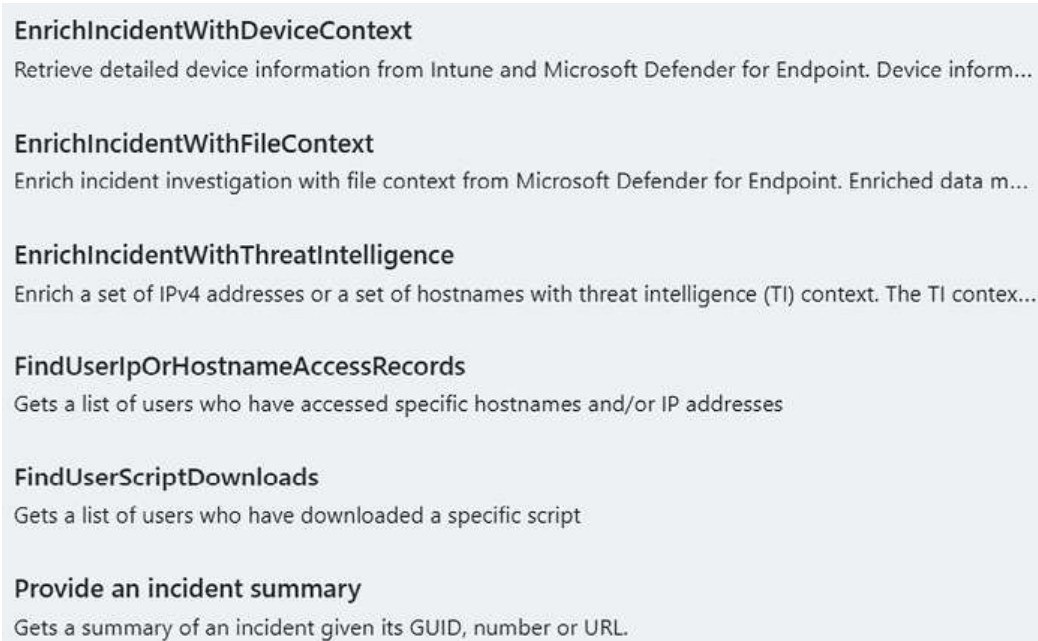


Figure 3.21 – Some system capability examples

The next screen capture displays some additional functions mentioned in **SYSTEM CAPABILITIES**:

A screenshot of a list of system capabilities. The list is presented in a light blue background with white text. Each item consists of a bolded title followed by a brief description.

EnrichIncidentWithDeviceContext	Retrieve detailed device information from Intune and Microsoft Defender for Endpoint. Device inform...
EnrichIncidentWithFileContext	Enrich incident investigation with file context from Microsoft Defender for Endpoint. Enriched data m...
EnrichIncidentWithThreatIntelligence	Enrich a set of IPv4 addresses or a set of hostnames with threat intelligence (TI) context. The TI contex...
FindUserIpOrHostnameAccessRecords	Gets a list of users who have accessed specific hostnames and/or IP addresses
FindUserScriptDownloads	Gets a list of users who have downloaded a specific script
Provide an incident summary	Gets a summary of an incident given its GUID, number or URL.

Figure 3.22 – Additional system capability examples

As mentioned earlier, the prompt bar also includes a menu option called **Sources**. As illustrated in the next screenshot, this menu option lets you manage different plugins:

Manage sources

Plugins
Files

Manage plugins

Turn on or create your own plugins to give Copilot access to the security services and websites you use. [Learn more](#)



All (39)

On (10)

Off (29)

Microsoft ⓘ



Azure Firewall **Preview**



Intrusion Detection and Prevention System (IDPS) signature analysis and fleet-wide IDPS attack investigation



Azure Web Application Firewall **Preview**



SQL injection block summaries, XSS block summaries, top WAF rules summaries and top malicious IP summaries



Microsoft Defender External Attack Surface Management



Attack surfaces, vulnerable assets, and attack surface insights

Show 9 more ▾

Figure 3.23 – Manage plugins in Security Copilot

Here, you can activate your own plugins as well. This is illustrated next:

Manage sources

Plugins
Files

Websites ⓘ



Public web

Content downloads



Custom ⓘ



Custom Plugin Defender Device Info **Private**

Device information, including OS, IPs, users, and more, powered by Defender XDR, developed by Bi Yue Xu.



Custom Plugin Defender Device Investigation **Private**

Incident Response playbook for suspicious Windows device, powered by Defender XDR, developed by Bi Yue Xu.



Custom Plugin Defender XDR Hunting **Private**

Hunting in Defender XDR, developed by Bi Yue Xu.



Figure 3.24 – Public web and custom plugin

From the previous screenshot, you may have seen a **Public web** plugin, located just above the **Custom** plugin section. It is a special plugin designed to integrate information from the public web. Security Copilot can be configured to access and retrieve information from publicly available sources on the internet. This capability enables Copilot to access up-to-date information and deliver insights and recommendations based on the latest emerging threats or vulnerabilities. This results in more informed advice and support for your security strategies and decisions.

In addition to managing plugins, the **Manage sources** menu provides the **Files** option to let you upload your own internal files to add organizational knowledge for Security Copilot, as shown in the next screenshot:

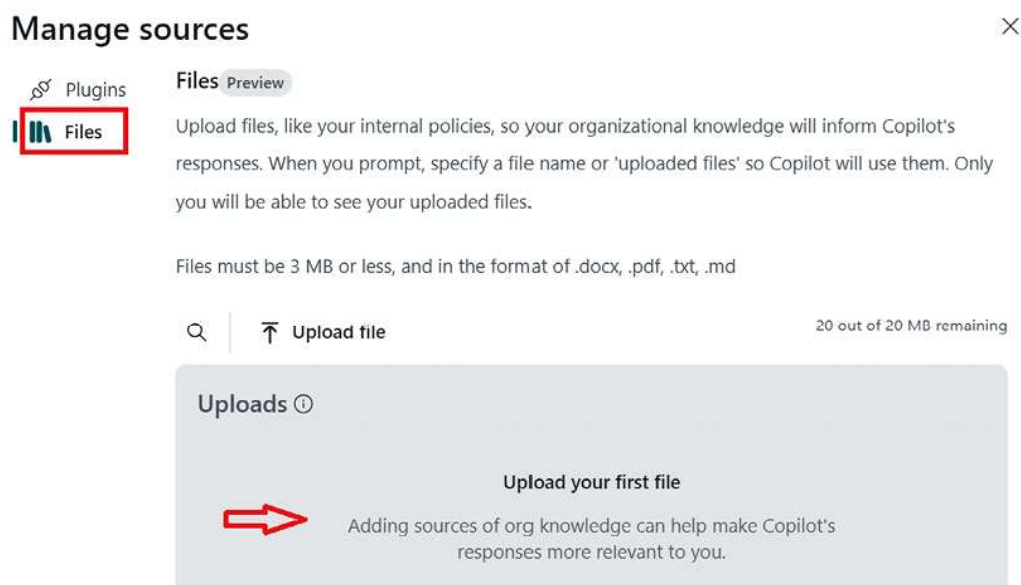


Figure 3.25 – The Files option in the Sources menu option

By uploading and incorporating these files into Security Copilot, you enable it to use your proprietary information to enhance Copilot's response and support. This integration allows Security Copilot to deliver advice and

actions that are more relevant and contextually informed based on the specific content of your organization. For instance, if Copilot has access to your internal guidelines or recent vulnerability reports, it can use this information to offer more accurate and tailored recommendations, enhancing its ability to address your organization's unique needs and challenges.

Lastly, we have the *additional resources* menu option in the lower-right corner of the home screen, indicated by a question mark icon. This menu offers access to a range of supporting materials for Security Copilot, including documentation, training videos, and additional support resources. This is shown in the next screenshot:

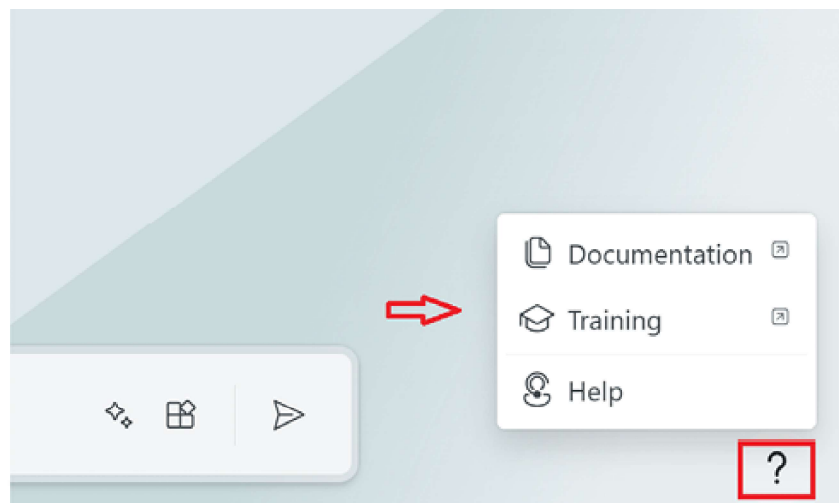


Figure 3.26 – The additional resources menu option

The **Documentation** function leads you to the official Microsoft resources for Security Copilot. The **Training** function leverages videos and visual tutorials to guide you in learning about and using Security Copilot effectively. The **Help** function offers the self-help widget to provide articles related to your query and allows you to submit a support case. The *additional resources* menu option, outlined in red and shown as a question

mark icon in the previous screenshot, is designed to help you maximize your use of Security Copilot by providing essential resources and support.

Now that you're getting familiar with both the embedded experience and the standalone mode and have reviewed their user interfaces for more efficient navigation, in the next section, let's use a case study to illustrate how Security Copilot can support you throughout the security incident investigation.

Case study - harnessing Security Copilot in defending against cyber threats

In a typical **Security Operations Center (SOC)** environment, Tier 1 analysts are responsible for monitoring and reviewing incoming security incidents. They're in charge of the initial triage and basic investigations, including the identification of false positives. When a critical incident is detected, the Tier 1 analyst must quickly escalate it to the Tier 2 team for a more thorough investigation. In this case study, you will take on the role of a Tier 1 analyst and discover how Copilot can support you throughout the incident investigation. Many features of Security Copilot are designed to enable you to assess and manage incidents with greater efficiency and effectiveness.

Let's use a security incident in the Microsoft Defender XDR portal for our case study. As shown in the next screen capture, this high-severity incident involves three devices, four user accounts, and one email inbox. It consists of a correlation of 25 alerts generated by different Microsoft security solutions. This incident, titled **Multi-stage incident involving Initial**

access & Lateral movement on multiple endpoints reported by multiple sources, appears complex, extensive, and intimidating:

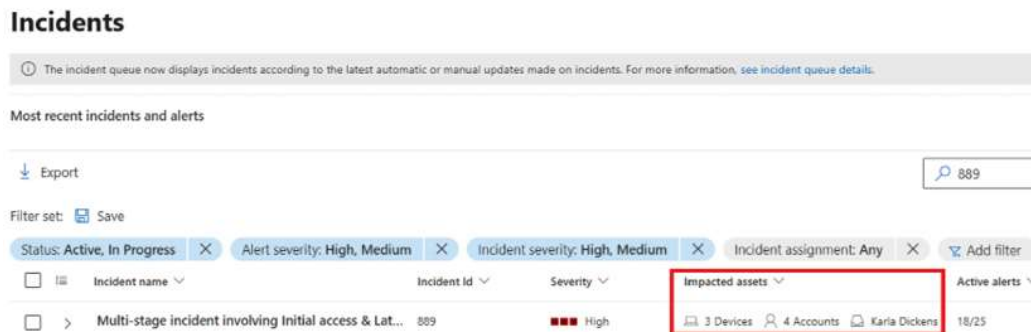


Figure 3.27 – The security incident in the case study

As soon as you start examining this incident in the Microsoft Defender XDR portal, Security Copilot is already present on the incident page, as shown in the next diagram. It automatically generates a summary of the incident, providing a clear overview of the attack.

Additionally, it offers tailored guidance for responding to the incident through its **Guided response** feature, which is also accessible on the incident page:



Figure 3.28 – Incident summary and guided response provided by Copilot

Rather than sifting through all 25 alerts in the incident to understand the attack, let's review the summary provided by Security Copilot first. You can copy the **Incident summary** information for further review using Copilot's **Copy to clipboard** option. This feature is illustrated in the next screenshot:

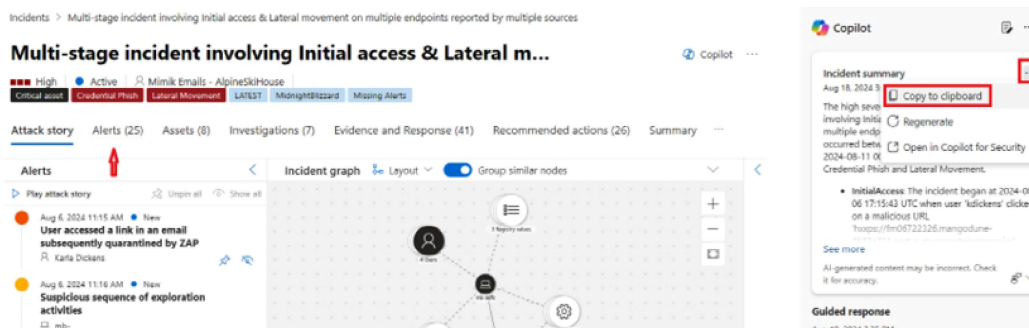


Figure 3.29 – The Copy to clipboard option

For your reference, here is the full **Incident summary** information copied from Security Copilot:

The high severity incident 'Multi-stage incident involving Initial access & Lateral movement on multiple endpoints reported by multiple sources' occurred between 2024-08-06 17:15:43 UTC and 2024-08-11 00:01:42 UTC. It was tagged as Credential Phish and Lateral Movement.

- **InitialAccess:** The incident began at 2024-08-06 17:15:43 UTC when user 'kdickens' clicked on a malicious URL 'hxxps://fm06722326.mangodune-7572a721.eastus.azurecontainerapps.io/'.
- **Discovery:** At 2024-08-06 17:16:17 UTC, a suspicious sequence of exploration activities was detected on 'mb-winclient' (Windows 10), involving the processes 'whoami.exe', 'powershell.exe' (running as SYSTEM), and impacting users 'pgustavo' and 'kdickens'.

- **DefenseEvasion:** At 2024-08-06 17:16:20 UTC, a process was injected with potentially malicious code on 'mb-winclient' (Windows 10), involving the files 'ContosoADFSadmincreds.ps1', 'Midnight161.ps1', and impacting users 'pgustavo' and 'kdickens'.
- **Execution:** At 2024-08-06 17:16:20 UTC, a malicious PowerShell Cmdlet was invoked on 'mb-winclient' (Windows 10), involving the files 'ContosoADFSadmincreds.ps1', 'Midnight161.ps1', and impacting users 'pgustavo' and 'kdickens'.
- **CredentialAccess:** At 2024-08-06 17:17:07 UTC, a suspected DCSync attack (replication of directory services) was detected on 'mb-winclient' (Windows 10), impacting user 'pgustavo'.
- **LateralMovement:** At 2024-08-06 17:17:09 UTC, an ongoing hands-on-keyboard attack via Impacket toolkit was detected on 'mb-adfs' (Windows Server 2022), involving the processes 'lsass.exe' (running as SYSTEM), 'powershell.exe' (running as SYSTEM), and impacting users 'LocalSystem' and 'adfsadmin'.
- **Persistence:** At 2024-08-06 17:17:10 UTC, suspicious service creation was detected on 'mb-adfs' (Windows Server 2022), involving the process 'services.exe' (running as SYSTEM), and impacting user 'adfsadmin'.
- **CredentialAccess:** At 2024-08-06 17:18:20 UTC, an ADFS private key extraction attempt was detected on 'mb-adfs' (Windows Server 2022), impacting user 'adfsadmin'.
- **DefenseEvasion:** At 2024-08-11 00:01:42 UTC, an attempt to hide the use of a dual-purpose tool was detected on 'mb-adfs' (Windows Server 2022), involving the file 'jyglecpm.1v0.exe', and impacting user 'adfsadmin'.

As seen from the incident summary, Security Copilot provides an overview of the incident that helps you quickly understand the scope and impact of the attack. It groups the suspicious events into distinct attack stages, outlining the attack's progression from initial access to lateral movement and persistent access. Each stage is detailed with specific timestamps and a concise summary of the events. In a typical investigation, the Tier 1 analyst would need to create a similar incident outline manually. With Copilot, this process is now automated and much faster.

After reviewing the incident summary, it's clear that this is a highly involved incident with multiple sophisticated attacks. As a Tier 1 analyst, your goal is to quickly assess the attacks, rule out the false positives, determine the incident impact, and decide whether it needs to be escalated to the Tier 2 team. Let's dive into some of the incident investigation and see how Security Copilot can assist throughout the process.

Initial access, discovery, and defense evasion

The *initial access* occurs when the attacker gains entry into the target system or network. In this case, the attacker employs a common attack tactic by tricking the user to click on a malicious link, to establish the initial foothold within the user's corporate network. For your reference, the initial access point, as outlined in the Security Copilot incident summary, is provided next:

InitialAccess: The incident began at 2024-08-06 17:15:43 UTC when user 'kdickens' clicked on a malicious URL

```
'hxxps://fm06722326.mangodune-  
7572a721.eastus.azurecontainerapps.io/'
```

Once the attackers gain access to the corporate network, they need to gather information about the environment – for instance, running the `whoami.exe` Windows process to gather details about the current user's identity and environment. Executing `whoami/groups` shows the groups to which the current user belongs, revealing the user's access level and permissions within the system. This process is documented during the **Discovery** phase in the Security Copilot incident summary, as shown next:

Discovery: At 2024-08-06 17:16:17 UTC, a suspicious sequence of exploration activities was detected on 'mb-winclient' (Windows 10), involving the processes 'whoami.exe', 'powershell.exe' (running as SYSTEM), and impacting users 'pgustavo' and 'kdickens'.

So far, the attack techniques encountered are standard and frequently observed. For a Tier 1 analyst, these techniques are familiar and well-known, making the investigation relatively simple.

However, starting from the *defense evasion* phase, as documented in the Security Copilot incident summary, things may get a bit tricky. You see a process injection event in the alert:

DefenseEvasion: At 2024-08-06 17:16:20 UTC, a process was injected with potentially malicious code on 'mb-winclient' (Windows 10), involving the files 'ContosoADFSadmincreds.ps1', 'Midnight161.ps1', and impacting users 'pgustavo' and 'kdickens'.

What might a **process was injected with potentially malicious code** indicate? What's a process injection? Let's consult with Security Copilot. You can switch from its embedded experience to Copilot's standalone mode. This allows you to ask Security Copilot various questions using its prompt feature.

Upon switching to Security Copilot's standalone environment, you are directed to the Copilot session where the incident summary is already present. In this session, you can generate additional follow-up prompts.

This is illustrated in the next screenshot, with the prompt outlined:



Figure 3.30 – Consulting with Copilot via its prompt feature

The response from Copilot provides an overview of process injection and its characteristics, as displayed in the next screen capture:

Can you tell me more about DefenseEvasion: a process was injected with potentially malicious code on 'mb-winclient' (Windows10), involving the files 'ContosoADFSadmincreds.ps1', 'Midnight161.ps1'

>  3 steps completed 55 seconds

Aug 18, 2024

The Defense Evasion event you're asking about occurred at 2024-08-06 17:16:20 UTC on the machine 'mb-winclient' running Windows 10. The event involved the files 'ContosoADFSadmincreds.ps1' and 'Midnight161.ps1', which are likely PowerShell scripts. PowerShell scripts are often used by attackers due to their flexibility and power. The users 'pgustavo' and 'kdickens' were impacted by this event, which could mean that their accounts were used to perform the action, or that their data or operations were affected by it.

The term "process injection" typically refers to a technique used by attackers to execute arbitrary code in the address space of a separate live process. This technique improves the stealth and evasion capabilities of malware since the execution of the malicious code does not result in the creation of a new process, making it harder to detect.

Unfortunately, the log does not provide specific details about this event. To get more details, you would need to examine the logs of the affected system, particularly the PowerShell logs if they are available. You could also look at the contents of the 'ContosoADFSadmincreds.ps1' and 'Midnight161.ps1' files if they are still present on the system.

Figure 3.31 – Response from Security Copilot

The process injection overview may still be somewhat abstract. You can follow up with Copilot for a more detailed description using the prompt seen in the next screen capture:

Can you describe in detail about the technique used by attackers to execute arbitrary code in the address space of a separate live process.

Figure 3.32 – Asking Copilot with a follow-up prompt

With the response from Copilot, you have a better understanding of process injection. The next screenshot presents a portion of the response from Security Copilot:

2. **Crafting the Payload:** The attacker then crafts a payload, which is the piece of code they want the system to execute. This could be anything from code that creates a backdoor in the system, to code that simply crashes the system.
3. **Injection:** The attacker then injects this payload into the system or application. This is often done by inputting the code into an insecure form or data entry point in the application, or by tricking the system into loading a file containing the malicious code.
4. **Execution:** If the attack is successful, the system will then execute the injected code, thinking it is part of the normal program. This allows the attacker to carry out their intended action (e.g., gaining unauthorized access, extracting sensitive data).

Figure 3.33 – More detailed response from Security Copilot

The information from Security Copilot adds more context and insights for this alert, enabling you, the Tier 1 analyst, to start a more thorough investigation immediately.

Back to the Microsoft Defender XDR portal, analysts typically leverage the Defender for Endpoint **Timeline** feature to investigate the event that might have triggered the **a process was injected with potentially malicious code** alert. The next screenshot shows that in the **Timeline** section, Defender recorded a device event, **powershell.exe executed a script**. This event led Defender for Endpoint to immediately detect and report **powershell.exe process contains suspicious patterns in AMSI content related to 'Process Injection' and other techniques**.

This then led to the triggering of the process injection alert:

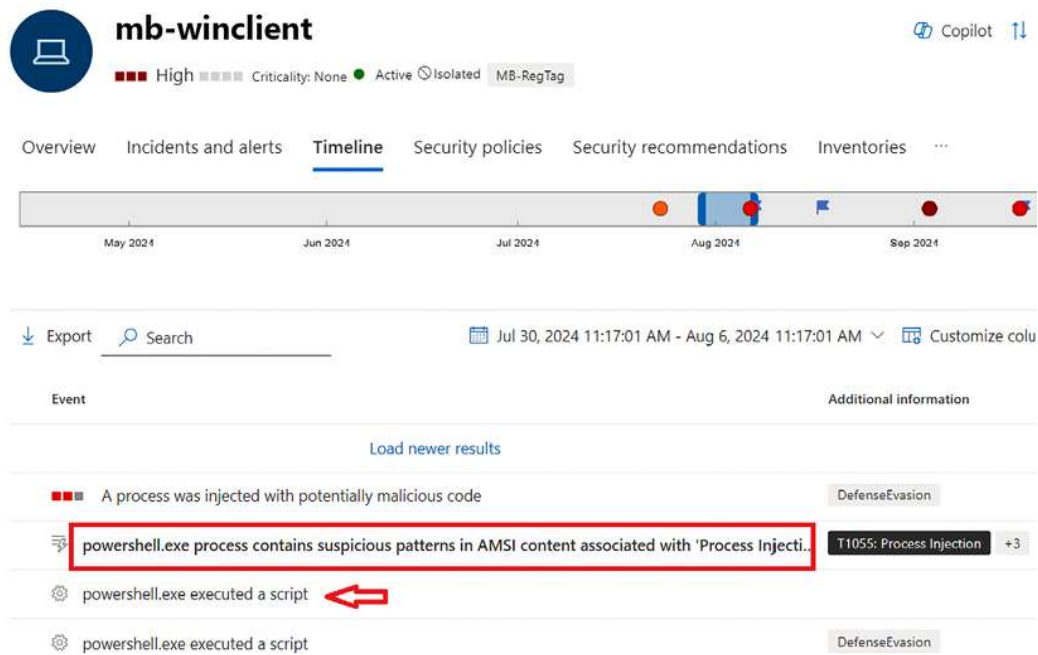


Figure 3.34 – Defender for Endpoint Timeline

Defender also provides the detailed PowerShell process commands that you can ask Security Copilot to analyze, as shown in the next screen capture:

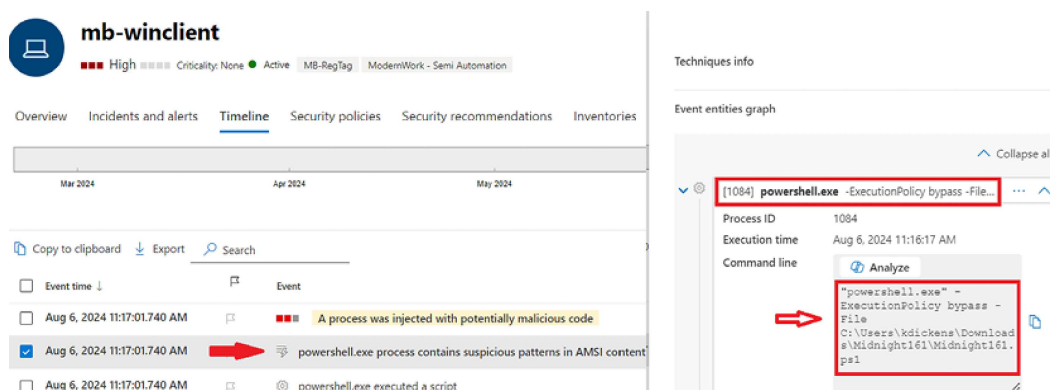


Figure 3.35 – Asking Security Copilot to analyze the PowerShell command line

With Security Copilot's information on process injection, combining the details from the device events, especially that the PowerShell script was executed from the user's downloads directory, it's clear that this is likely a malicious attack rather than a false positive. The use of a more advanced

technique of process injection suggests that this case should be escalated to the Tier 2 team for further investigation.

In Defender's **Timeline** feature, security analysts typically review device events that occurred around the time the security alert was triggered to identify any additional malicious activity. This process is both time-consuming and labor-intensive. Security Copilot can handle the heavy lifting for you. Let's return to Security Copilot's standalone environment and use its prompt feature to accomplish this.

The prompt seen in the next screenshot instructs Security Copilot to use a Defender KQL query to retrieve all device process events from around the time of the process injection activity. It then asks Copilot to analyze these events for any signs of suspicious activity:

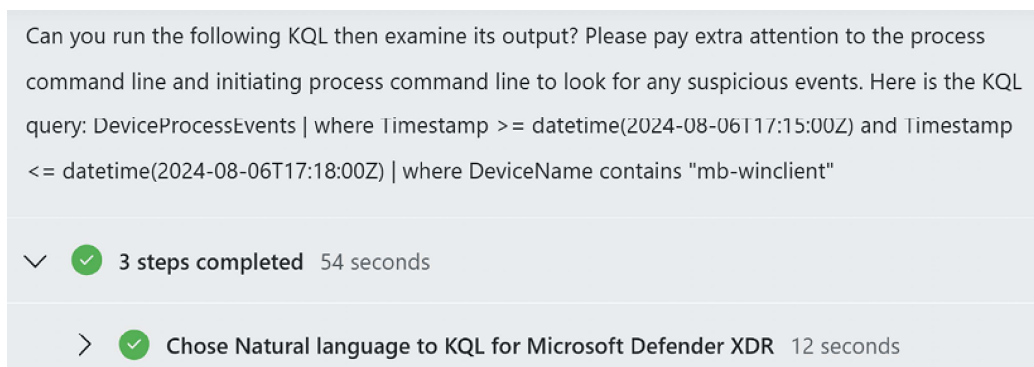


Figure 3.36 – Security Copilot prompt

As shown in the next screen capture, Security Copilot has flagged a few events that are worth investigating further, with one in particular that stands out:

Upon examining the process command line and initiating process command line, several events stand out:

1. At 2024-08-06T17:15:43.2841119Z, Microsoft Edge was launched with a URL that was accessed via a safe link. This could be the initial access point for the attacker.
2. At 2024-08-06T17:16:17.2236813Z, a PowerShell script named 'Midnight161.ps1' was executed. This script could be part of the attacker's toolkit.
3. At 2024-08-06T17:16:29.4285926Z and 2024-08-06T17:16:56.6809837Z, PowerShell was used to start another PowerShell process with elevated privileges (runas verb). This is a common technique used for privilege escalation.
4. At 2024-08-06T17:16:58.7137936Z and 2024-08-06T17:17:01.9498066Z, a script named 'ContosoADFSadmincreds.ps1' was executed. This script could be used to extract credentials.
5. At 2024-08-06T17:17:33.3585749Z and 2024-08-06T17:17:33.2111318Z, the 'csc.exe' (C# compiler) was used to compile code. This could be a sign of the attacker compiling malicious code on the fly.

These events suggest that the attacker used PowerShell scripts and privilege escalation to perform malicious activities on the 'mb-winclient' device.

Figure 3.37 – Response from Security Copilot

The suspicious event highlighted in the previous screenshot may warrant further investigation. You can ask Security Copilot to further investigate it by using the following prompt in Copilot's standalone experience:

Can you run the following KQL then examine its output? Please pay extra attention to the process command line and initiating process command line to look for 'csc.exe' (C# compiler) was used to compile code. Then display the relevant event here. Here is the KQL query: DeviceProcessEvents | where Timestamp >= datetime(2024-08-06T17:15:00Z) and Timestamp <= datetime(2024-08-06T17:18:00Z) | where DeviceName contains "mb-winclient"

Figure 3.38 – Security Copilot prompt

Security Copilot then provides more details on the events related to `csc.exe`, as shown in the next screenshot:

Upon examining the process command line and initiating process command line, several events stand out:

1. At 2024-08-06T17:17:33.3582409Z, 'csc.exe' (C# compiler) was used to compile code. The command line used was "csc.exe" /noconfig /fullpaths
@ "C:\WINDOWS\TEMP\3j555zka\3j555zka.cmdline". This could be a sign of the attacker compiling malicious code on the fly.
2. At 2024-08-06T17:17:33.2107333Z, 'csc.exe' (C# compiler) was used to compile code. The command line used was "csc.exe" /noconfig /fullpaths
@ "C:\WINDOWS\TEMP\anulltrs\anulltrs.cmdline". This could be a sign of the attacker compiling malicious code on the fly.

These events suggest that the attacker used 'csc.exe' (C# compiler) to compile code on the 'mb-winclient' device.

References

Figure 3.39 – Response from Security Copilot

This investigation may take some time to finish. However, as a Tier 1 analyst, you can conclude that this is likely a malicious event involving a sophisticated attack technique. The Tier 2 team will need to carry out a more in-depth investigation. In the meantime, you can move on to the next security alert.

Credential access

The Security Copilot incident summary also identifies a suspected `DCSync` attack as part of `CredentialAccess` activity. The snippet from the incident summary is shown next:

CredentialAccess: At 2024-08-06 17:17:07 UTC, a suspected DCSync attack (replication of directory services) was detected on 'mb-winclient' (Windows 10), impacting user 'pgustavo'.

What is a **DCSync** attack? Rather than spending a lot of time researching it online, you can leverage Security Copilot's standalone experience to quickly get an idea of what it is and how it works. The next screenshot displays the question you can ask Copilot, along with some of its responses:

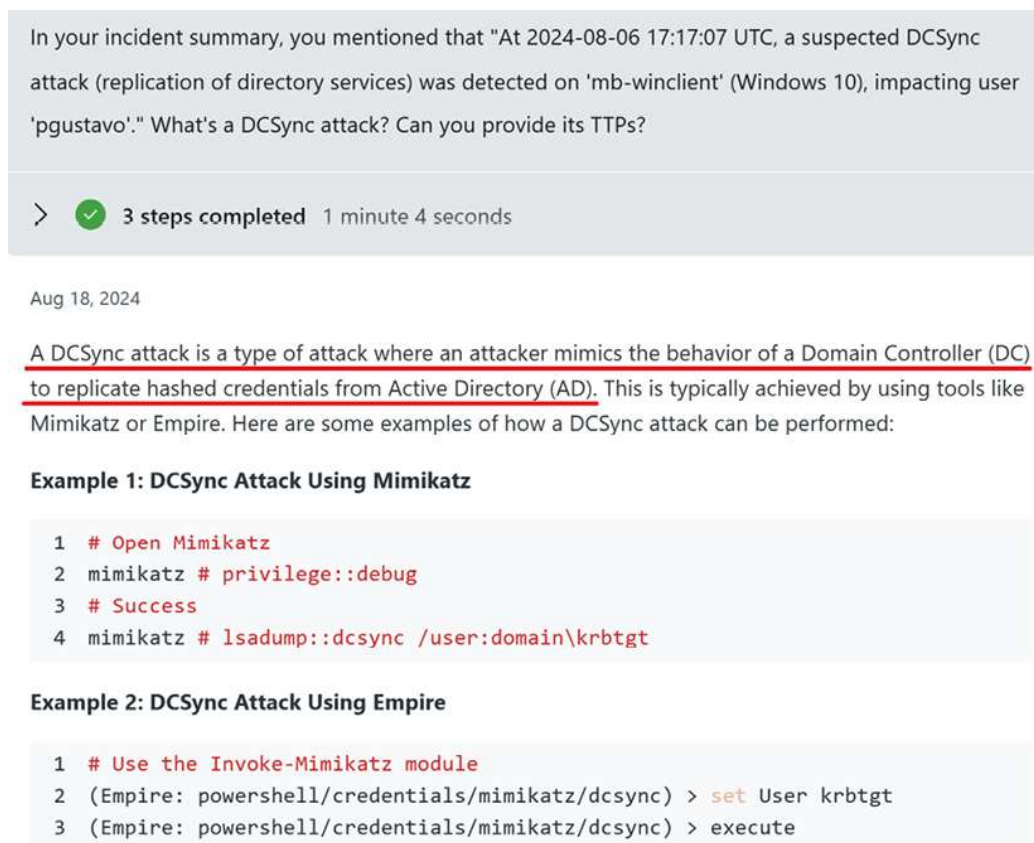


Figure 3.40 – Security Copilot prompt and responses

Security Copilot first provides an overview of the **DCSync** attack with some specific examples. It then walks you through the steps involved in a typical **DCSync** attack, as seen in the next snapshot:

The Tactics, Techniques, and Procedures (TTPs) of a DCSync attack typically involve the following steps:

1. **Initial Access:** The attacker gains access to a system within the network. This could be through spear-phishing, exploiting a vulnerability, or using stolen credentials.
2. **Privilege Escalation:** The attacker escalates their privileges to that of a domain administrator or an account with similar permissions.
3. **Credential Dumping:** The attacker uses tools like Mimikatz or Empire to perform the DCSync attack, which tricks the domain controller into syncing the hashed credentials of the target account.
4. **Lateral Movement:** With the stolen credentials, the attacker can move laterally across the network, accessing other systems and furthering their reach within the network.
5. **Persistence:** The attacker establishes a method of maintaining their access to the network, such as creating a backdoor or scheduling tasks that will re-establish their connection if it is lost.
6. **Exfiltration:** The attacker may exfiltrate data from the network, either for their own use or to sell on the dark web.
7. **Command and Control (C2):** The attacker maintains communication with the compromised systems, often using a C2 server to remotely control the systems and execute commands.
8. **Defense Evasion:** The attacker takes steps to avoid detection, such as disabling security software, clearing logs, or using stealthy malware that can evade traditional antivirus solutions.

These steps provide a general overview of the TTPs associated with a DCSync attack. However, the specific actions and tools used can vary depending on the attacker and the specifics of the network environment.

Figure 3.41 – Steps involved in a typical DCSync attack

After reviewing the information provided by Security Copilot, you should have a better understanding of the key aspects of a **DCSync** attack and how it operates. If there are more questions or if further clarification is needed, you can always use Copilot's prompt feature in its standalone mode to gain additional support.

Once you have a solid understanding of the **DCSync** attack, you can apply this insight to assist the security incident investigation. Back in the Microsoft Defender XDR portal, when you examine the alert story for the **Suspected DCSync attack** alert, you'll likely notice something is off when the end user sends a replication request to a domain controller, as seen in the screen capture:

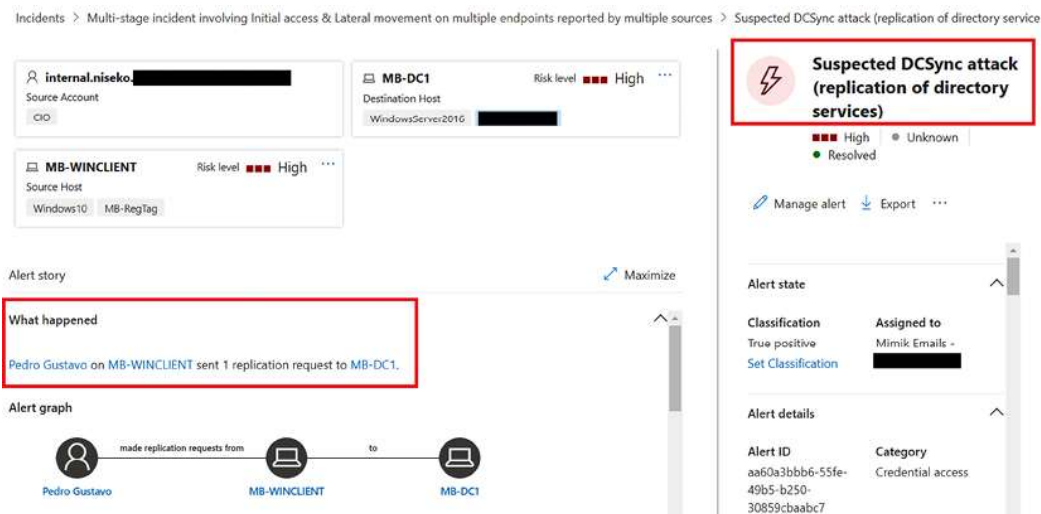
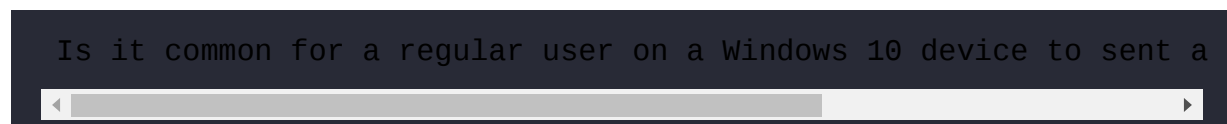


Figure 3.42 – Suspected DCSync attack alert

You can confirm your suspicion with Copilot by entering the following prompt in Copilot's standalone mode:



Note

As seen in the next screen capture, Security Copilot confirms that **“it is not common for a regular user on a Windows 10 device to send a replication request to a Domain Controller (DC). In a typical Active Directory**



environment, only Domain Controllers replicate data amongst themselves.”

Is it common for a regular user on a Windows 10 device to send a replication request to a DC?

>  2 steps completed 29 seconds

Aug 18, 2024

No, it is not common for a regular user on a Windows 10 device to send a replication request to a Domain Controller (DC). In a typical Active Directory environment, only Domain Controllers replicate data amongst themselves. This is a process that is typically transparent to regular users and happens in the background.

A regular user account should not have the necessary permissions to initiate a replication request. If a regular user is attempting to replicate data from a Domain Controller, it could be an indication of a potential security issue, such as a user with elevated privileges or a possible attack on the network.

In the context of a DCSync attack, the attacker would need to have domain admin level privileges to successfully perform the attack. This is because the DRSUAPI RPC interface, which is used to perform the replication, requires these high level privileges. Therefore, seeing a regular user account making these requests is highly unusual and suspicious.

In summary, any replication requests from a regular user account or a Windows 10 device should be thoroughly investigated as they are not common occurrences and could indicate a potential security issue.

Figure 3.43 – Response from Security Copilot

At this point, you likely can confirm this is a true security incident, not a false positive. Given the nature of the attack, it will require further investigation by the Tier 2 team.

Without help from Security Copilot, researching and confirming whether suspicious behavior is truly malicious can be time-consuming and labor-intensive. However, with Copilot, it is faster and more straightforward to confirm malicious activities.

Additionally, its explanations offer more context, helping the Tier 1 analyst assess the impact and severity of the incident. This enables the analyst to quickly decide whether the incident needs to be escalated to the Tier 2 team or not.

Now, let's move on to the lateral movement stage of the attack.

Lateral movement

In this same security incident, there is an alert for **Ongoing hands-on-keyboard attack via Impacket toolkit**. It is listed in the Security Copilot incident summary, as seen next:

LateralMovement: At 2024-08-06 17:17:09 UTC, an ongoing hands-on-keyboard attack via Impacket toolkit was detected on 'mb-adfs' (Windows Server 2022), involving the processes 'lsass.exe' (running as SYSTEM), 'powershell.exe' (running as SYSTEM), and impacting users 'LocalSystem' and 'adsfadmin'.

In the Microsoft Defender XDR portal, the alert description provides a brief description of the Impacket toolkit, as shown next:

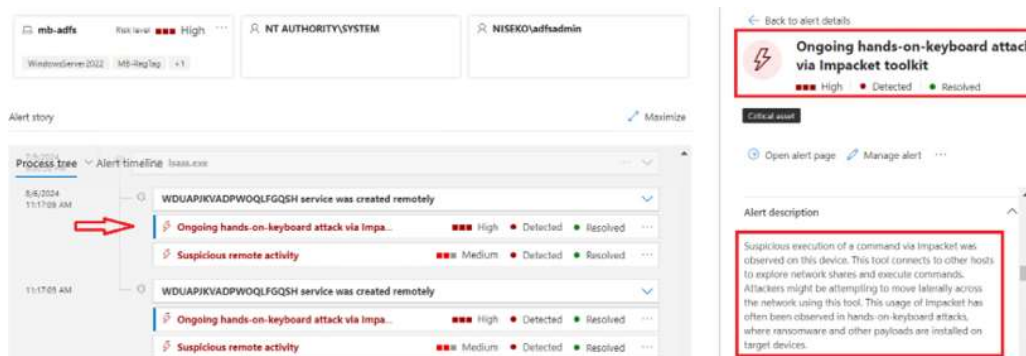


Figure 3.44 – Alert description in Microsoft Defender portal

The description of the Impacket toolkit in the Microsoft Defender portal is helpful. However, for more detailed information, you can turn to Security Copilot's standalone experience and ask the following:

Can you tell me more about the Impacket tool? Where is it used m

Copilot provides a more thorough description of this toolkit. While Impacket is a legitimate tool, Security Copilot emphasizes that it can also be exploited by attackers. As shown in the next screen capture, Security Copilot includes several examples to illustrate this point:

Can you tell me more about the Impacket tool? Where is it used most often? How is it exploited by attackers?

>  2 steps completed 39 seconds

Aug 18, 2024

Impacket is a collection of Python classes focused on providing network protocols, such as SMB1/2/3, MSRPC, or RDP, that allow for the construction of tools capable of interacting with Microsoft Windows and other systems. It's an open-source library maintained by SecureAuth Corporation and is widely used by security researchers and network administrators for network testing and security audits.

Impacket includes several ready-to-use scripts and examples that can be used to perform various network-related tasks, such as extracting hashes, transferring files, or executing remote commands. Some of the most well-known scripts included in Impacket are `secretsdump.py` (used for dumping hashes from various sources), `smbexec.py` (used for executing commands over SMB), and `psexec.py` (used for executing commands on remote systems).

While Impacket is a legitimate tool with many valid uses, it can also be exploited by attackers due to its powerful capabilities. For example, attackers can use Impacket to move laterally across a network, execute commands on remote systems, or extract sensitive information such as password hashes. In particular, the `secretsdump.py` script can be used to extract hashes from a Windows system, which can then be cracked offline or used in pass-the-hash attacks.

Impacket is often used in attacks involving Active Directory environments due to its ability to interact with various Windows protocols and services. For example, it can be used to perform a DCSync attack, which involves mimicking a Domain Controller to replicate hashed credentials from Active Directory.

In summary, while Impacket is a powerful tool for network testing and security audits, its capabilities can also be exploited by attackers to perform malicious activities. Therefore, any unexpected or unauthorized use of Impacket or similar tools in a network should be investigated as a potential security threat.

Figure 3.45 – Response from Security Copilot

As seen in the previous screenshot, Security Copilot also highlights a specific attack scenario, pointing out that **Impacket can be used to carry**

out a DCSync attack. And, as the Tier 1 analyst, you have just confirmed that a `DCSync` attack is involved in the same security incident.



Note

It's also worth mentioning that while using Security Copilot, it captures the sequence of your prompts and responses in a session. A session is a distinct interaction period with Security Copilot, during which Copilot retains the context of the conversation. This allows it to provide relevant answers to subsequent requests, ensuring that the conversation flows logically and that each response builds upon the previous ones. This could be the reason why Security Copilot specifically points out that Impacket can be used to perform a `DCSync` attack.

Persistence

As we proceed with the incident summary generated by Security Copilot, the next security alert there is a suspicious service creation event that occurred during the attack's *persistence* stage:

Persistence: At 2024-08-06 17:17:10 UTC, suspicious service creation was detected on 'mb-adfs' (Windows Server 2022), involving the process 'services.exe' (running as SYSTEM), and impacting user 'adfsadmin'.

If you start examining this alert in the Microsoft Defender portal, you will notice that Defender for Identity, Defender for Endpoint EDR, and

Defender XDR all generated similar alerts, likely for the same suspicious event, as seen in the next screen capture:

Alert name	Detection source	Product name	First activity
Ongoing hands-on-keyboard attack via Impacket ...	EDR	Microsoft Defender for Endpoint	Aug 6, 2024 11:17 AM
Suspicious service creation	Microsoft Defender for Identity	Microsoft Defender for Identity	Aug 6, 2024 11:17 AM
Suspicious service registration	EDR	Microsoft Defender for Endpoint	Aug 6, 2024 11:17 AM
Suspicious service creation	Defender XDR	Microsoft Defender for Endpoint	Aug 6, 2024 11:17 AM
Suspicious sequence of exploration activities	EDR	Microsoft Defender for Endpoint	Aug 6, 2024 11:17 AM
System executable renamed and launched	EDR	Microsoft Defender for Endpoint	Aug 6, 2024 11:17 AM

Figure 3.46 – The alerts in the Defender incident

Let’s first take a look at the **Suspicious service creation** alert triggered in **Microsoft Defender for Identity (MDI)**, as shown next:

Suspicious service creation

internal.niseko

Source Account

MB-ADFS

Destination Host

WindowsServer2022

MB-FlagTag

Risk level

Alert story

What happened

adfsadmin created WDUAPIKVADPWQQLFGQSH in order to execute potentially malicious commands on MB-ADFS.

Alert graph

adfsadmin

created

WDUAPIKVADPWQQLFGQSH

on

MB-ADFS

Timestamp

2024-08-06T17:17:10.3170341Z

Account

adfsadmin

Computer

MB-ADFS

Service name

WDUAPIKVADPWQQLFGQSH

Service path

%COMSPEC% /C "powershell.exe -EncodedCommand QwAGAFwAUwBJAHIAaOBwAHQAcwBcAFIAZQBbuAGEAbQBIAFAAbwB3AGUAcbZAGgAZQB8sAGwAlgrBwAHMAMQAs"

Figure 3.47 – The MDI Suspicious service creation alert

The service path listed in the alert looks suspicious and it is encoded. Let’s use the following prompt to consult with Security Copilot and understand its purpose:

```
Can you decode then tell me more about this service path: %COMSP
```

The next screen capture displays the response from Security Copilot:

The provided service path is a command line script that uses the command interpreter, typically `cmd.exe` on Windows systems, to execute a PowerShell command. The specific components of the service path are as follows:

1. `%COMSPEC%` : This is an environment variable that points to the command interpreter, which is typically `cmd.exe` on Windows systems.
2. `/C` : This is a switch used with `cmd.exe` to carry out the command specified by the string and then terminate.
3. `powershell.exe -EncodedCommand` : This part of the script executes `powershell.exe` with the `-EncodedCommand` parameter. The `-EncodedCommand` parameter is used to allow the execution of base64-encoded commands.
4. `QwA6AFwAUwBjAHIAaQBwAHQAcbAFIAZQBwAGEAbQB1AFaAbwB3AGUAcgBzAGgAZQBsAGwALgBwAHMAMQA=` : This is a base64-encoded command. When decoded, it translates to `C:\Scripts\RenamePowershell.ps1`.

In summary, this service path is used to execute the `RenamePowershell.ps1` PowerShell script located in the `C:\Scripts\` directory. The use of base64 encoding can often be a technique to obfuscate the actual command being run, which could be a sign of malicious activity. However, without further context or analysis of the `RenamePowershell.ps1` script itself, it's not possible to determine the exact purpose of this command.

Figure 3.48 – Response from Security Copilot

Note

Security Copilot provides a detailed breakdown of the service path. It identifies the encoded command as `base64` encoding and decodes it for you. It then concludes with a summary: **this service path is used to execute the `RenamePowershell.ps1` PowerShell script located in the `C:\Scripts\` directory.** The use of `base64` encoding can often be a technique to obfuscate the actual command being run, which could be a sign of malicious activity.

This information is helpful. Let's continue examining the other related security alerts. The **Suspicious service registration** alert triggered in **Microsoft Defender for Endpoint (MDE)** likely pertains to the same suspicious activity that is just looked at. This alert provides a little bit more

information and mentions **services.exe modified service image file**, as shown next:

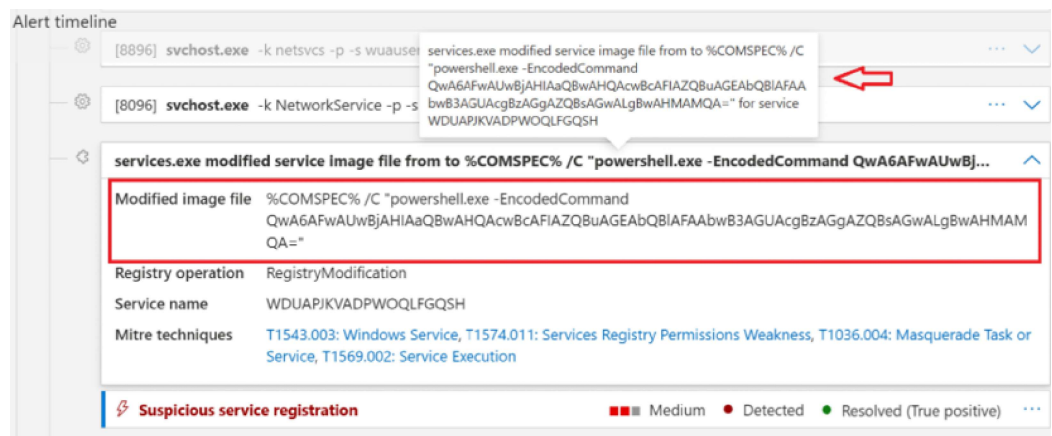
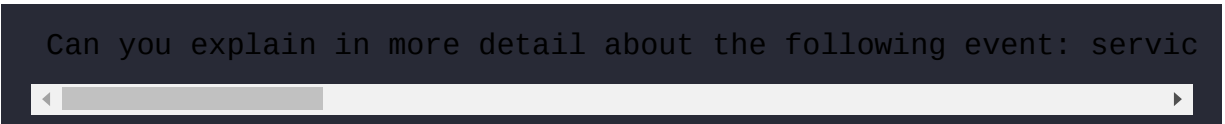


Figure 3.49 – The MDE Suspicious service registration alert

Using the following prompt, let’s see what Security Copilot can find out:



The screenshot shown next displays Copilot’s response:

The event you're referring to indicates that the `services.exe` process, which is a critical system process responsible for starting, stopping, and interacting with system services, has modified the image file path of a service named `WDUAPJKVADPWQLFGQSH`.

The new image file path is `%COMSPEC% /C "powershell.exe -EncodedCommand QwA6AFwAUwBjAHIAaQBwAHQAcwBcAFIAZQBuAGEAbQB1AFABwB3AGUAcgBzAGgAZQBsAGwALgBwAHMAMQA="`. This is a command line script that uses the command interpreter, typically `cmd.exe` on Windows systems, to execute a PowerShell command.

The specific components of the service path are as follows:

1. `%COMSPEC%` : This is an environment variable that points to the command interpreter, which is typically `cmd.exe` on Windows systems.
2. `/C` : This is a switch used with `cmd.exe` to carry out the command specified by the string and then terminate.
3. `powershell.exe -EncodedCommand` : This part of the script executes `powershell.exe` with the `-EncodedCommand` parameter. The `-EncodedCommand` parameter is used to allow the execution of base64-encoded commands.
4. `QwA6AFwAUwBjAHIAaQBwAHQAcwBcAFIAZQBuAGEAbQB1AFABwB3AGUAcgBzAGgAZQBsAGwALgBwAHMAMQA=` : This is a base64-encoded command. When decoded, it translates to `C:\Scripts\RenamePowershell.ps1`.

In summary, this service path is used to execute the `RenamePowershell.ps1` PowerShell script located in the `C:\Scripts\` directory. The use of base64 encoding can often be a technique to obfuscate the actual command being run, which could be a sign of malicious activity. However, without further context or analysis of the `RenamePowershell.ps1` script itself, it's not possible to determine the exact purpose of this command.

It's worth noting that changes to service image file paths, especially those involving scripts or unusual locations, can be a sign of malicious activity. In this case, the `services.exe` process has been instructed to launch a PowerShell script whenever the `WDUAPJKVADPWQLFGQSH` service is started, which is unusual behavior and could potentially be malicious. Further investigation would be required to determine the nature of this activity.

Figure 3.50 – Response from Security Copilot

Copilot's findings for this **Suspicious service registration** alert closely align with its analysis of the **Suspicious service creation** alert triggered in MDI. This confirms the suspicion that the two alerts from different security solutions are both reporting the same malicious activity. However, because the MDE alert points out a `services.exe` modified service image file and this detail is included in the prompt to Copilot, Security Copilot can now provide additional insights in its analysis that weren't present in the previous report.

Note



With the help of Security Copilot, you now have a clear picture of this malicious activity: the `services.exe` process has been set to run `RenamePowershell.ps1` whenever the `WDUAPJKVADPWOQLFGQSH` service is started. For your reference, the following snippet is taken from Copilot's last response:

It's worth noting that changes to service image file paths, especially those involving scripts or unusual locations, can be a sign of malicious activity. In this case, the services.exe process has been instructed to launch a PowerShell script whenever the WDUAPJKVADPWOQLFGQSH service is started, which is unusual behavior and could potentially be malicious.

This example also highlights the importance of effective prompting. The more specific the information you provide to Copilot, the more relevant and precise the response you're likely to receive.

Additionally, this example further emphasizes Microsoft Defender XDR's capability in integrating and correlating data across various Defender solutions. When different Defender tools detect the same malicious activity, they generate individual alerts. Microsoft Defender XDR then aggregates these alerts into a unified incident. This correlation helps to provide a comprehensive view of the threat.

Credential access

Let’s review one more alert from the incident summary provided by Security Copilot: a suspicious credential access event involving an ADFS private key extraction. Its incident summary snippet is shown next:

CredentialAccess: At 2024-08-06 17:18:20 UTC, an ADFS private key extraction attempt was detected on ‘mb-adfs’ (Windows Server 2022), impacting user ‘adfsadmin’.

In the Microsoft Defender XDR portal, in addition to the alert story, the device timeline also shows the events that led to the alert being triggered. For this one, the device event, **jyglecpm.1v0.exe ran an LDAP query**, triggered the **ADFS private key extraction attempt** alert.

A section of the device timeline is displayed in the next screenshot:

☐ Event time ↓	☐ Event	Additional information
Load newer results		
☐ Aug 10, 2024 6:01:14.651 PM	☐ ■■■ ADFS private key extraction attempt	CredentialAccess
☐ Aug 10, 2024 6:01:14.651 PM	☐ ⚙ jyglecpm.1v0.exe ran an LDAP query	T1087.002: Domain Account
☐ Aug 10, 2024 6:01:14.638 PM	☐ ⚙ jyglecpm.1v0.exe ran an LDAP query	T1087.002: Domain Account

Figure 3.51 – The device timeline

To further investigate this device event, one option is to utilize Security Copilot to analyze the command line for the `jyglecpm.1v0.exe` process that ran the LDAP query. You can perform this directly within the Microsoft Defender portal, leveraging the embedded experience of Security Copilot. Alternatively, in standalone mode, you can paste the command line into the Copilot prompt and request analysis.

The next screenshot illustrates the progression from the event shown in the device timeline to the display of its suspicious command line, then to its

analysis within Security Copilot's embedded experience:

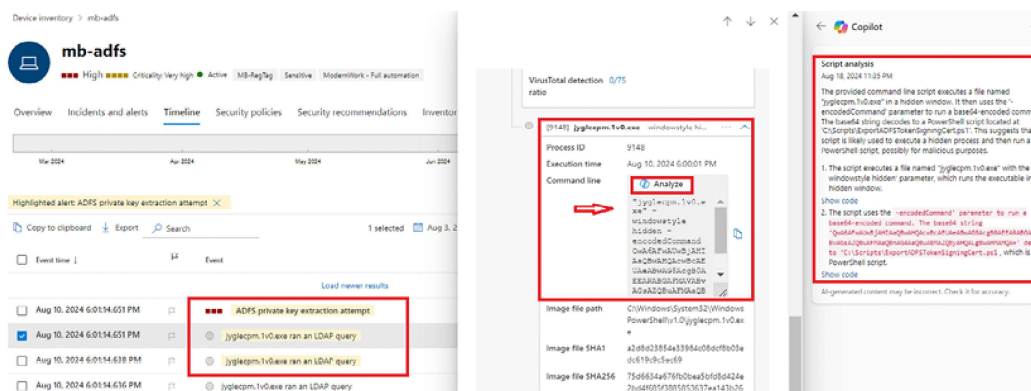


Figure 3.52 – Copilot command-line analysis

Security Copilot offers a detailed analysis of this process command line. An excerpt of the analysis is provided next for your reference since it's difficult to read in the screenshot:

The provided command line script executes a file named “jyglecpm.1v0.exe” in a hidden window. It then uses the ‘-encodedCommand’ parameter to run a base64-encoded command. The base64 string decodes to a PowerShell script located at ‘C:\Scripts\ExportADFS TokenSigningCert.ps1’. This suggests that the script is likely used to execute a hidden process and then run a PowerShell script, possibly for malicious purposes.

From the Copilot analysis, you can sense something wasn't right when `jyglecpm.1v0.exe` performed the LDAP query. To further investigate, you can first get a sense of what the normal LDAP operations are by prompting Copilot with the following questions in its standalone experience:

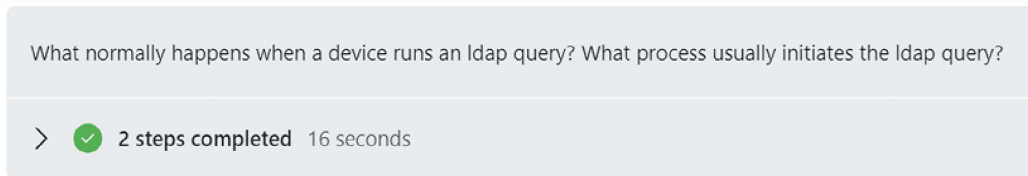


Figure 3.53 – Security Copilot prompt

The next screenshot displays the information returned by Copilot:

When a device runs an LDAP (Lightweight Directory Access Protocol) query, it's typically trying to access or manipulate data stored in a directory service. This could be for a variety of reasons, such as authenticating a user, finding information about a user or group, or updating directory information.

The process that initiates the LDAP query can vary depending on the specific use case. However, it's often a client application or service that needs to interact with the directory service. For example, an email client might run an LDAP query to look up the email addresses of users in a company. Similarly, a web application might run an LDAP query to authenticate a user who is trying to log in.

In a Windows environment, it's common for the process initiating the LDAP query to be a part of the Active Directory Domain Services (AD DS). This could be a process like LSASS (Local Security Authority Subsystem Service), which is responsible for enforcing the security policy on the system. It verifies users logging on to a Windows server or workstation, handles password changes, and creates access tokens. It might also be a process like NETLOGON, which supports network logon of users and service accounts.

Remember, the specifics can vary greatly depending on the environment and the application or service that's running the LDAP query.

Figure 3.54 – Security Copilot response

Based on Copilot's explanation, you quickly gain an understanding of LDAP and how it operates. LDAP queries are typically initiated by client applications or services that need to access data stored in a directory service. For instance, an email client might perform an LDAP query to retrieve the email addresses of users within an organization.

Now you may be wondering why an unfamiliar and rarely seen process such as `jyglecpm.1v0.exe` needs to run an LDAP query to access data in a directory service. It is especially suspicious with its encoded command line. Let's continue to consult with Security Copilot.

The prompt is shown in the next screen capture:

Can you tell me if this is normal LDAP operation based on the following command line in the LDAP query:

```
"jyglecpm.1v0.exe" -windowstyle hidden -encodedCommand  
QwA6AFwAUwBjAHIAaQBwAHQAQcWbCzAEUAeABwAG8AcgB0AEEARABGAFMAVABvAGsAZQBwAFMAaQBnAG4AaQBwAE  
MAZQBByAHQALgBwAHMAMQA=
```

Figure 3.55 – Security Copilot prompt

Security Copilot, leveraging its vast amount of knowledge, reports that the command-line script does not resemble a typical LDAP operation. Its full response is displayed in the next screen capture:

The command line script you provided does not appear to be a normal LDAP operation. It executes a file named "jyglecpm.1v0.exe" in a hidden window, which means the process will run in the background without displaying a window to the user. This is not typical behavior for LDAP operations, which usually involve network communication to access and manage directory information.

Moreover, the script uses the `-encodedCommand` parameter to run a base64-encoded command. The base64 string decodes to `C:\Scripts\ExportADFS token Signing Cert.ps1`, indicating that a PowerShell script named "ExportADFS token Signing Cert.ps1" located in the "C:\Scripts" directory is being executed. This script might be used to export the ADFS (Active Directory Federation Services) token signing certificate.

While ADFS is a part of Microsoft's Active Directory suite and is used in some LDAP environments, the exporting of a token signing certificate is not a standard LDAP operation. This could potentially be used for malicious purposes such as token forging. Therefore, this command line script does not appear to be a normal LDAP operation and may warrant further investigation.

Figure 3.56 – Security Copilot response

Important note

Without the assistance of Security Copilot, the process of determining whether the behavior is truly malicious can be time-consuming and labor-intensive. Traditional methods often involve extensive manual research, analysis, and investigation, which can delay the identification of true threats. However, with Copilot, this process becomes significantly more efficient and straightforward.



The additional context and explanations offered by Security Copilot can assist Tier 1 analysts in quickly understanding the nature and severity of the incident. As a result, they can make informed decisions on whether the incident requires escalation to the Tier 2 team. By leveraging Security Copilot, Tier 1 analysts not only can expedite the identification of true security threats but also ensure that appropriate actions are taken promptly, thus optimizing the overall incident response process.

Summary

In this chapter, you were introduced to the processes for setting up and customizing Security Copilot, as well as navigating its user interfaces. The chapter concluded with a real-life case study of a security incident investigation, allowing you to observe Security Copilot's application in real-world security scenarios and understand the synergy between its various components. By gaining a clear understanding of both the embedded and standalone experiences, you can better leverage the platform's AI capabilities to address your specific security needs.

In the next chapter, you will explore how various plugins extend Security Copilot's functionalities. It will cover both pre-installed Microsoft plugins and third-party options, as well as the development of custom plugins tailored to unique security requirements. This will build on the foundation you've established, enhancing your ability to adapt the tool to your specific needs.

**Subscribe to _secpro - the
newsletter read by 65,000+**

cybersecurity professionals

Want to keep up with the latest cybersecurity threats, defenses, tools, and strategies?

Scan the QR code to subscribe to **_secpro**—the weekly newsletter trusted by 65,000+ cybersecurity professionals who stay informed and ahead of evolving risks.



<https://secpro.substack.com>

Unlock this book's exclusive benefits now

Scan this QR code or go to packtpub.com/unlock, then search this book by name.

Note: Keep your purchase invoice ready before you start.



OceanofPDF.com

4

Extending Security Copilot's Capabilities with Plugins

Security Copilot was developed as a comprehensive framework designed to enhance an organization's security posture by seamlessly connecting to its systems. This framework leverages advanced AI capabilities to provide tailored insights and proactive security measures.

In this chapter, we will explore the world of **plugins** that extend the capabilities of Security Copilot, showcasing how they enhance Copilot's functionality and adaptability to meet diverse security needs.

Plugins are a key differentiator for Security Copilot. Unlike other solutions that focus solely on developing standalone products, Security Copilot is strategically designed as both a platform and a product. Rather than being confined to a fixed set of features, it can be expanded and tailored to diverse needs through its wide range of plugins. This modular approach enables Security Copilot to provide a more versatile and integrated experience. As we explore the plugins for Security Copilot, we'll start by examining the **preinstalled Microsoft plugins**, providing a thorough understanding of their features and applications. Next, we'll look into **non-Microsoft**

plugins. Moreover, this chapter will provide insights into the development and utilization of **custom plugins** tailored to specific security needs.

Through this exploration, you will develop the skills to effectively use plugins and even create your own, empowering you to further enhance and refine your security strategies with the support of Security Copilot.

The following key areas outlined in this chapter will guide you through the discovery and exploration:

- Exploring Security Copilot plugins
- Unleashing the power of preinstalled Microsoft plugins
- OpenAI and beyond – Delving into non-Microsoft plugins
- Crafting your own – The world of custom plugins



Want to try out the prompts, custom plugins, and promptbooks featured in this book? Take a look at the book's GitHub repository at <https://github.com/PacktPublishing/Microsoft-Copilot-for-Security>.

Exploring Security Copilot plugins

A plugin is a set of specialized capabilities designed to enhance and extend Security Copilot's functionality. Essentially, it provides new security features to expand the core capabilities of Security Copilot, allowing Copilot to address a wider range of security challenges. For instance, some of Microsoft Defender XDR's features can serve as a plugin for Security

Copilot. Capabilities in Intune and Microsoft Entra, as well as third-party solutions such as ServiceNow, Jamf, Darktrace, and AbuseIPDB, can also be used as plugins for Security Copilot.

Imagine your Security Copilot solution as a high-tech car. The plugins are like a set of premium accessories that you can add to customize and boost your car's performance. These accessories – whether they're preinstalled or available from other providers – allow you to tailor the system to better meet your needs.

To give you a better idea about the plugins, here's a short sample list of Microsoft and non-Microsoft plugins available for Security Copilot:

- Microsoft Defender XDR
- Microsoft Defender Threat Intelligence (MDTI)
- Microsoft Defender External Attack Surface Management (EASM)
- Microsoft Entra
- Microsoft Purview
- AbuseIPDB
- CyberArk Privilege Cloud
- Darktrace
- Intel 471 Threat Intelligence
- Jamf
- Red Canary
- Tanium
- UrlScan

In addition, you can further enhance Security Copilot's features by creating your own plugins.

The plugins allow Security Copilot to evolve from a fixed set of features into a more dynamic ecosystem. You can pick and choose from a range of available plugins. This flexibility allows you to tailor your setup by including only the plugins that meet your needs and disabling those that are unnecessary. This modular approach transforms Security Copilot from a static product into a versatile platform with a broad range of options. As the Security Copilot marketing team puts it, “*we are building a platform and a product.*” This strategy ensures that as Security Copilot evolves, its functionality will continue to grow with new plugins, offering greater adaptability and customization.

Capabilities (or skills) of each plugin

Each plugin offers a set of capabilities, often called **skills**, that Security Copilot can utilize. For instance, the Microsoft Defender XDR plugin includes capabilities such as incident summarization, guided response, scripts analysis, and incident report creation.

Whenever you ask Security Copilot a question through its prompt feature, it will choose the most suitable plugin based on its capabilities/skills to provide an answer to your question. As an example, if you ask Copilot to summarize a Microsoft Defender incident, it selects the Microsoft Defender XDR plugin, as illustrated in the next screenshot:



Figure 4.1 – Selecting the plugin that best fits your prompt

In some instances, if there is no suitable plugin, not even the Generic one, Security Copilot defaults to using the standard GPT model in Azure OpenAI Service, as shown in the following screenshot:

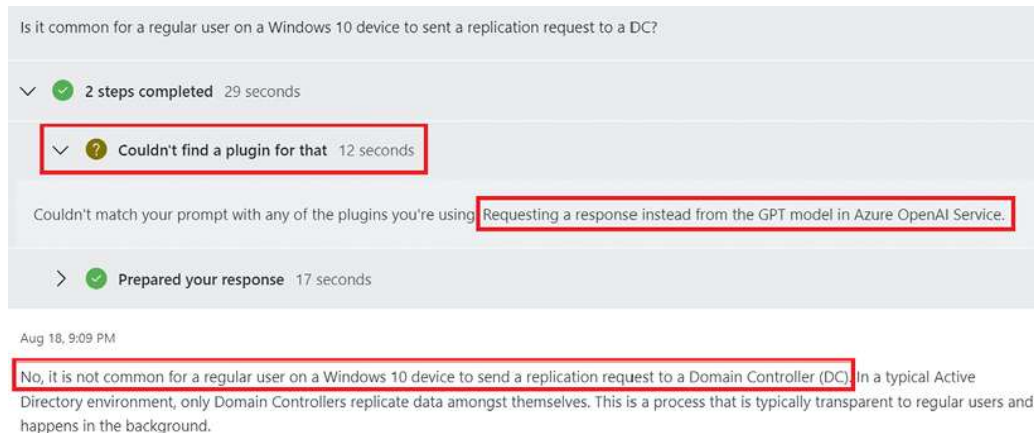


Figure 4.2 – Security Copilot defaults to using the standard GPT model in Azure OpenAI Service

To get an overview of the capabilities or skills offered by a plugin, you can use the **SYSTEM CAPABILITIES** option from the **Prompts** menu to view a list of plugins and their associated skills, as shown in the following screenshot:

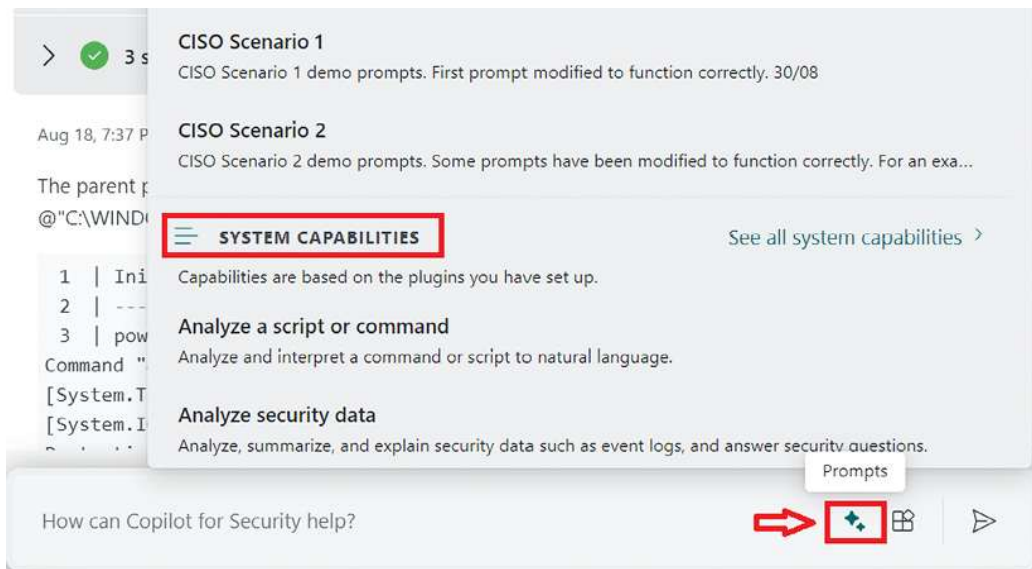


Figure 4.3 – SYSTEM CAPABILITIES



Important note

Microsoft is continually enhancing and updating Security Copilot’s capabilities. As a result, the plugins and their associated skills listed under **SYSTEM CAPABILITIES** are subject to change over time. Consequently, the information presented in this book, such as the plugin name or a specific skill, may not always reflect what appears in the most current version of Security Copilot.

Up to this point, you have been briefly introduced to plugins in Security Copilot. To further showcase how these plugins enhance Copilot’s functionality and adaptability to various security needs, we’ll examine them in more detail next. We’ll start by looking into the specific features and advantages of some of the Microsoft plugins in the next section.

Unleashing the power of preinstalled Microsoft plugins

Security Copilot supports a wide array of **Microsoft plugins**. The specific plugins and features available to you are determined by the Microsoft services and configurations your organization has in place. Depending on the Microsoft solutions assigned to your role or organization, you may have access to any of the plugins listed here:

- Azure AI Search (Preview)
- Azure Firewall
- Azure Web Application Firewall (Preview)
- Microsoft Defender External Attack Surface Management
- Microsoft Defender Threat Intelligence
- Microsoft Defender XDR
- Microsoft Entra
- Microsoft Intune
- Microsoft Purview
- Microsoft Sentinel
- Natural Language to KQL for Microsoft Defender XDR



Note

The preceding list includes plugins that are in preview as of March 2025. These plugins have not yet reached **General Availability (GA)**.

Security Copilot uses a special method called **on-behalf-of authentication** to interact with other Microsoft services that your organization already uses. Think of it like this: when you use Security Copilot, this method lets Copilot access other Microsoft tools or services on your behalf, using the permissions you already have. Essentially, it's like giving Security Copilot the ability to use your access rights to seamlessly integrate and work with those other services, without you needing to log in separately to each one. This means Security Copilot can automatically utilize the available plugins without requiring any additional setup from you.

This also means that Security Copilot relies on your access permissions to use the plugins. Even if a plugin is enabled in your Security Copilot settings, if you do not have the appropriate permissions, the plugin will not function as intended. Alternatively, the plugin will have all the permissions you maintain, which should highlight the importance of applying the principle of least privilege and securing your credentials.

By default, users have access to preinstalled Microsoft and non-Microsoft plugins. They can manage their own plugin settings, such as turning plugins on or off and setting up required authentication methods. Additionally, administrators with the owner role can enforce organization-wide plugin restrictions. This includes controlling which existing and new plugins are available to users, as well as determining who can add and manage custom plugins.

Assuming you have activated all the Microsoft plugins and have the appropriate access, let's examine some of the plugins, particularly those not in preview, in the next few sections.

Security Copilot Defender XDR plugins

Microsoft Defender XDR, also known as Microsoft Defender, is an advanced security solution that protects organizations from a wide array of cyber threats. It provides comprehensive monitoring and safeguards the entire IT environment. This includes endpoint security through Microsoft Defender for Endpoint, email protection against phishing and malicious messages via Microsoft Defender for Office, and user account security with Microsoft Defender for Identity. Additionally, it extends protection to cloud applications with Microsoft Defender for Cloud Apps. By integrating with these security tools and services, Defender XDR provides a unified approach to threat detection and response, combining insights from multiple sources to effectively address and mitigate potential risks across the organization's digital assets.

Microsoft Defender XDR also includes a powerful feature known as **advanced hunting**. Utilizing **Kusto Query Language (KQL)**, this tool serves as an advanced analytics engine for the organization's cyber telemetry data.

It enables security teams to quickly and thoroughly analyze data from various sources, including activities from emails, devices, users, and network traffic. As a result, it significantly accelerates the investigation process, detection, and threat hunting.

The Microsoft **Defender XDR plugin** in Security Copilot, leveraging the advanced capabilities of AI and the extensive features within Microsoft Defender XDR, offers many additional enhanced security functionalities to support security teams.

In [Chapter 2](#), we demonstrated how the Microsoft Defender XDR plugin enables seamless integration of Security Copilot into the Microsoft Defender portal, assisting security teams with the following enhanced capabilities:

- **Summarize incidents:** Security Copilot compiles details from all related alerts into a clear and concise incident summary
- **Use guided responses:** Security Copilot guides the analyst through the recommended investigation and remediation actions based on the incident details
- **Analyze scripts, codes, and registry keys:** Security Copilot breaks down complex scripts, command lines, and registry keys, offering a clear and straightforward explanation that is easy to understand
- **Analyze files:** Security Copilot examines files for malicious content or suspicious behavior
- **Generate KQL queries:** Security Copilot creates advanced queries to hunt for threats across the network
- **Summarize device information:** Security Copilot provides an overview of a device's security posture and any unusual activities
- **Create incident reports:** Security Copilot documents findings and actions taken during an investigation to generate an incident report



Note

The standalone experience of Security Copilot includes all the plugin capabilities/skills of Defender XDR available in the embedded mode, along with many additional capabilities not offered in the embedded experience.

In addition, the capabilities/skills of Defender XDR are divided into two separate plugins: the **Microsoft Defender XDR plugin** and the **Natural Language to KQL for Microsoft Defender XDR plugin**.

The Microsoft Defender XDR plugin is designed for incident analysis and investigation, while the Natural Language to KQL for Microsoft Defender XDR plugin focuses on generating KQL queries for analyzing data from Microsoft Defender XDR.

The **SYSTEM CAPABILITIES** menu option in Security Copilot outlines the core capabilities or skills offered by the two Microsoft Defender XDR plugins, as shown here:

Microsoft Defender XDR:

- **Analyze a file:** Inspect a file using available information, including API calls, certificates, and strings
- **Generate an incident report:** Get a report about an attack and your response, including who took action and when
- **Generate guided response:** Get step-by-step response recommendations for an incident
- **List incidents and related alerts:** Get the list of incidents or find specific incidents
- **Summarize the security state of the device:** Get device insights, security issues, and other important information

Natural Language to KQL for Microsoft Defender XDR:

- **Generate Microsoft Defender XDR KQL Queries:** Generates and runs KQL hunting queries using Microsoft Defender XDR data

In [Chapter 3](#), you assumed the role of a tier 1 analyst in a case study to see how Security Copilot can assist in incident investigations. This time, we will revisit the same incident from that case study. However, you will now take on the role of a tier 2 analyst to explore how Microsoft Defender XDR plugins can support you throughout the investigation.

Note



The walk-through provided in this section is intended to demonstrate some of the possible steps a tier 2 analyst might take during an investigation, but it is not all-inclusive. Individual tier 2 analysts may follow different workflows, use alternative prompts, or craft different KQL queries based on their investigative approach and the specifics of the incident.

The incident summary provided by Security Copilot reveals that the incident started when the user clicked on a URL in an email, as illustrated here:

- **InitialAccess:** The incident began at 2024-08-06 17:15:43 UTC when user 'kdickens' clicked on a malicious URL 'hxxps://fm06722326[.]mangodune-7572a721[.]eastus[.]azurecontainerapps[.]io/' in an email that was later quarantined by ZAP.

Figure 4.4 – The initial access description in Copilot's incident summary

The next alert then reports a suspicious sequence of exploration activities involving the `'whoami.exe'` and `powershell.exe` processes.

- **Discovery:** At 2024-08-06 17:16:17 UTC, a suspicious sequence of exploration activities was detected on the device 'mb-winclient' (Windows10), involving the processes 'whoami.exe', 'powershell.exe' (running as SYSTEM), and impacting users 'pgustavo' and 'kdickens'.

Figure 4.5 – The description of the discovery stage in Security Copilot's incident summary



As a tier 2 analyst, you need to investigate what occurred after the user clicked on the malicious link in the email, leading to a sequence of exploratory activities on the same device.

In Microsoft Defender, each email is assigned a unique identifier called the **network message ID**. Referencing this ID, you can request Security Copilot to retrieve basic information about this email for a quick review.

The following screenshot shows the Security Copilot prompt fetching email entities. Notice that in this instance, Copilot selects the Natural Language to KQL for Microsoft Defender XDR plugin to pull the email entity information:

What entities can you pull from email where its Network message id is 7416dceb-aa36-4f4b-7de0-08dcb635d9c0?

3 steps completed 34 seconds

- > Chose Natural language to KQL for Microsoft Defender XDR 11 seconds
- > Processed your request 13 seconds
- > Prepared your response 11 seconds

Figure 4.6 – Request Security Copilot to fetch email data

Security Copilot then provides details about this email, including the subject, the sender's email address, the domain, and the IP, as illustrated in the following screenshot:



Figure 4.7 – Security Copilot provides details about this email

Security Copilot's response doesn't include details about URLs or file attachments in the email. You can follow up to request this information. The specific Copilot prompt is displayed in the following screenshot:

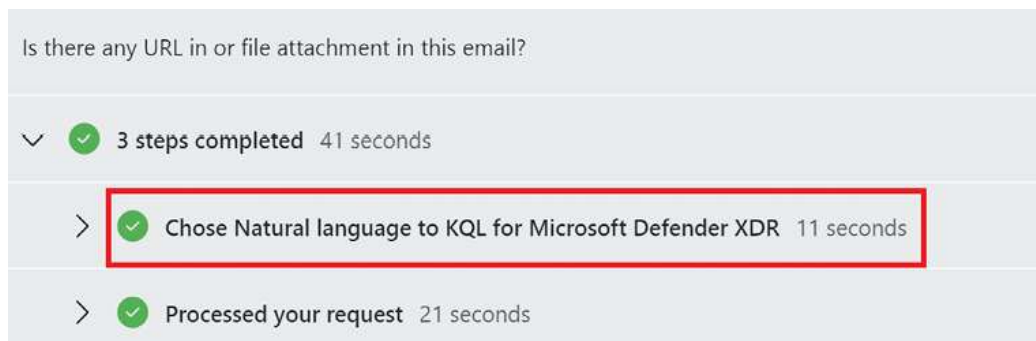


Figure 4.8 – Follow-up request for Security Copilot

This time, Security Copilot extracts the URL from the email, as shown next. This demonstration also illustrates that when a prompt isn't clear or detailed

enough, Copilot may not give the relevant answers. However, you can always use a follow-up prompt to get the information you need:

The email with Network message id '7416dceb-aa36-4f4b-7de0-08dcb635d9c0' contains the following URL and file attachment:

 Export to Excel 		
NetworkMessageId	Url	FileName
	NetworkMessageId	Url
---	---	---
7416dceb-aa36-4f4b-7de0-08dcb635d9c0	https://fm06722326.mangodune-7572a721.eastus.azurecontainerapps.io/	

Figure 4.9 – Security Copilot extracts and displays the URL included in the email

Using the Natural Language to KQL for Microsoft Defender XDR plugin, Security Copilot is able to pull the suspicious email and its associated entities for you to review quickly. You now know that the email was sent by an internal user, has the subject line of **Interesting news**, and contains a suspicious link that the user clicked on.

As a tier 2 analyst, your next step is likely to determine whether any files were downloaded or executed as a result of the user clicking on the link. There is a KQL query that security teams can use to identify file download activities following such link clicks. You can now request Security Copilot to run this KQL query and report on its findings.

As shown in the following screenshot, Security Copilot, utilizing its Natural Language to KQL for Microsoft Defender XDR plugin, executes the KQL query specified in the prompt:

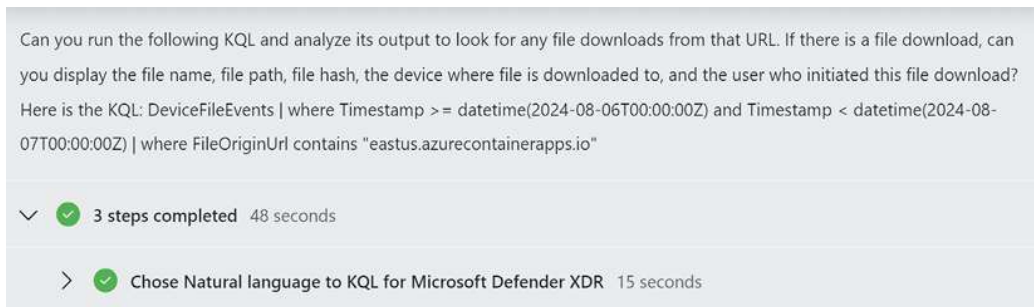


Figure 4.10 – Security Copilot to execute the KQL query and then analyze the resulting data

The response provided by Security Copilot indicates that the file, `Midnight161.zip`, was downloaded to the `C:\Users\kdickens\Downloads\` directory on that user's device. This is illustrated in the following screenshot. Verifying the timestamp of the URL click confirms that it matches the time of the file download. *You now have a suspicious file to investigate:*

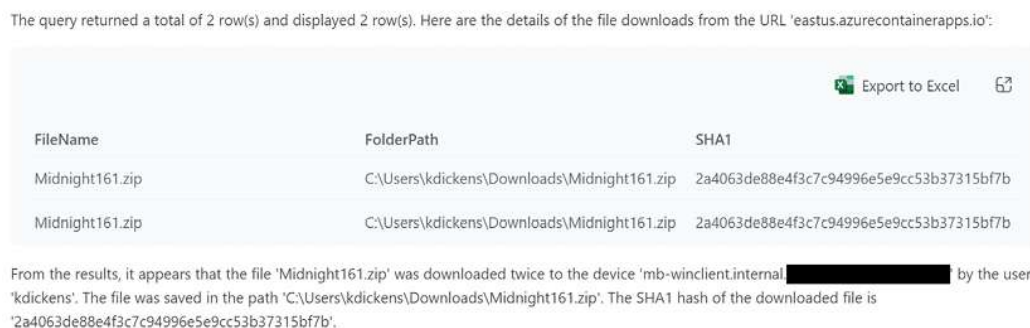


Figure 4.11 – Security Copilot reports that the file, `Midnight161.zip`, was downloaded

You can request Security Copilot to assess this downloaded file's reputation, prevalence, and other relevant details. The prompt shown next asks Security Copilot to evaluate the downloaded file:

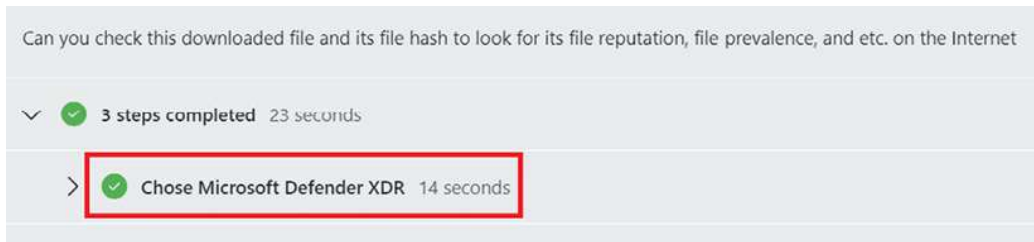


Figure 4.12 – Ask Security Copilot to evaluate the downloaded file

The response generated by Security Copilot is shown in the following screenshot:

Aug 25, 8:41 PM

The file with the SHA1 hash '2a4063de88e4f3c7c94996e5e9cc53b37315bf7b' was analyzed, but no additional insights were found. This could mean that the file is not widely prevalent or has not been flagged as malicious in the available data sources. However, it's important to note that the absence of negative indicators does not necessarily mean the file is safe. Always exercise caution when dealing with files from unknown sources.

Figure 4.13 – Responses from Security Copilot



Important note

Often, if a file is downloaded from a website but is relatively unknown with very low prevalence, it may indicate that the file is suspicious.

Let's ask Security Copilot to execute another KQL query to review any file creation, modification, or deletion events that occurred during the day of the incident, specifically those involving files with the `Midnight161` keyword in their names. The Security Copilot prompt and the plugin used are shown in the following screenshot:



Figure 4.14 – The Security Copilot prompt and the plugin used

Security Copilot executes the KQL query, analyzes the results, and then reports the key findings. The following screenshot displays that Security Copilot identifies a PowerShell script and reports: **The file “Midnight161.ps1” was also created on the same device by the same user using the process “powershell.exe”. The file events occurred in the folder path “C:\Users\kdickens\Downloads”:**

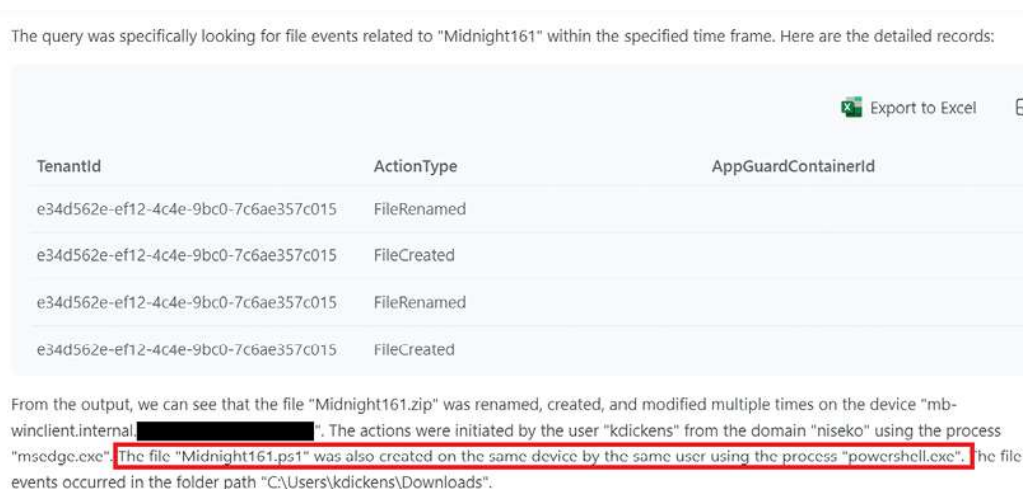
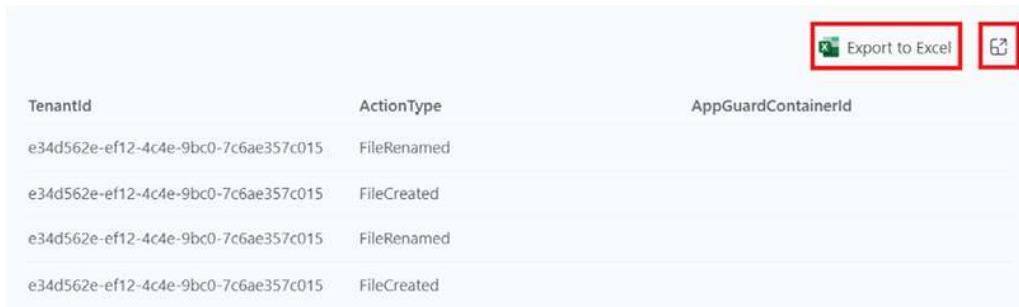


Figure 4.15 – Security Copilot’s response and the identification of a new PowerShell script, Midnight161.ps1

By examining the KQL results through the **Export to Excel** option or by expanding the results listed in Security Copilot, as shown in the following screenshot, you are able to review the timestamps of the two files, **Midnight161.zip** and **Midnight161.ps1**, to confirm that they were created around the same time:



TenantId	ActionType	AppGuardContainerId
e34d562e-ef12-4c4e-9bc0-7c6ae357c015	FileRenamed	
e34d562e-ef12-4c4e-9bc0-7c6ae357c015	FileCreated	
e34d562e-ef12-4c4e-9bc0-7c6ae357c015	FileRenamed	
e34d562e-ef12-4c4e-9bc0-7c6ae357c015	FileCreated	

Figure 4.16 – Security Copilot allows you to fully analyze its KQL output

You now have one additional file to investigate, `Midnight161.ps1`.

Leveraging the Natural Language to KQL for Microsoft Defender XDR plugin, Security Copilot can extract process, file, registry, network, and other device events containing the `Midnight161` keyword. It then analyzes these events and displays the ones that are related to PowerShell execution. The KQL query along with the Security Copilot prompt is shown in the following screenshot:



Figure 4.17 – The Security Copilot prompt and the plugin used

As illustrated in the following screenshot, Security Copilot identified that the `Midnight161.ps1` PowerShell script was run by the user `kdickens`. This script established network connections to two external sites and it also executed `whoami.exe`. Note that the execution of `whoami` is highlighted in the second alert within the incident summary provided by Security Copilot, which reports the suspicious sequence of exploration activities:

The KQL query you provided was successfully executed and returned more than 150 rows, of which 26 are displayed. The query was specifically looking for PowerShell execution related to "Midnight161" within the specified time frame. Here are some of the key findings:

- The PowerShell script "Midnight161.ps1" was executed from the path "C:\Users\kdickens\Downloads\Midnight161\Midnight161.ps1".
- The script was executed by the user "kdickens" from the domain "██████".
- The script made network connections to "prod-15.eastus.logic.azure.com" and "raw.githubusercontent.com".
- The script was executed with the command line "powershell.exe" -ExecutionPolicy bypass -File C:\Users\kdickens\Downloads\Midnight161\Midnight161.ps1.
- The script also executed "whoami.exe" with the command line "whoami.exe" /user.
- The script was detected by AMSI (Antimalware Scan Interface) as a potential threat.

Figure 4.18 – Security Copilot's findings related to PowerShell execution

With this additional context from Security Copilot, you now have a clearer understanding of the events that unfolded after the user clicked on the link. You can determine that after the click of the email link, a file named `Midnight161.zip` was downloaded to the device.

Then, a file named `Midnight161.ps1` was created around the same time, which ran `whoami.exe` to collect information about the user environment.

It's quite impressive how Security Copilot can enhance incident investigations with its Microsoft Defender XDR plugins. Later in this chapter, as well as in other chapters, we will demonstrate how these KQL queries can be transformed into custom plugins. These plugins can then be incorporated into promptbooks for more efficient investigation workflows. Additionally, you can chain different promptbooks together to further streamline your investigation process. For now, let's dive into the EASM plugin next and see how it can support you.

Security Copilot for External Attack Surface Management

plugin

An organization's external and public-facing assets, such as its website and online applications, are vulnerable targets for attackers. Since these elements are publicly accessible on the internet, it is easier for attackers to spot potential vulnerabilities, such as outdated software, unprotected services, or misconfigured settings. This visibility allows attackers to focus on these weaknesses to gain unauthorized access or to exploit the organization's systems.

Microsoft Defender EASM is designed to provide a view of the attack surface of your organization's external-facing digital assets, much like how attackers would see from the outside in. Imagine your company as a large and well-guarded building. The goal is to make sure that no one can sneak in through the unlocked door or open window. Microsoft Defender EASM acts like a team of security experts who walk around the building, examining every possible entry point to identify any weaknesses.

Defender EASM works by scanning and analyzing the organization's digital presence seen on the internet, everything from websites and applications to cloud services and network configurations. It then provides detailed insights about potential risks and vulnerabilities, helping businesses to address these issues before they can be exploited by malicious actors. By identifying and assessing these vulnerabilities, Microsoft Defender EASM enables organizations to be more proactive in protecting and securing their external digital assets, addressing weaknesses before they can be exploited.

Security Copilot can further enhance Defender EASM functionalities by offering detailed insights into vulnerabilities and asset statuses. It helps to identify external-facing assets affected by specific **Common Vulnerabilities and Exposures (CVEs)**, or with high **Common**

Vulnerability Scoring System (CVSS) scores, prioritizes risks based on their severity, and offers a comprehensive view of the attack surface.

Security Copilot also simplifies asset management with natural language queries and highlights expired domains and SSL certificates. By integrating these capabilities, Security Copilot allows for more effective risk prioritization and proactive security measures, ultimately improving the management and protection of your external digital assets.

Please note that Security Copilot is not embedded in the Microsoft Defender EASM console. However, you can still access and use its plugin through Security Copilot's standalone experience.

The **SYSTEM CAPABILITIES** menu option in Security Copilot outlines some of the Defender EASM core capabilities available within the standalone portal:

- **Get assets impacted by CVE:** Identify the assets that a CVE impacts, their details, and when they were observed.
- **Get assets impacted by CVSS:** Identify the assets that a CVSS score impacts, their details, and when they were observed.
- **Get attack surface insights:** Learn about high-, medium-, or low-priority insights impacting attack surfaces.
- **Get attack surface summary:** Discover what assets are in an attack surface.
- **Get EASM assets:** Get assets based on a natural language query.
- **Get expired domains:** Learn about expired domains, their details, and assets for attack surfaces.
- **Get expired SSL certificates:** Learn about expired SSL certificates, their details, and associated assets for attack surfaces.

- **Get Microsoft Defender EASM general information:** Learn about Microsoft Defender EASM's features, data, and other details.
- **Get SSL certificates using SHA-1:** Learn about SSL certificates using SHA-1, their details, and associated assets.

Note



The features available in EASM differ based on whether you have a free or paid license. This also affects the EASM plugin functionality within Security Copilot. As an example, the free license provides access to pre-built attack surface insights, but it may not allow you to search for your organization's specific attack surface if it's not part of the predefined data. The next few examples will showcase EASM capabilities within Security Copilot when using a paid license.

For example, by using the Defender EASM plugin in Security Copilot's standalone mode, you can request a summary of the attack surface for your organization's external-facing digital assets. The Security Copilot prompt utilizing this plugin is illustrated in the following screenshot:

Show me the attack surface summary for ██████████ Bank.

✓ 3 steps completed 16s

> ✓ Chose Defender External Attack Surface Management 4s

> ✓ Processed your request 4s

Figure 4.19 – The Security Copilot prompt

The response generated by Security Copilot, shown next, reveals a complex online environment with 268 confirmed domains and 7,374 hosts, indicating a substantial infrastructure:

Here is the attack surface summary for ██████████ Bank:

- Confirmed Domains: 268
- Confirmed Hosts: 7374
- Confirmed Pages: 0
- Confirmed SSL Certificates: 355
- Confirmed Autonomous Systems (AS): 1
- Confirmed IP Blocks: 13
- Confirmed IP Addresses: 4423
- Confirmed Contacts: 18

Please note that this information is accurate as of 2023-10-27T19:35:10Z.

Figure 4.20 – Response from Security Copilot

Despite this extensive network, from Security Copilot's response, it's noteworthy that there are no confirmed web pages associated with these hosts, which could suggest a focus on backend operations or security considerations. The organization holds 355 confirmed SSL certificates, highlighting a commitment to secure communications and data protection.

You can then ask Security Copilot to list expired SSL certificates for your externally facing resources. These certificates may signal **shadow IT** or abandoned assets that are not known by security teams. Shadow IT refers to the use of technology, applications, or services within an organization

without the approval or knowledge of the IT department. While employees may adopt these tools to enhance productivity, it can lead to security risks and compliance issues since they may not meet the organization's security standards. As shown in the following screenshot, Security Copilot identifies the expired SSL certificates for you:

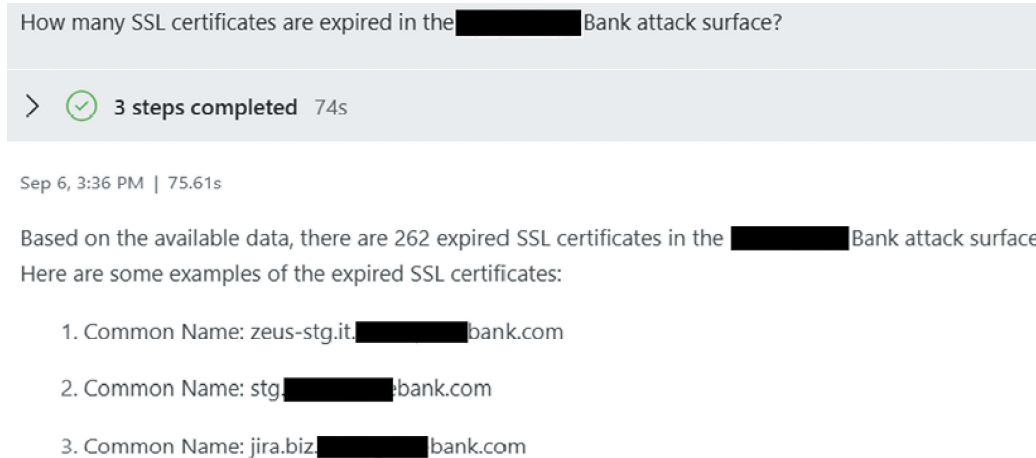


Figure 4.21 – Security Copilot lists expired SSL certificates

Once you have identified the expired SSL certificates, you can then ask Security Copilot to list which related assets might have high-severity vulnerabilities. For instance, you can prompt Security Copilot for a list of vulnerabilities associated with a host tied to the expired SSL certificate, as shown next:

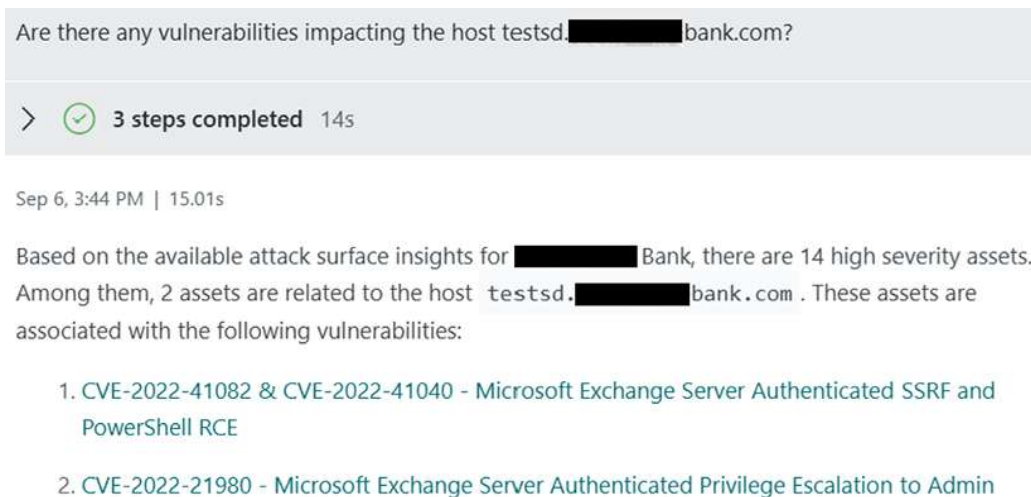


Figure 4.22 – Security Copilot lists vulnerabilities associated with a host

Next, you can prompt Security Copilot to get a list of recommended mitigation steps for the CVEs:

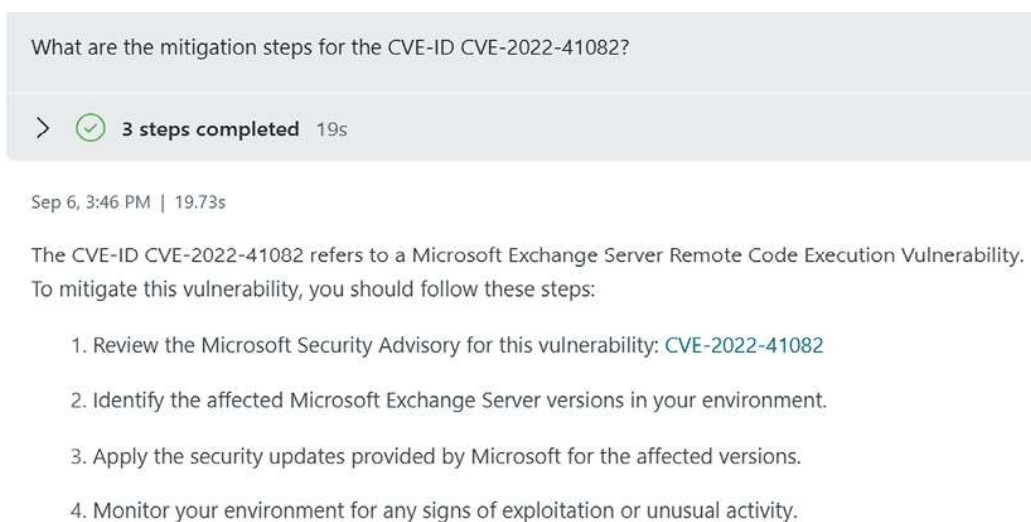
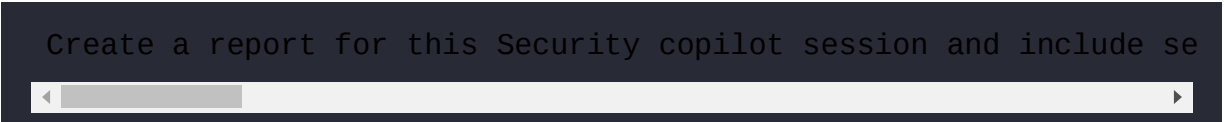


Figure 4.23 – Security Copilot to provide mitigation steps for a CVE

Finally, after gathering sufficient information from Security Copilot, you can request it to generate a report, covering the specific topics discussed. A sample prompt is shown next:

Create a report for this Security copilot session and include se



While Defender XDR offers a comprehensive and unified approach to detecting and responding to threats within an organization's infrastructure, EASM is dedicated to identifying and managing vulnerabilities and risks that are exposed from outside the organization. Next, we will explore how the Microsoft Threat Intelligence plugin in Security Copilot can further assist you in identifying and addressing threats.

Security Copilot Threat Intelligence plugin

Picture your house in a neighborhood. Traditionally, a basic alarm system might alert you if someone breaks a window or opens a door. MDTI is like a comprehensive upgrade of your system to include not only alarms but also advanced surveillance that watches for suspicious behavior in and around your neighborhood. This upgraded system, as an illustrative example of MDTI, gathers data on past criminal activities and the specific traits of repeat offenders. For example, if offenders are known to drive a black sports car with a distinctive decal, this system will alert you if a black sports car with that same decal shows up in your neighborhood. In the realm of cybersecurity, the black sports car represents an **Indicator of Compromise (IOC)**, which is any signal used to identify attackers or the malware they employ. This allows you to take action before a potential threat fully materializes.

MDTI gathers intelligence data from various sources, including internal research, external threat feeds, and industry partnerships, to provide insights

into emerging threats and tactics. An equivalent analogy would be for this upgraded system from the previous example to incorporate information from local law enforcement and neighborhood watch groups.

MDTI not only offers comprehensive protection through threat analysis and identification but also extends its capabilities to monitoring and evaluating the infrastructure used by attackers. It tracks the tools, networks, and tactics employed by cybercriminals. If attackers shift to new infrastructure, such as different IP addresses or new domains, or begin using upgraded malware, the system provides updated threat intelligence on the attacker's new infrastructure, enabling the monitoring and detection of these specific threats and cybercriminals for your organization.

In essence, MDTI is a vast and dynamic repository that is continuously updated with threat data. *“Defender Threat Intelligence enables security professionals to directly access, ingest, and act upon our powerful repository of threat intelligence built from 78 trillion signals and more than 10,000 multidisciplinary experts worldwide.”* (Microsoft Defender Threat Intelligence, <https://www.microsoft.com/en-us/security/business/siem-and-xdr/microsoft-defender-threat-intelligence>). This extensive collection of data is used to assist security teams in detection, analytics, and incident response, helping to uncover and neutralize modern adversaries and cyber threats, including ransomware.

With the MDTI plugin integrated into Security Copilot, you can now tap into its vast amount of knowledge on threats, attack techniques, adversary profiles, and more to assist you during incident investigation, threat detection, and hunting.

As an example, you may request Security Copilot to provide an overview of the latest threats to your organization, as shown in the following screenshot:

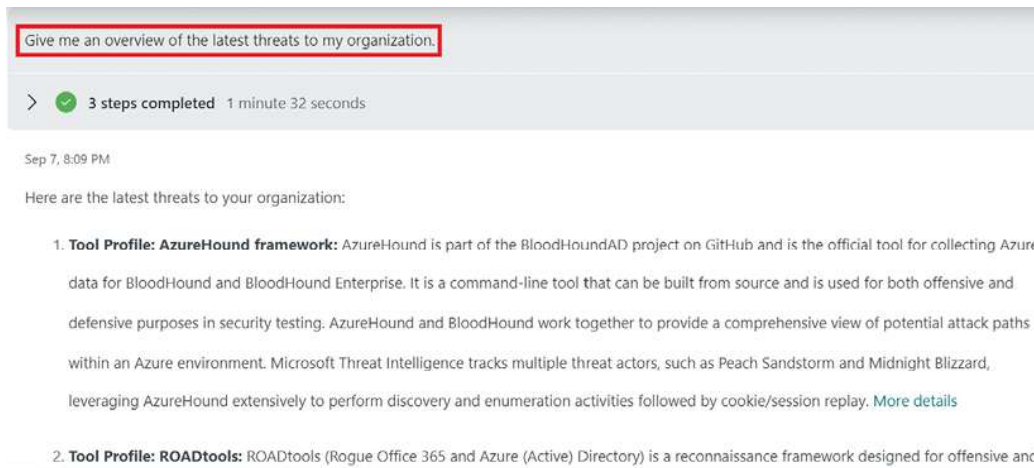


Figure 4.24 – The Copilot prompt utilizing the MDTI plugin

You may then consult Security Copilot for more detailed information on why this poses a threat to your organization, as illustrated next:

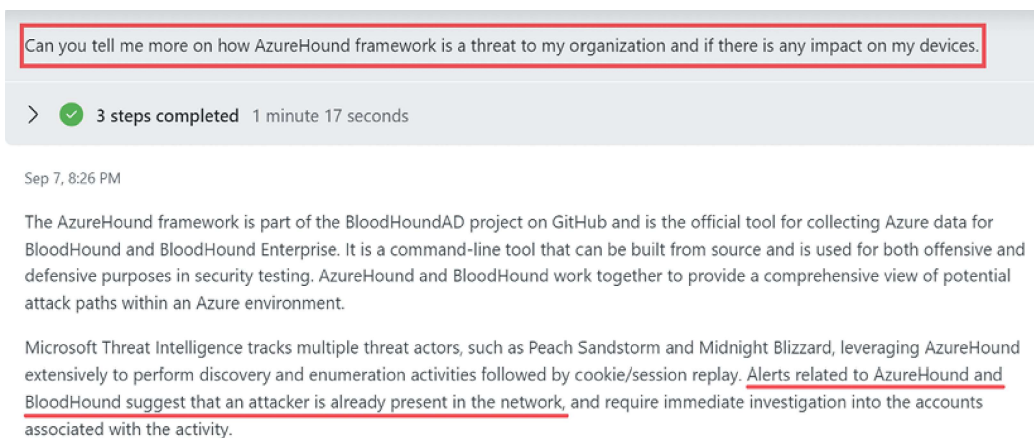


Figure 4.25 – Another Security Copilot prompt example utilizing the MDTI plugin

To get more specific information on this threat, you can request Security Copilot to provide the **Tactics, Techniques, and Procedures (TTPs)** associated with this threat, as well as the IOCs. Following that, you can ask

Security Copilot to generate the detection rules for you. An example Copilot prompt is shown in the following screenshot:

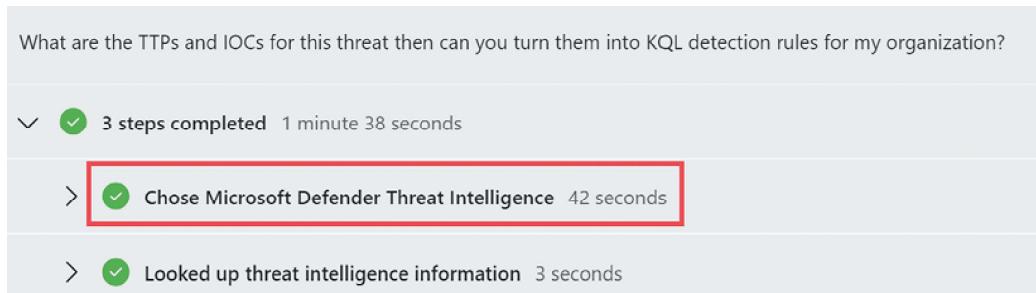


Figure 4.26 – The Copilot prompt utilizing the MDTI plugin

The following screenshot displays a KQL query suggested by Security Copilot:

Based on the above information, you can create KQL detection rules for your organization. Here are some sample KQL queries that you can use as a starting point:

1. Detect AzureHound cmdlet execution activity:

```
1 DeviceProcessEvents
2 | where FileName has "azurehound.exe"
3 | where ProcessCommandLine has "azurehound" and ProcessCommandLine has_any ("az-rm", "az-ad",
"list", "Invoke-azurehound")
4
```

Figure 4.27 – A detection rule provided by Security Copilot

Another KQL query provided by Security Copilot in its response focuses on detecting reconnaissance activity through network logs, as shown next:

2. Detect reconnaissance activity using network logs:

```
1 DeviceNetworkEvents
2 | where RemoteUrl in ("login.microsoftonline.com", "graph.microsoft.com")
3 | where InitiatingProcessCommandLine has_all ("list", "-u", "-p") or InitiatingProcessCommandLine
has_all ("list", "--u", "--p")
4 or InitiatingProcessCommandLine has_all ("list", "--app", "--secret") or
InitiatingProcessCommandLine has_all ("list", "-app", "-secret")
5 or InitiatingProcessCommandLine has_all ("list", "-app", "--cert") or InitiatingProcessCommandLine
has_all ("list", "-app", "-cert")
6 or InitiatingProcessCommandLine has_all ("list", "-j") or InitiatingProcessCommandLine has_all
("list", "--j")
7 | where InitiatingProcessFolderPath !contains "Microsoft"
8 | summarize dcount(RemoteUrl) by bin(Timestamp, 1m), InitiatingProcessFileName, DeviceId
9 | where dcount_RemoteUrl == 2
```

Figure 4.28 – Another detection rule provided by Security Copilot

During an investigation, if you encounter a suspicious domain or IP, you can leverage Security Copilot's MDTI plugin to quickly gather relevant information for you. First, you can prompt Security Copilot to check the reputation of the suspicious domain, for instance, **weinsteinfrog[.]com**, as seen next:

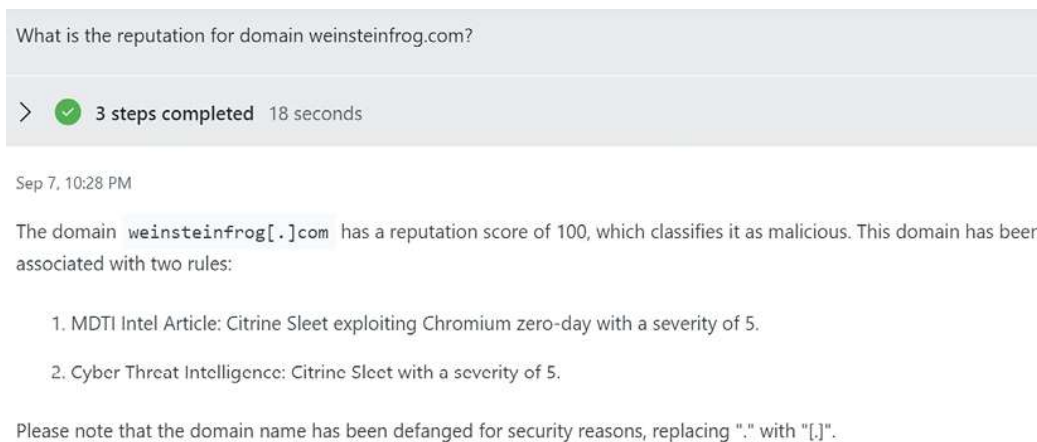


Figure 4.29 – Check the reputation of a suspicious domain

From Security Copilot's response, you learn that this domain, **weinsteinfrog[.]com**, is considered malicious and has been linked to **Citrine Sleet exploiting Chromium zero-day**.

For further analysis, you can request Security Copilot to list the web components for this domain. The Security Copilot prompt and some of its responses are displayed in the following screenshot:

What web components are associated with weinsteinfrog.com?

>  3 steps completed 20 seconds

Sep 7, 10:29 PM

The domain `weinsteinfrog.com` has been associated with the following web components:

Active Resolutions

- IP: 185.135.84.58
 - First Seen: 2024-07-10T23:39:36+00:00
 - Last Seen: 2024-09-07T21:29:33+00:00
 - Source: pingly, Microsoft
 - Collected: 2024-09-08T04:29:34+00:00
 - Record Type: A
 - Record Hash: 04ccafa2fc99c6089cc925a06767fe505c11522dc16f42507cba88fadd3ca159

Figure 4.30 – Grab web components for the suspicious domain

From Security Copilot's results, you obtain an IP address, `185.135.84.58`, associated with the suspicious domain, **weinsteinfrog[.]com**. Now, you can request Security Copilot to pull passive DNS data for this IP address.

Note



Passive DNS records historical data on domain-to-IP mappings, enabling security analysts to observe how an IP address has resolved to various domains over time. This can help to identify additional malicious domains that can be used as IOCs.

To start, you can ask Security Copilot for passive DNS data related to the IP address `185.135.84.58`, including the relevant dates. The following

screenshot displays the prompt along with the first snippet of the response from Security Copilot, which identifies the **weinsteinfrog[.]com** domain as a part of the active resolutions for IP **185.135.84.58**:

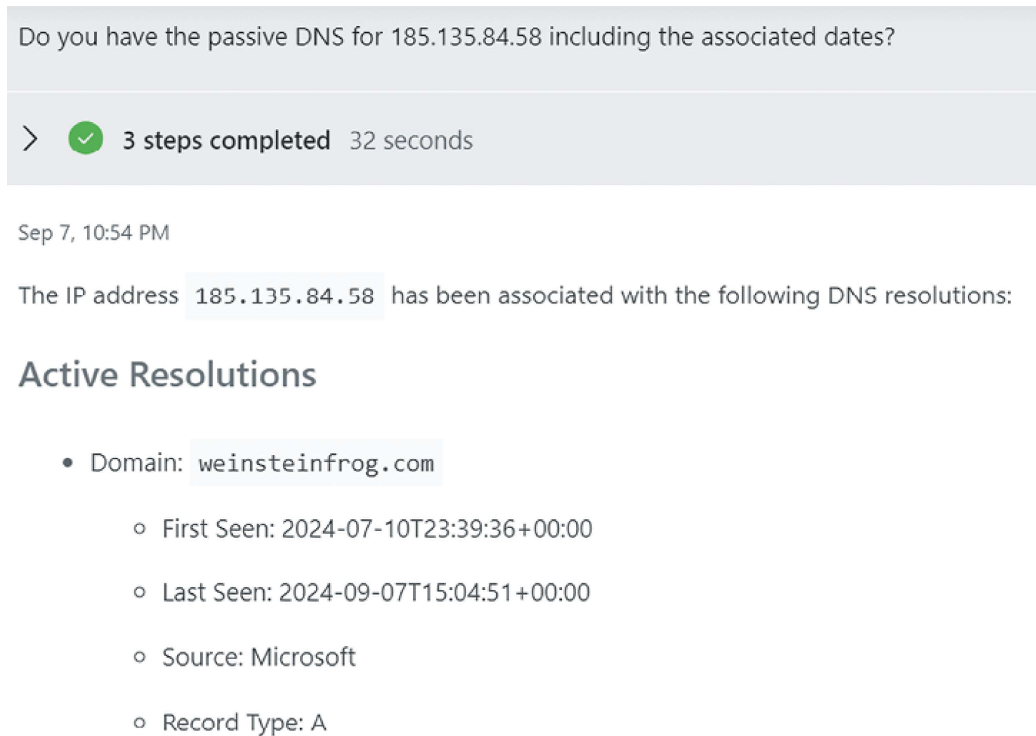


Figure 4.31 – Security Copilot prompt to pull passive DNS data along with its response

The following screenshot displays additional responses generated by Security Copilot, specifically the inactive resolutions. From there, it is quite easy and fast to identify another domain, **www.voyagorclub[.]space**, that has recently been linked to the IP address **185.135.84.58**:

Inactive Resolutions

- Domain: `www.voyagorclub.space`
 - First Seen: 2024-07-10T20:40:56+00:00
 - Last Seen: 2024-09-04T05:52:17+00:00
 - Source: Microsoft
 - Record Type: A
 - Record Hash: e6434c3dbd3922faa8391df5ab73f5b5923d5fb5a20086bb17e2a6d8bc9b5c3d
- Domain: `www.weinsteinfrog.com`
 - First Seen: 2024-07-15T09:20:49+00:00
 - Last Seen: 2024-09-04T05:52:17+00:00
 - Source: Microsoft
 - Record Type: A
 - Record Hash: 9818a81444b4c63b714460b41f9504990f16d596efb208bdbf044cdd9091a0ce

Figure 4.32 – Another domain discovered via passive DNS data

Next, you can consult with Security Copilot to check on the reputation of this newly discovered domain, **`www.voyagorclub[.]space`**. As seen in the following screenshot, Security Copilot reports that this domain is also highly suspicious:



Figure 4.33 – Security Copilot prompt to check domain reputation and its response

Given Security Copilot's assessment of this domain and the fact that the infrastructure hosted by this top-level domain is often linked to suspicious behavior, you may consider adding this domain to your investigation or detection rule as well.

Up to this point, you've observed how Security Copilot can deliver threat intelligence tailored to your organization and provide responses that are updated with the latest threat information. Additionally, Security Copilot allows you to quickly pivot and identify further IOCs.

What you've seen so far represents a subset of the capabilities offered by the MDTI plugin within Security Copilot. This plugin provides many more features beyond what's been mentioned. In a later chapter, we will use a real-life case study to further highlight its additional functions. Meanwhile, the **SYSTEM CAPABILITIES** menu option for this plugin serves as a reference for some of its capabilities or skills you can leverage:

- **Get CVE details by IDs:** Get the details and remediation for a list of CVE IDs
- **Get CVE details by keywords:** Get a list of terse info for CVEs related to a keyword, or if no keyword is provided, a list of recent CVEs
- **Get CVE mitigation:** Get the mitigation or remediation steps of a given CVE
- **Get DNS resolutions by hostname:** Get the DNS resolutions of a given hostname
- **Get DNS resolutions by IP address:** Get the DNS resolutions of a given IP address
- **Get intelligence profile indicators of compromise:** Get the IOCs related to a given intelligence profile

- **Get reputation for indicators of compromise:** Get the reputation details for a list of indicators of compromise.
- **GetRelatedIncidentsByQuery:** Returns the related incidents/alerts in a given time period for matching Threat Analytics reports.
- **Look up threat intelligence:** Look up threat intelligence information like intelligence profiles, articles, and threat analytics.

Before we wrap up our discussion on the MDTI plugin, please note that this feature is also accessible within the embedded experience of Security Copilot as shown in the following screenshot:

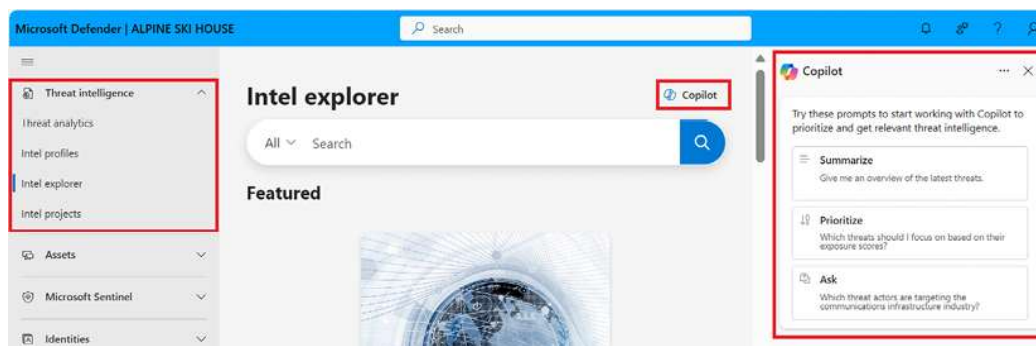


Figure 4.34 – Security Copilot embedded in the Microsoft Defender Threat Intelligence console

Having seen the Microsoft Threat Intelligence plugin in action, next, we will explore how the Microsoft Purview plugin can assist in safeguarding data within the organization.

Security Copilot Purview plugin

Microsoft Purview is a comprehensive solution designed to help organizations to manage and understand their data. It provides tools to classify and organize information, making it easier to see where sensitive data is located and how it is being used. This is particularly useful for

ensuring that data is properly protected and compliant with regulations. Microsoft Purview helps businesses gain insights into their data landscape, making it simpler to manage and safeguard their information.

Microsoft Purview **Data Loss Prevention (DLP)** is a set of strategies and tools aimed at preventing sensitive information from being accidentally or intentionally shared or lost. DLP policies are used to monitor and control how data is handled and shared. By setting up rules and alerts, DLP helps to ensure that confidential information remains secure and is not exposed to unauthorized individuals. This protects against data breaches and helps maintain compliance with privacy laws and regulations.

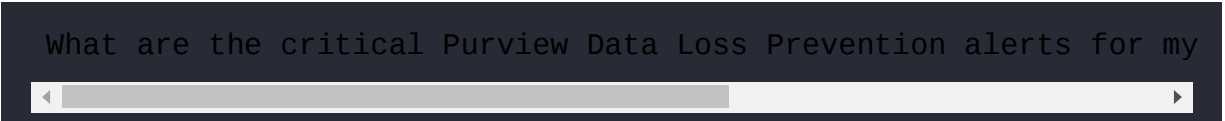
In [Chapter 2](#), we looked into the Security Copilot features provided by the Purview plugin that are embedded directly within the Purview console. The standalone experience of Security Copilot includes all the embedded capabilities, as well as additional ones not offered in the embedded experience.

Again, the **SYSTEM CAPABILITIES** option lists the core capabilities of the Purview plugin, as shown here:

- **Ask Microsoft Purview documentation:** Ask questions or search for information about Microsoft Purview solutions.
- **Get Microsoft Purview data risk summary:** Summarizes risk of the data associated with the security incident or a Data Loss Prevention alert.
- **Get Microsoft Purview user risk summary:** Provides an overview of user risk using Purview Insider Risk Management.
- **Summarize Microsoft Purview alerts:** Summarizes Microsoft Purview alerts from Purview Data Loss Prevention and Insider Risk Management.

- **Triage Microsoft Purview alerts:** Retrieves recent Purview Data Loss Prevention alerts based on severity and status.
- **Zoom into Microsoft Purview data risk:** Identifies attributes like labels or activities for the data in the context of Microsoft Purview.
- **Zoom into Microsoft Purview user risk:** Provides information about the user's activities from Purview Insider Risk Management.

These core skills offer a solid foundation for understanding the types of questions you can pose to Security Copilot. However, the scope of your interactions with Copilot is not limited to these initial queries. You can explore and test a broader range of prompts. For instance, instead of using the **Triage Microsoft Purview alerts** prompt listed in the **SYSTEM CAPABILITIES** menu option, you can ask Security Copilot with this prompt:



What are the critical Purview Data Loss Prevention alerts for my

The response from Security Copilot is displayed in the following screenshot:

What are the critical Purview Data Loss Prevention alerts for my organization that I need to be aware of?

>  3 steps completed 27 seconds

Sep 8, 2:52 PM

Displaying top 5 Microsoft Purview Data Loss Prevention (DLP) alerts with status 'New' and 'High' severity:

 Export to Excel

Alert ID	Alert Title	Severity
dl146bf2fa-7b13-ae61-2e00-08dcd027d07e	DLP policy (U.S. Financial Data) matched for email with subject (Document)	High
dl146bf2fa-7b13-ae61-6e00-08dccf5ea614	DLP policy (U.S. Financial Data) matched for email with subject (Document)	High
dl146bf2fa-7b13-ae61-ae00-08dcce957baa	DLP policy (U.S. Financial Data) matched for email with subject (Document)	High

Figure 4.35 – The Security Copilot prompt and its responses

To gain more insights into a specific alert, you can then request Security Copilot to provide more detailed information. The following screenshot displays an example Security Copilot prompt and its reply:

Can you tell me more about the first alert, with alert ID dl146bf2fa-7b13-ae61-2e00-08dcd027d07e? For example, the information on the DLP policy triggered this alert, the type of the sensitive data involved, and the data loss impact.

>  3 steps completed 27 seconds

Sep 8, 3:01 PM

The high severity DLP alert with ID `dl146bf2fa-7b13-ae61-2e00-08dcd027d07e` and title "DLP policy (U.S. Financial Data) matched for email with subject (Document)" was generated on September 8, 2024, at 17:00:00 UTC. The alert is currently in "new" status and is associated with the user `isbe@[REDACTED]`.

The policy responsible for this alert is named "U.S. Financial Data" with Policy ID `a93b9ed7-8c59-4bcd-b14b-77c586e2a48e`. The rule that triggered the alert is "High volume of content detected U.S. Financial Data" with Rule ID `7ecfc508-7cba-47fe-b978-337fce162126`. This is related to the workload "Exchange".

The email involved in this alert is `isbe@[REDACTED]`. However, the specific sensitive content that matched the policy rule is not provided in the alert details.

Please note that the user `isbe@[REDACTED]` is not marked with any specific risk level in Insider Risk Management.

Figure 4.36 – The Security Copilot prompt and its responses

You may then start your investigation with prompts such as the one displayed next:



Figure 4.37 – The Security Copilot prompt and its responses

There are many prompt examples and resources you can reference when developing your own prompts. A good starting point would be the Security Copilot GitHub resource at <https://github.com/Azure/Copilot-For-Security/tree/main/Sample%20Prompts/Microsoft%20Purview>.

Next, let's dive into the Microsoft Entra plugin and explore its capabilities.

Security Copilot Entra plugin

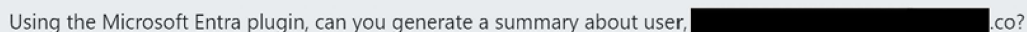
Microsoft Entra is a comprehensive identity and access management solution that secures digital identities and facilitates the management of access to systems and data. Think of it as a central hub where businesses can effectively manage user accounts, ensure secure sign-ins, and control access to sensitive information and resources. Entra also provides log data that is crucial for tracking and investigating security incidents. These logs

offer detailed records of user activities and sign-ins, allowing administrators to quickly identify and address potential security threats.

Whether you're monitoring user activities, managing access, addressing identity risks, or investigating compromised accounts, Security Copilot provides you with the insights and tools to stay ahead. Utilizing data from Entra users, groups, sign-in logs, audit logs, diagnostic logs, and more, Security Copilot makes it simple to detect and analyze any unusual activities that could indicate a security issue.

It enhances your ability to assess and manage risks, respond to security incidents with greater efficiency, and maintain a clearer view of access controls and user activities.

Security Copilot offers insight into user profiles, including contact details and authentication methods. This helps you to manage user accounts more effectively and respond quickly to any authentication issues. As an example, the following screenshot illustrates the Security Copilot prompt requesting user data:

A screenshot of a text prompt in a light blue box. The text reads: "Using the Microsoft Entra plugin, can you generate a summary about user, [REDACTED].co?". The word "user," is followed by a black rectangular redaction box, and ".co?" follows it.

Using the Microsoft Entra plugin, can you generate a summary about user, [REDACTED].co?

Figure 4.38 – The Security Copilot prompt

Security Copilot responds with detailed user information, including the user's name, email address, ID, job title, department, company name, and account status. This is shown next:

The user with the display name "Karla Dickens" has the following details:

- Given Name: Karla
- Surname: Dickens
- Email: [REDACTED].co
- User Principal Name: [REDACTED].co
- ID: [REDACTED]
- Job Title: Account Manager
- Account Status: Enabled
- Created Date and Time: 2024-06-19T14:46:09Z
- Company Name: Niseko
- Department: Sales

Figure 4.39 – The Security Copilot responses

Additionally, Security Copilot gives you a clear picture of any risks associated with individual users. You can access detailed summaries of user accounts and risks, understand the reasons behind flagged accounts, and dive into the factors driving these assessments.

If you need to review sign-in logs, through Security Copilot, you can easily find information on user login attempts, including detailed data from specific dates or recent periods. This feature is valuable for detecting suspicious sign-ins or understanding login patterns.

In addition to monitoring sign-ins, Security Copilot enables you to investigate failed login attempts and the reasons behind them, track authentication methods, and check terms of use agreements. This

thoroughness ensures that any security gaps are identified and addressed promptly.

When it comes to oversight and auditing, Security Copilot simplifies the process of examining changes within your system. Whether it's modifications to applications, user groups, or security policies, you can view comprehensive audit logs detailing who made changes and when. This transparency is crucial for maintaining security and compliance, as it allows for accurate tracking of alterations and helps pinpoint any irregularities.

Once again, the **SYSTEM CAPABILITIES** option in Security Copilot highlights the key features offered by the Microsoft Entra plugin that you can reference:

- **Explore a summary of a user's active risk with Entra ID Protection:** View a detailed summary of a Microsoft Entra ID user's risk
- **Explore diagnostic log collection in Microsoft Entra:** View settings for diagnostic log collection and streaming of activity logs in Microsoft Entra ID
- **Explore Microsoft Entra audit log details:** View changes to applications, groups, users, and licenses in Microsoft Entra ID
- **Find group details in Microsoft Entra:** View Microsoft Entra ID group ownership and membership details
- **Find sign-in logs in Microsoft Entra:** View Microsoft Entra ID sign-in log details, including policy evaluation results
- **Find user details in Microsoft Entra:** View contact information, authentication method registration, and account details for users
- **Investigate identity risks with Entra ID Protection:** View details of Microsoft Entra ID users with high, medium, or low risk of

compromise

Other plugins

Security Copilot comes with additional Microsoft plugins preinstalled. As of March 2025, these plugins are as follows:

- **Microsoft Intune:** Devices, apps, policies, and postures
- **Azure Firewall: Intrusion Detection and Prevention System (IDPS)** signature analysis and fleet-wide IDPS attack investigation
- **Azure Web Application Firewall (Preview):** SQL injection block summaries, XSS block summaries, top WAF rules summaries, and top malicious IP summaries
- **Microsoft Sentinel:** Incidents and workspaces
- **Azure AI Search (Preview):** Indexed data

For your information, the following are some of the core capabilities that the Microsoft Intune plugin brings to Security Copilot:

- **Analyze device configuration error code:** Get detailed information about a device configuration error code
- **Describe device configuration policy:** Summarize and assess the impact of a Microsoft Intune policy
- **Get assignment scope for app or policy:** Get a summary of the number of users and devices that an app or policy is assigned to
- **Get device configuration differences between two devices:** Get a summary of similarities and differences in the configuration of two managed devices
- **Get device group memberships:** Summarize the group memberships of a managed device

- **Get discovered or managed apps for device:** Get a list of Intune managed apps, or software applications, installed on a managed device
- **Get Microsoft Intune Devices:** Get a summary of managed devices with key information for a user
- **Get policies assigned to a device:** Get info on policies assigned to a managed device, including device config and app config
- **Learn about policy setting:** Get detailed info about a device configuration policy setting, including best practices
- **Learn where my policies use a specified setting:** Get info about whether any existing device configuration policies contain a specified setting
- **Understand why a device has app or policy:** Get info about why a managed device has a policy or app by checking its group memberships

Alongside the Microsoft plugins, Security Copilot also includes other built-in plugins. Additionally, there is an extensive array of non-Microsoft plugins available in Security Copilot. Furthermore, you can create your own custom plugins. We will explore these options in more detail in the next few sections.

OpenAI and beyond - Delving into non-Microsoft plugins

The plugin mechanism allows Security Copilot to interact with various external systems and databases, extending Copilot's functionality beyond its core capabilities. This feature sets it apart from competitors as Security Copilot functions both as a product and a platform. Rather than being

restricted to a fixed set of functions, Security Copilot can be expanded and tailored through a wide range of plugins. This modular approach provides flexibility and adaptability to address diverse needs.

The **SYSTEM CAPABILITIES** option in the prompt menu lets you view the list of plugins and their features. In addition to Microsoft plugins, there are also built-in plugins such as the **Generic plugin** and the **Public Web plugin**. Next, let's dive into these two additional plugins.

Built-in plugins in Security Copilot

The Generic plugin is a **GPT-style** plugin that takes input in the prompt and drops it on the AI model. As a built-in plugin, neither the Generic plugin itself nor its skills can be turned off in Security Copilot. Additionally, it acts as a catch-all plugin – when Security Copilot can't find a specific plugin to handle a prompt, Copilot automatically defaults to the Generic plugin.

The Generic plugin is often used in Security Copilot. For instance, in the case study from [Chapter 3](#), this plugin was frequently called to handle prompts, as illustrated in the next three screenshots.

The following first screenshot illustrates that Security Copilot picks the Generic plugin when offering a response regarding the defense evasion technique related to process injection:

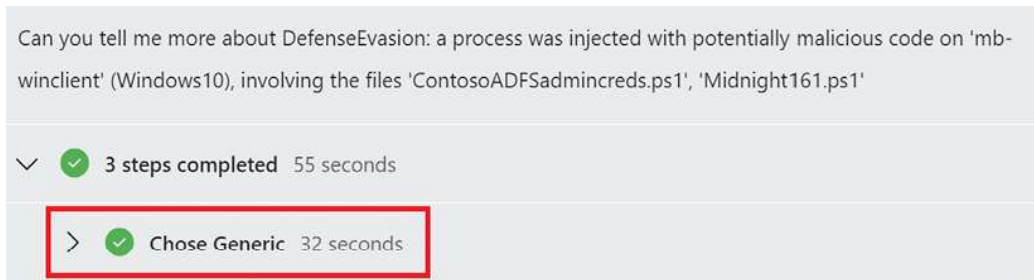


Figure 4.40 – The Generic plugin utilized to provide information on process injection

The following second screenshot shows that Security Copilot employs the Generic plugin when asked about the DCSync attack and its TTPs:

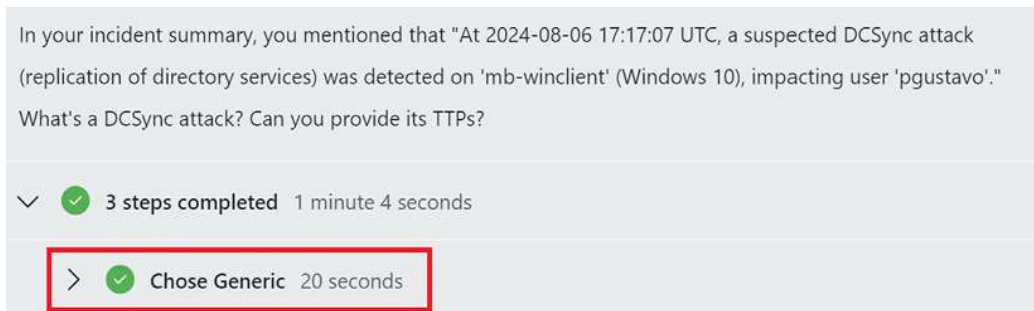


Figure 4.41 – The Generic plugin utilized to provide information on a DCSync attack

The third screenshot demonstrates Security Copilot's ability to recognize encoded commands and even decode them through the Generic plugin:



Figure 4.42 – The Generic plugin utilized to decode and analyze service path

The Generic plugin provides a range of capabilities. In addition to those highlighted in the case study, you can learn more about this plugin by